



RAPPORT AUDIT OFFENSIF ET REMÉDIATION D'UNE INFRASTRUCTURE WINDOWS VIRTUALISÉE – NEOTECH SOLUTIONS

Projet : PENETRATION TESTING & HARDENING

Binôme : EKPEVI Kossi Augustin | MEYISSO Samuel Emmanuel

Programme : Bachelor Cybersécurité & Hacking Éthique

Module : **Projet B1 – SYS&OFF12_2025-2026**

École 89

Date de rendu : Fin mai

Nom du professeur référent : Monsieur Eddy MOZAR

Page de versioning

Version	Taches effectuées	Date	Personne
1.0	Début du projet	17/02/26	Augustin / Samuel
1.1	Mise en place de l'architecture réseau	20/02/26	Samuel / Augustin
1.2	Sélection des vulnérabilités	26/02/26	Samuel
1.3	Mise en place des vms dans virtualbox	02/03/26	Augustin
1.4	Configuration de pare-feu pfsense	15/03/26	Augustin
1.5	Configuration du serveur AD\DHCP\DNS	19/03/26	Augustin
1.6	Configuration du serveur de redondance DHCP\DNS	22/03/26	Augustin
1.7	Configuration du serveur fichier	24/03/26	Augustin
1.8	Configuration du serveur FTP	27/04/26	Augustin
1.9	Mise en place des utilisateurs, machine et GPO mot de passe	29/03/26	Augustin
1.10	GPO de mappage de lecteur (Drive Maps)	03/03/26	Augustin
1.11	Configuration du serveur IIS Web (SRV_WEB)	05/04/26	Augustin
1.12	Mise en place des deux pc clients	06/04/26	Augustin
1.13	Implémentation des vulnérabilités	24/04/26	Samuel
1.14	Audit initiale infrastructure	28/04/26	Samuel
1.15	Implémentation de vulnérabilité	03/05/26	Samuel
1.16	Implémentation de vulnérabilité	04/05/26	Samuel
1.17	Implémentation de vulnérabilité	05/05/26	Samuel
1.18	Implémentation de vulnérabilité	06/05/26	Samuel
1.19	Implémentation de vulnérabilité terminé	07/05/26	Samuel
1.20	Remédiation vulnérabilité	08/05/26	Samuel
1.21	Glossaire	20/05/26	Samuel

1.Introduction

Dans un contexte de numérisation croissante des entreprises, la mise en place et la sécurité des systèmes d'information est devenue un enjeu majeur pour la continuité d'activité et la protection des données sensibles. Le projet SYS12 et OFF12 s'inscrivent dans cette problématique en plaçant les étudiants dans une situation professionnelle réaliste, où ils doivent concevoir, attaquer puis sécuriser une infrastructure réseau simulant une entreprise fictive. À travers ce projet, nous endossons successivement les rôles d'architecte infrastructure, de pentester (Red Team) et d'analyste en sécurité défensive (Blue Team).

2. Contexte

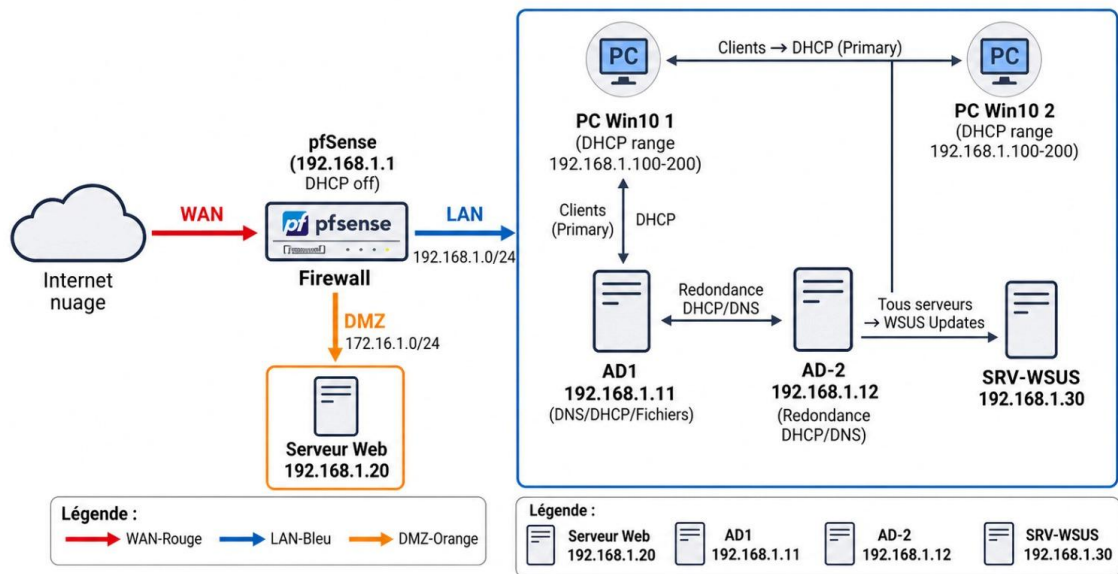
Les cyberattaques ciblent aujourd'hui quotidiennement les organisations, quels que soient leur taille ou leur secteur d'activité. Face à ces menaces, il est indispensable pour les entreprises de connaître leurs vulnérabilités, d'évaluer leur niveau d'exposition et de mettre en œuvre des mesures de protection adaptées.

3. Objectifs du projet

Ce projet propose un environnement d'entreprise fictive, composé d'une infrastructure réseau virtualisée intégrant volontairement des vulnérabilités applicatives, systèmes et réseau, afin de permettre une mise en situation concrète des étudiants. Cette approche favorise l'acquisition de compétences techniques, méthodologiques et comportementales directement transférables au monde professionnel.

5. Conception de l'architecture

SCHÉMA RÉSEAU PROJET SYS12 CYBERSÉCURITÉ



6. Mise en place des Vms

Pour la mise en place du serveur samba, DHCP et DNS on a opter pour une Debian 12

À cause de sa stabilité et de sa sécurité qui en font une base solide pour les serveurs et les systèmes critiques. La philosophie de ses développeurs garantit un système cohérent et soigneusement testé.

Les étapes de sa mise en place des vms

6.1 Adressage réseau

- pfSense LAN : 192.168.1.1
- SRV-AD-1(DHCP/DNS/AD/fichiers & FTP): 192.168.1.11(IP fixe)
- SRV-AD-2 (redondance DHCP & DNS): 192.168.1.12 (IP fixe)
- SRV-WEB (Hébergement IIS) : 192.168.1.20
- SRV-WSUS : 192.168.1.30
- DHCP distribue 192.168.1.100–192.168.1.200 (Plage d'adresse) aux clients
- Deux postes clients : 192.168.1.103 & 192.168.1.104

Rôles de redondance :

- SRV-AD-1 s'occupe du DHCP principal.
- SRV-AD-2 surveille et prend le relais si le premier serveur tombe (via script simple ou config failover).

NB : Pour assurer la continuité du service DHCP en cas de panne du serveur principal (SRV-AD-1), un serveur secondaire (SRV-AD-2) est configuré en redondance. Il utilise la même

plage d'adresses mais avec une priorité plus faible, et un script de monitoring vérifie la disponibilité du primaire toutes les 30 secondes.

Étape 1 : Installer pfSense (pare-feu/routeur)

Préparation VM pfSense

1. Télécharger l'ISO pfSense (gratuit) : <https://www.pfsense.org/download/> (version Community Edition).
2. Créer nouvelle VM VirtualBox :
 - a. Nom : "pfSense-NovaBike".
 - b. Type : BSD, 64-bit.
 - c. RAM : 1 Go (1024 Mo).
 - d. Disque : 20 Go dynamique.
 - e. **Réseau** :
 - i. Adaptateur 1 : Activé - Attaché à "accès par pont " (c'est WAN/Internet).
 - ii. Adaptateur 2 : Activé - Attaché à "inet " (c'est LAN interne).
3. Monte l'ISO pfSense sur la VM, démarre.

Installation pfSense

À l'écran boot, appuyer Entrée sur "Install pfSense".

1. Partition : "Auto (ZFS)" > OK.
2. Clavier : Default.
3. Package : "No".
4. Laisse installer .
5. **Important** : Notez les interfaces détectées (ex: em0 = WAN, em1 = LAN).
6. Assigner interfaces :
 - a. WAN = em0 (NAT).
 - b. LAN = em1 (INET_LAN).
 - c. Autres = none.
7. Configure LAN IP :
 - a. IP : 192.168.1.1/24
 - b. IPv4 Gateway : none
 - c. DHCP server : ON (plage d'adresse: 192.168.1.100-192.168.1.150 temporairement, on changera après).

Figure 2 – Configuration des deux interfaces réseau de pfSense dans VirtualBox (WAN vers Internet, LAN vers réseau interne)

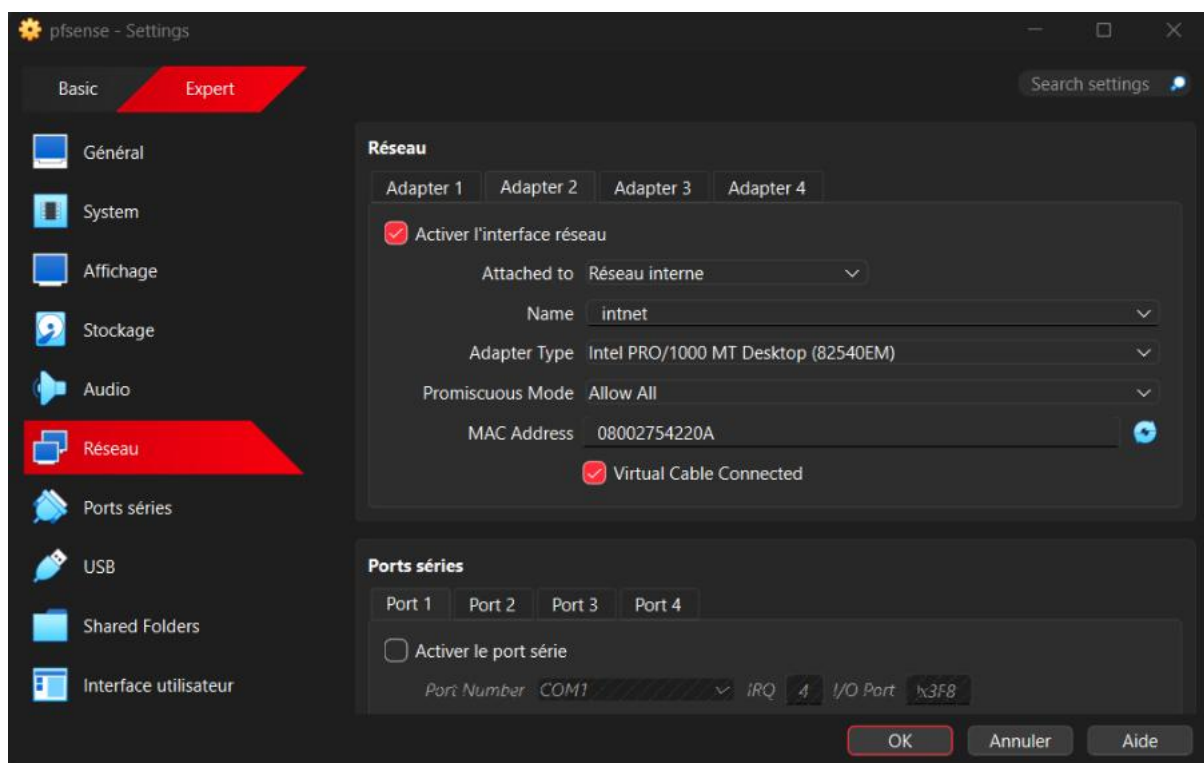
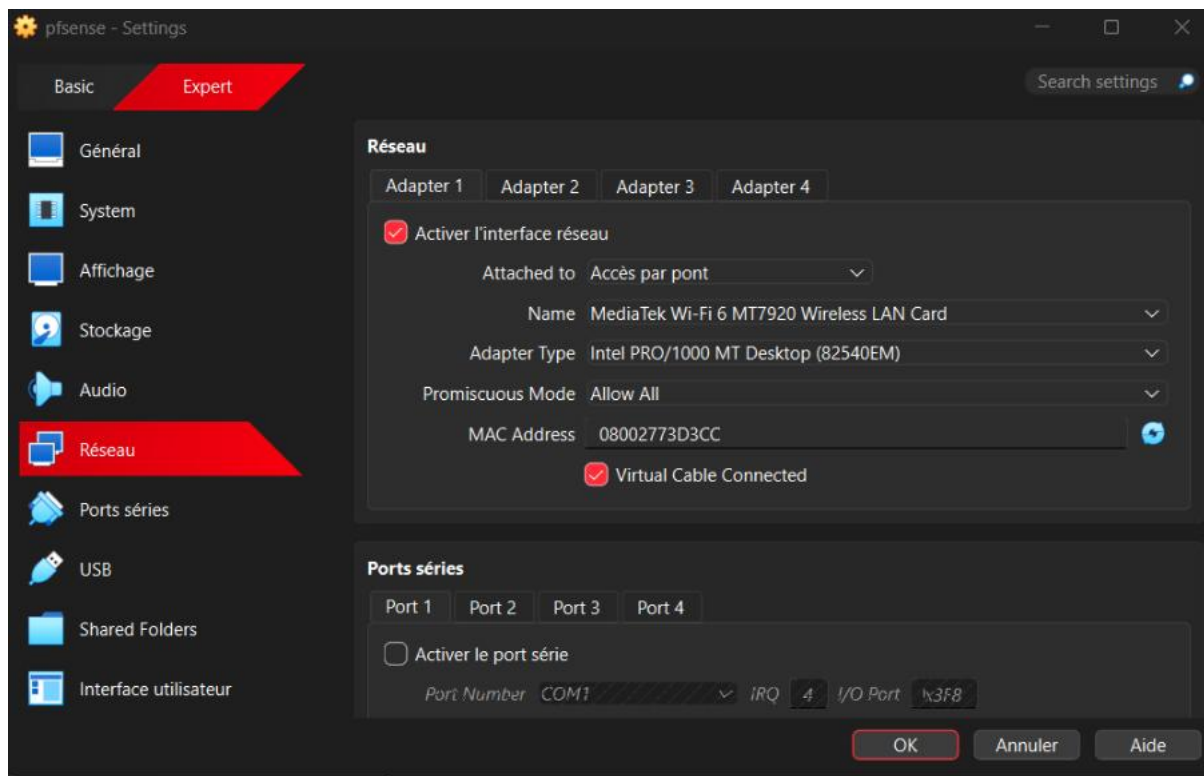


Figure 3 – Assignment automatique des interfaces physiques (em0=WAN, em1=LAN)

```
VirtualBox Virtual Machine - Netgate Device ID: caf86d9ad7be325c9973

*** Welcome to pfSense 2.6.0-RELEASE (amd64) on pfSense ***

WAN (wan)      -> em0      -> v4/DHCP4: 192.168.0.20/24
LAN (lan)      -> em1      -> v4: 192.168.1.1/24
```

Figure 4 – Test de connectivité depuis un poste client : IP obtenue par DHCP et Accès par pont.

```
PS C:\Users\vboxuser> ping 192.168.1.1

Envoi d'une requête 'Ping' 192.168.1.1 avec 32 octets de données :
Réponse de 192.168.1.1 : octets=32 temps=1 ms TTL=64
Réponse de 192.168.1.1 : octets=32 temps=2 ms TTL=64
Réponse de 192.168.1.1 : octets=32 temps=3 ms TTL=64
Réponse de 192.168.1.1 : octets=32 temps=2 ms TTL=64

Statistiques Ping pour 192.168.1.1:
    Paquets : envoyés = 4, reçus = 4, perdus = 0 (perte 0%),
Durée approximative des boucles en millisecondes :
    Minimum = 1ms, Maximum = 3ms, Moyenne = 2ms
PS C:\Users\vboxuser>
```

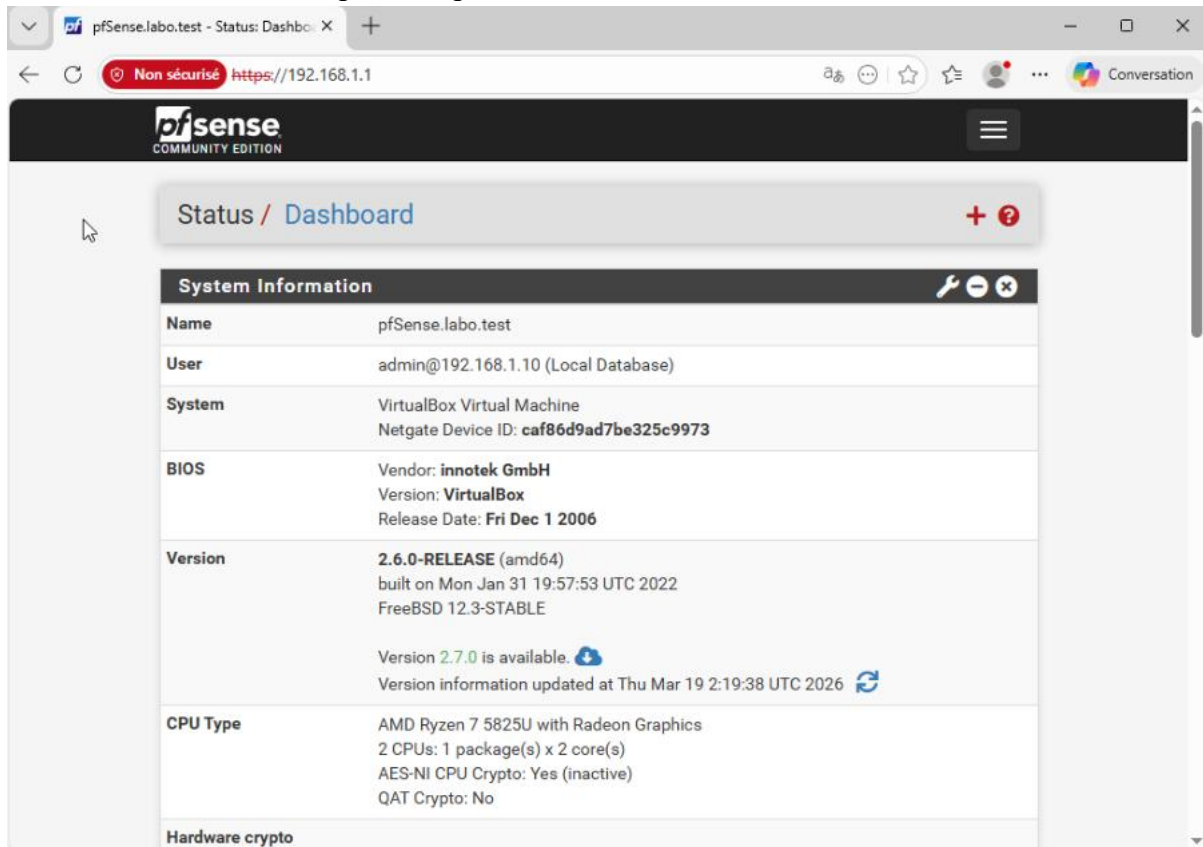
Le client ping le pare feu pfsense

```
PS C:\Users\vboxuser> ping 8.8.8.8

Envoi d'une requête 'Ping' 8.8.8.8 avec 32 octets de données :
Réponse de 8.8.8.8 : octets=32 temps=37 ms TTL=115
Réponse de 8.8.8.8 : octets=32 temps=121 ms TTL=115
Réponse de 8.8.8.8 : octets=32 temps=17 ms TTL=115
Réponse de 8.8.8.8 : octets=32 temps=17 ms TTL=115

Statistiques Ping pour 8.8.8.8:
    Paquets : envoyés = 4, reçus = 4, perdus = 0 (perte 0%),
Durée approximative des boucles en millisecondes :
    Minimum = 17ms, Maximum = 121ms, Moyenne = 48ms
PS C:\Users\vboxuser>
```

Connexion internet via le pare-feu pfsense établie



Connexion à la page pfsense via le pc client réussie

Texte rapport (section 3.1 Installation pfSense)

pfSense est installé comme routeur/pare-feu frontal. Il sépare le réseau interne de l'entreprise (192.168.1.0/24) d'Internet. L'interface WAN utilise le NAT de VirtualBox pour simuler un accès Internet, tandis que LAN est configurée en 192.168.1.1/24 avec DHCP temporaire. Un mot de passe fort a été défini pour l'admin. Les tests confirment la connectivité (ping réussi vers 8.8.8.8 et entre machines).

Étape 2 : Installer les 2 serveurs AD Windows Server 2022

2.1 Préparation Vms (à faire pour les deux serveurs AD)

Pour **chaque** serveur (1 puis 2) :

1. Télécharger ISO Windows Server 2022 (évaluation gratuite 180 jours) :
<https://www.microsoft.com/fr-fr/evalcenter/evaluate-windows-server-2022>
2. Nouvelle VM VirtualBox :
 - a. Nom: "SRV-AD-1" puis "SRV-AD-2".

- b. Type : Microsoft Windows, 64-bit.
 - c. **RAM** : 4 Go chacun (si tu as 16 Go total, OK).
 - d. CPU : 2 cœurs.
 - e. Disque : 60 Go dynamique.
 - f. **Réseau** : Adaptateur 1 - “NVB_LAN” seulement.
3. Monte ISO Windows Server, démarre.

2.2 Installation Windows Server (identique pour les deux)

1. Langue : Français.
2. Édition : “Windows Server 2022 Standard (Desktop Expérience)”.
3. Clé : ignorer (évaluation).
4. Partition : Nouveau > 60 Go > Suivant.
5. Installe (10 min), reboot.
6. Premier démarrage :
 - a. Nom machine: “SRV-AD-1” (ou 2).
 - b. Mot de passe admin : “Bless9626@” (fort).

Après installation :

- IP statique : Ouvrir Paramètres - Réseau - Ethernet - Propriétés - IPv4 :
 - o SRV-AD-Primary: IP 192.168.1.11, Masque 255.255.255.0, Passerelle 192.168.1.1, DNS 192.168.1.10
 - o SRV-AD-Secondary: IP 192.168.1.12, Masque 255.255.255.0, Passerelle 192.168.1.1, DNS 192.168.1.10
- Test : ping 192.168.1.1 et ping 8.8.8.8 depuis les deux serveurs.

Figure 6 – Configuration réseau SRV-AD-1 : connecté uniquement au réseau interne intnet

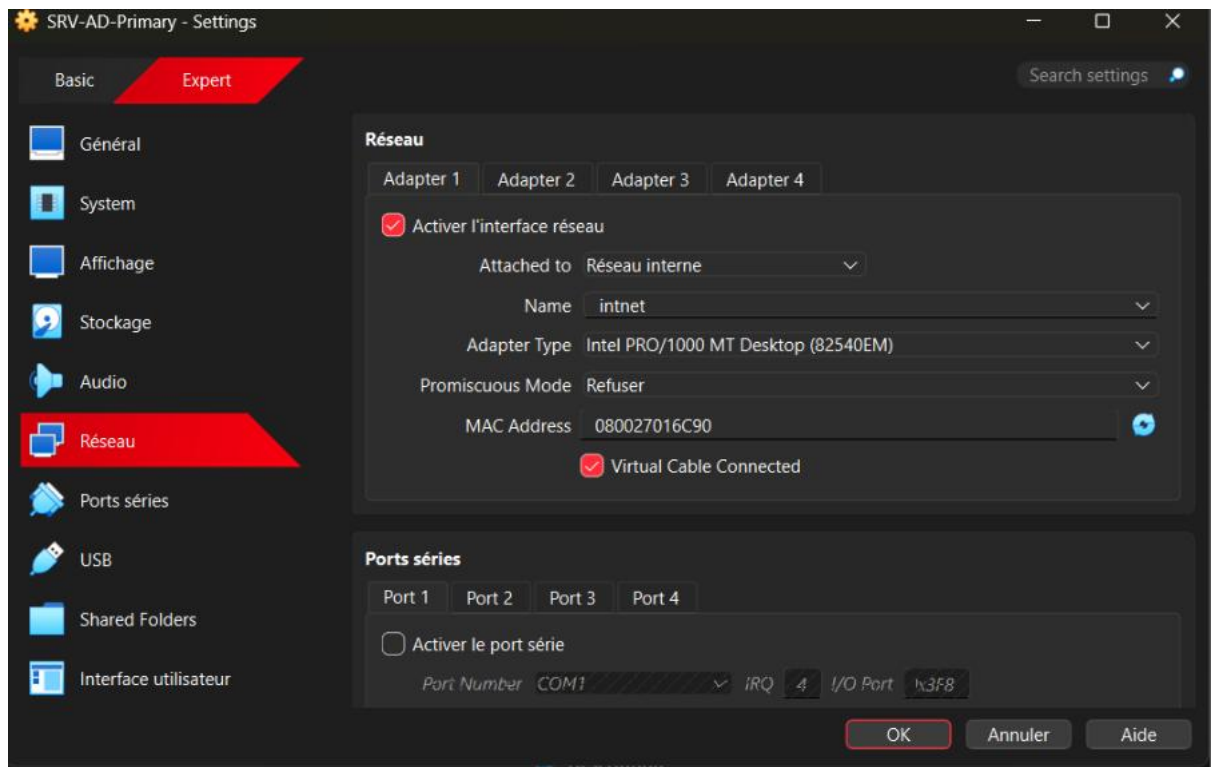


Figure 7– Configuration réseau SRV-AD-2 : connecté uniquement au réseau interne intnet

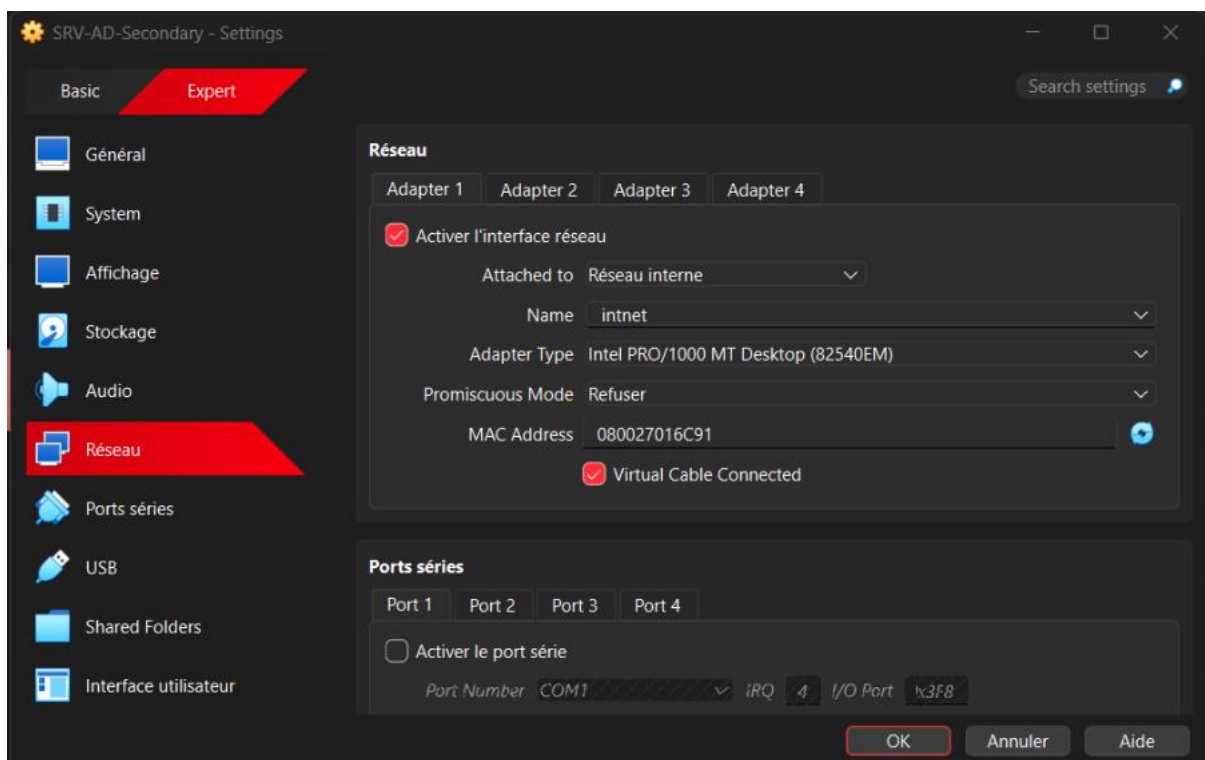


Figure 8 – Adressage statique 192.168.1.11 sur SRV-AD-Primary, passerelle vers pfSense

```
Carte Ethernet Ethernet :  
  
Suffixe DNS propre à la connexion. . . : labo.test  
Adresse IPv6 de liaison locale. . . . : fe80::44bd:abec:2ef:8fda%3  
Adresse IPv4. . . . . : 192.168.1.11  
Masque de sous-réseau. . . . . : 255.255.255.0  
Passerelle par défaut. . . . . : fe80::a00:27ff:fe54:220a%3  
192.168.1.1
```

```
192.168.1.1  
PS C:\Users\Administrateur> ping 192.168.1.1  
  
Envoi d'une requête 'Ping' 192.168.1.1 avec 32 octets de données :  
Réponse de 192.168.1.1 : octets=32 temps=1 ms TTL=64  
Réponse de 192.168.1.1 : octets=32 temps=4 ms TTL=64  
Réponse de 192.168.1.1 : octets=32 temps=1 ms TTL=64  
Réponse de 192.168.1.1 : octets=32 temps=1 ms TTL=64  
  
Statistiques Ping pour 192.168.1.1:  
    Paquets : envoyés = 4, reçus = 4, perdus = 0 (perte 0%),  
Durée approximative des boucles en millisecondes :  
    Minimum = 1ms, Maximum = 4ms, Moyenne = 1ms  
PS C:\Users\Administrateur> _
```

Bonne connectivité entre pfsense et SRV-AD-1.

Figure 8 – Vérification de la connectivité Internet via pfSense depuis un serveur du réseau local

```
PS C:\Users\Administrateur> ping 8.8.8.8  
  
Envoi d'une requête 'Ping' 8.8.8.8 avec 32 octets de données :  
Réponse de 8.8.8.8 : octets=32 temps=14 ms TTL=115  
Réponse de 8.8.8.8 : octets=32 temps=20 ms TTL=115  
Réponse de 8.8.8.8 : octets=32 temps=13 ms TTL=115  
Réponse de 8.8.8.8 : octets=32 temps=14 ms TTL=115  
  
Statistiques Ping pour 8.8.8.8:  
    Paquets : envoyés = 4, reçus = 4, perdus = 0 (perte 0%),  
Durée approximative des boucles en millisecondes :  
    Minimum = 13ms, Maximum = 20ms, Moyenne = 15ms  
PS C:\Users\Administrateur> _
```

Figure 9 – Adressage statique 192.168.1.11 sur SRV-AD-1, passerelle vers pfSense


```
PS C:\Users\Administrateur> ipconfig

Configuration IP de Windows

Carte Ethernet Ethernet :

    Suffixe DNS propre à la connexion. . . : labo.test
    Adresse IPv6 de liaison locale. . . . : fe80::1547:6116:1a25:9ee2%3
    Adresse IPv4. . . . . : 192.168.1.12
    Masque de sous-réseau. . . . . : 255.255.255.0
    Passerelle par défaut. . . . . : fe80::a00:27ff:fe54:220a%3
                                     192.168.1.1
PS C:\Users\Administrateur>

192.168.1.1
PS C:\Users\Administrateur> ping 192.168.1.1

Envoi d'une requête 'Ping' 192.168.1.1 avec 32 octets de données :
Réponse de 192.168.1.1 : octets=32 temps=1 ms TTL=64
Réponse de 192.168.1.1 : octets=32 temps=1 ms TTL=64
Réponse de 192.168.1.1 : octets=32 temps=1 ms TTL=64
Réponse de 192.168.1.1 : octets=32 temps=1 ms TTL=64

Statistiques Ping pour 192.168.1.1:
    Paquets : envoyés = 4, reçus = 4, perdus = 0 (perte 0%),
    Durée approximative des boucles en millisecondes :
        Minimum = 1ms, Maximum = 1ms, Moyenne = 1ms
PS C:\Users\Administrateur>
```

Les tests de connexions présentent une bonne connectivité entre pfSense et SRV-AD-2.

Figure 10 – Vérification de la connectivité Internet via pfSense depuis le serveur

```
PS C:\Users\Administrateur> ping 8.8.8.8

Envoi d'une requête 'Ping' 8.8.8.8 avec 32 octets de données :
Réponse de 8.8.8.8 : octets=32 temps=16 ms TTL=115
Réponse de 8.8.8.8 : octets=32 temps=20 ms TTL=115
Réponse de 8.8.8.8 : octets=32 temps=13 ms TTL=115
Réponse de 8.8.8.8 : octets=32 temps=20 ms TTL=115

Statistiques Ping pour 8.8.8.8:
    Paquets : envoyés = 4, reçus = 4, perdus = 0 (perte 0%),
    Durée approximative des boucles en millisecondes :
        Minimum = 13ms, Maximum = 20ms, Moyenne = 17ms
PS C:\Users\Administrateur>
```

Texte rapport section 3.2 :

Les serveurs Windows Server 2022 sont installés en machines virtuelles VirtualBox avec 4 Go RAM et IP statiques. Chaque serveur communique avec pfSense (192.168.1.1) et accède à Internet.

Étape 3 : Active Directory + DNS + DHCP Failover

3.1 Sur SRV-AD-1 d'abord

1. **Promouvoir en contrôleur de domaine :**
 - a. PowerShell admin: Install-WindowsFeature AD-Domain-Services - IncludeManagementTools
 - b. Puis : Install-ADDSForest -DomainName "neotech.local" -InstallDns
 - c. Mot de passe DSRM : "neotech2026!"
 - d. Reboot.
2. **Configurer DNS** (il est auto avec AD) : Vérifier dans DNS Manager que zone "neotech.local" existe.
3. **Installer DHCP:** Install-WindowsFeature DHCP -IncludeManagementTools
4. **Autoriser DHCP :** DHCP Manager - clic droit serveur - Autoriser.
5. **Créer scope DHCP :**
 - a. Nouveau scope "Neotech-Scope".
 - b. Plage : 192.168.1.100 - 192.168.1.200
 - c. Masque : 255.255.255.0
 - d. Routeur : 192.168.1.1
 - e. DNS : 192.168.1.10
 - f. Activer scope.

3.2 Configurer Failover avec SRV-AD-Secondary

Sur Secondary d'abord :

1. Rejoint au domaine: Add-Computer -DomainName neotech.local -Credential (Get-Credential) (admin@novabike.local / NovaBike2026!)
2. Reboot, login admin domaine.
3. Installe AD DS, DNS, DHCP (mêmes commandes).
4. Autorise DHCP.

Maintenant le failover (sur Primary) :

1. DHCP Manager - clic droit IPv4 - Configurer Failover.
2. Ajouter partenaire : 192.168.1.11
3. Mode: Hot Standby (Secondary backup).
4. Partage : 60% Primary / 40% Secondary.
5. Maximum Client Lead Time : 1 heure.
6. State Switchover Interval : 15 min.
7. Terminer.

Vérification : Sur les deux serveurs, DHCP Manager doit montrer “Partner Server : Active”.

Afficher/Modifier une relation de basculement ? X

Modifiez les paramètres relatifs à la relation de basculement :

Nom de la relation : win-kpd2abs9vfg.novabike.local-192.168.1.1

État de ce serveur : Normale
Remplacer par le partenaire hors service

État du serveur partenaire : Normale

☐ Activer l'authentification du message
Secret partagé :

☒ Intervalle de basculement d'état : 15 minutes

Délai de transition maximal du client (MCLT) : 1 heures 0 minutes

☒ Mode d'équilibrage de charge
Serveur local : 60 %
Serveur partenaire : 40 %

☐ Mode du serveur de secours
Rôle de ce serveur : Actif
Adresses réservées pour le serveur de secours : 5 %

OK Annuler

Test redondance (avant utilisateurs)

Maintenant le test décisif :

1. **Créer VM Windows 10 "PC-Neotech" - NVB_LAN - démarrer.**
2. Sur PC : ipconfig /renew - note IP/source (1).
3. **ÉTEINS SRV-AD-1 complètement.**
4. Sur PC : ipconfig /release - /renew - **doit donner NOUVELLE IP via 2 !**
5. Ping 192.168.1.1 OK ?
6. Rallume 1 - tout sync auto.

Configuration de basculement.

Adresse du pc connecté au serveur DHCP principal :

```
PS C:\Users\vboxuser> ipconfig /renew

Configuration IP de Windows

Carte Ethernet Ethernet :

    Suffixe DNS propre à la connexion. . . : labo.test
    Adresse IPv6 de liaison locale. . . . : fe80::314e:e8ea:ad5a:9a12%6
    Adresse IPv4. . . . . : 192.168.1.10
    Masque de sous-réseau. . . . . : 255.255.255.0
    Passerelle par défaut. . . . . : fe80::a00:27ff:fe54:220a%6
                                      192.168.1.1

PS C:\Users\vboxuser>
```

Le pc n'a plus d'adresse ip après avoir éteint le serveur DHCP principal :

```
PS C:\Users\vboxuser> ipconfig /release

Configuration IP de Windows

Carte Ethernet Ethernet :

    Suffixe DNS propre à la connexion. . . : labo.test
    Adresse IPv6 de liaison locale. . . . : fe80::314e:e8ea:ad5a:9a12%6
    Passerelle par défaut. . . . . : fe80::a00:27ff:fe54:220a%6

PS C:\Users\vboxuser>
```

Quand on a fait un ipconfig /renew le pc a eu une adresse ip donner par le serveur DHCP de redondance :

```
PS C:\Users\vboxuser> ipconfig /renew

Configuration IP de Windows

Carte Ethernet Ethernet :

    Suffixe DNS propre à la connexion. . . : labo.test
    Adresse IPv6 de liaison locale. . . . : fe80::314e:e8ea:ad5a:9a12%6
    Adresse IPv4. . . . . : 192.168.1.10
    Masque de sous-réseau. . . . . : 255.255.255.0
    Passerelle par défaut. . . . . : fe80::a00:27ff:fe54:220a%6
                                      192.168.1.1
```

Le pc arrive à ping le pare-feu :

```
PS C:\Users\vboxuser> ping 192.168.1.1

Envoi d'une requête 'Ping' 192.168.1.1 avec 32 octets de données :
Réponse de 192.168.1.1 : octets=32 temps=1 ms TTL=64
Réponse de 192.168.1.1 : octets=32 temps=2 ms TTL=64
Réponse de 192.168.1.1 : octets=32 temps=1 ms TTL=64
Réponse de 192.168.1.1 : octets=32 temps=1 ms TTL=64

Statistiques Ping pour 192.168.1.1:
    Paquets : envoyés = 4, reçus = 4, perdus = 0 (perte 0%),
Durée approximative des boucles en millisecondes :
    Minimum = 1ms, Maximum = 2ms, Moyenne = 1ms
```

Texte rapport :

Après optimisation, le failover utilise 60% Primary / 40% Secondary avec basculement en 5 minutes. Les tests confirment une reprise fluide du service DHCP.

2.5. Vérifier la présence de SYSVOL sur les deux DC

- Net share sur SRV-AD_1 montrant SYSVOL.
- net share sur SRV-AD_2 montrant SYSVOL.

```
PS C:\Users\Administrateur> net share

Nom partage  Ressource                                Remarque
-----
C$           C:\                                     Partage par défaut
IPC$         C:\                                     IPC distant
ADMIN$       C:\Windows                             Administration à distance
NETLOGON     C:\Windows\SYSVOL\novabike.local\SCRIPTS
SYSVOL       C:\Windows\SYSVOL\sysvol              Partage de serveur d'accès
La commande s'est terminée correctement.
```

2.7. Texte rapport

Deux serveurs Windows Server 2022, SRV-AD_1 et SRV-AD_2, ont été déployés comme contrôleurs de domaine du même domaine Active Directory. SRV-AD_2 a d'abord été joint au domaine, puis promu en contrôleur de domaine additionnel.

Les deux serveurs exposent les partages NETLOGON et SYSVOL, ce qui confirme la réplication de l'annuaire et des stratégies de groupe. En cas d'arrêt de SRV-AD_1, SRV-AD_2 est capable de continuer à authentifier les utilisateurs et à appliquer les GPO, assurant ainsi la redondance demandée.

Étape 8 : Utilisateurs + Groupes neotech

3. Organisation AD : OU + groupes (simple, mais très important)

Le sujet impose 6 “familles” : Direction, Technique, Commercial, Support, Serveurs, Postes.

3.1. Créer l’arborescence OU

Sur SRV-AD_1 (ou SRV-AD_2) :

1. Ouvrez **Outils - Utilisateurs et ordinateurs Active Directory**.
2. Clic droit sur le nom de votre domaine - **Nouveau - Unité d’organisation** :
 - a. Nom : ou SYS12.
3. Clic droit sur cette nouvelle OU - Nouveau - **Unité d’organisation** :
 - a. Créez les 6 OU suivantes :
 - i. Direction
 - ii. Technique
 - iii. Commercial
 - iv. Support
 - v. Serveurs
 - vi. Postes

3.2. Créer les groupes de sécurité

Toujours dans ADUC :

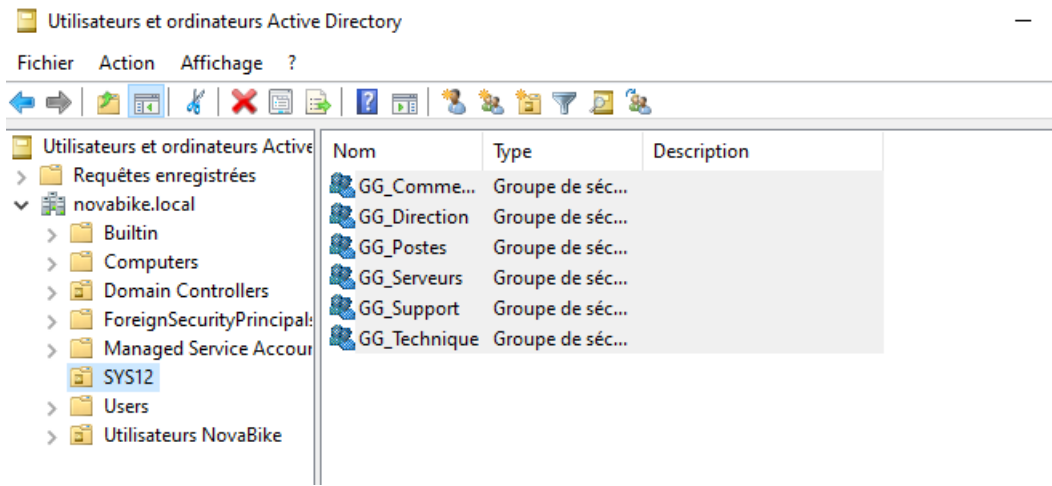
1. Clic droit sur l’OU neotech (ou une sous-OU Groupes si tu veux en créer une) → **Nouveau → Groupe**.
2. Pour chaque service, crée un groupe :
 - a. Nom : GG_Direction - Type : **Sécurité** - Étendue : **Globale**.
 - b. Pareil pour GG_Technique, GG_Commercial, GG_Support, GG_Serveurs, GG_Postes.

3.3. Ranger quelques utilisateurs dedans

1. Prends des utilisateurs que tu as déjà créés (ex : gerant, admin.atelier, etc.).
2. Clic droit sur l’utilisateur - **Déplacer** - choisissez l’OU qui correspond (ex. Direction).
3. Clic droit sur l’utilisateur - **Propriétés** - onglet **Membre de** - **Ajouter** :
 - a. Tapez GG_Direction ou le groupe correspondant.

3.4. Screenshots

Fenêtre avec la liste des groupes GG_Direction, GG_Technique, etc.



Fiche d'un utilisateur (onglet **Membre de**) montrant qu'il fait partie du bon groupe.

Utilisateur	Groupe
dir.general	GG_Direction
tech.01	GG_Technique
commercial.01	GG_Commercial
support.01	GG_Support
srv.admin	GG_Serveurs
poste.01	GG_Postes

La fenêtre de création d'un utilisateur.

Nouvel objet - Utilisateur

Créer dans : novabike.local/SYS12

Prénom : tech Initiales :

Nom : .01

Nom complet : tech .01

Nom d'ouverture de session de l'utilisateur :
tech .01 @novabike.local

Nom d'ouverture de session de l'utilisateur (antérieur à Windows 2000) :
NOVABIKE\ tech .01

< Précédent Suivant > Annuler

Nouvel objet - Utilisateur

Créer dans : novabike.local/SYS12

Mot de passe :

Confirmer le mot de passe :

☒ L'utilisateur doit changer le mot de passe à la prochaine ouverture de session

☐ L'utilisateur ne peut pas changer de mot de passe

☐ Le mot de passe n'expire jamais

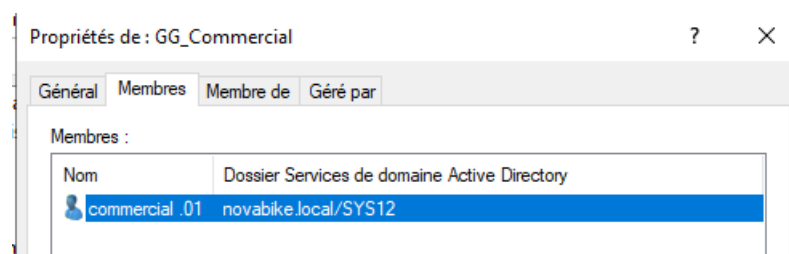
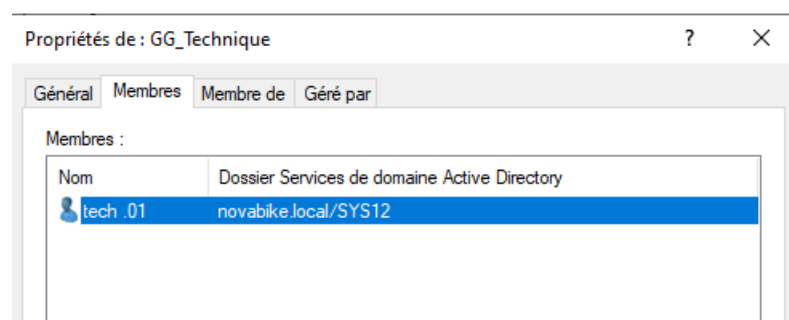
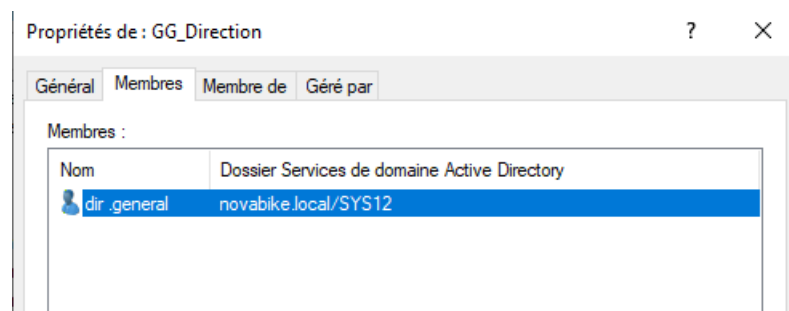
☐ Le compte est désactivé

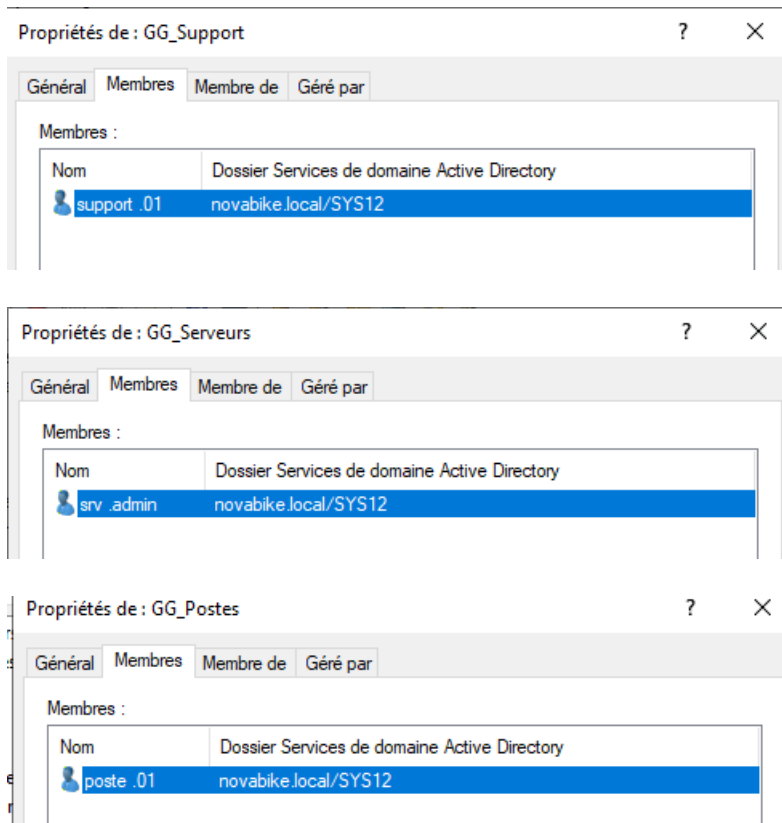
< Précédent Suivant > Annuler

Liste d'utilisateur créé

	dir .general	Utilisateur
	tech .01	Utilisateur
	commercial ...	Utilisateur
	support .01	Utilisateur
	srv .admin	Utilisateur
	poste .01	Utilisateur

L'onglet membre montrant le groupe associé.





3.5. Texte rapport

L'annuaire Active Directory a été structuré autour des services de l'entreprise. Une unité d'organisation "NEOTECH" regroupe six sous-OU : Direction, Technique, Commercial, Support, Serveurs et Postes.

Pour chaque service, un groupe de sécurité global (GG_Direction, GG_Technique, GG_Commercial, GG_Support, GG_Serveurs et GG_Postes) a été créé. Les utilisateurs sont déplacés dans l'OU correspondant à leur service et ajoutés au groupe de sécurité associé, ce qui permet de gérer les droits d'accès par métier plutôt qu'utilisateur par utilisateur.

1. GPO mot de passe

Le sujet SYS12 demande une politique de mot de passe. La bonne pratique est de la mettre dans la **Default Domain Policy**, au niveau du domaine, car c'est elle qui s'applique à tous les comptes du domaine.

Ce qu'il faut faire

1. Sur **SRV-AD_1**, ouvre **Group Policy Management**:
 - a. Win + R
 - b. Tapez gpmc.msc
 - c. Entrée.

2. Déplier le domaine.
3. Cliquer sur **Default Domain Policy**.
4. Clic droit - **Edit**.
5. Va dans :
 - a. **Computer Configuration**
 - b. **Policies**
 - c. **Windows Settings**
 - d. **Security Settings**
 - e. **Account Policies**
 - f. **Password Policy**

Ce qu'il faut régler

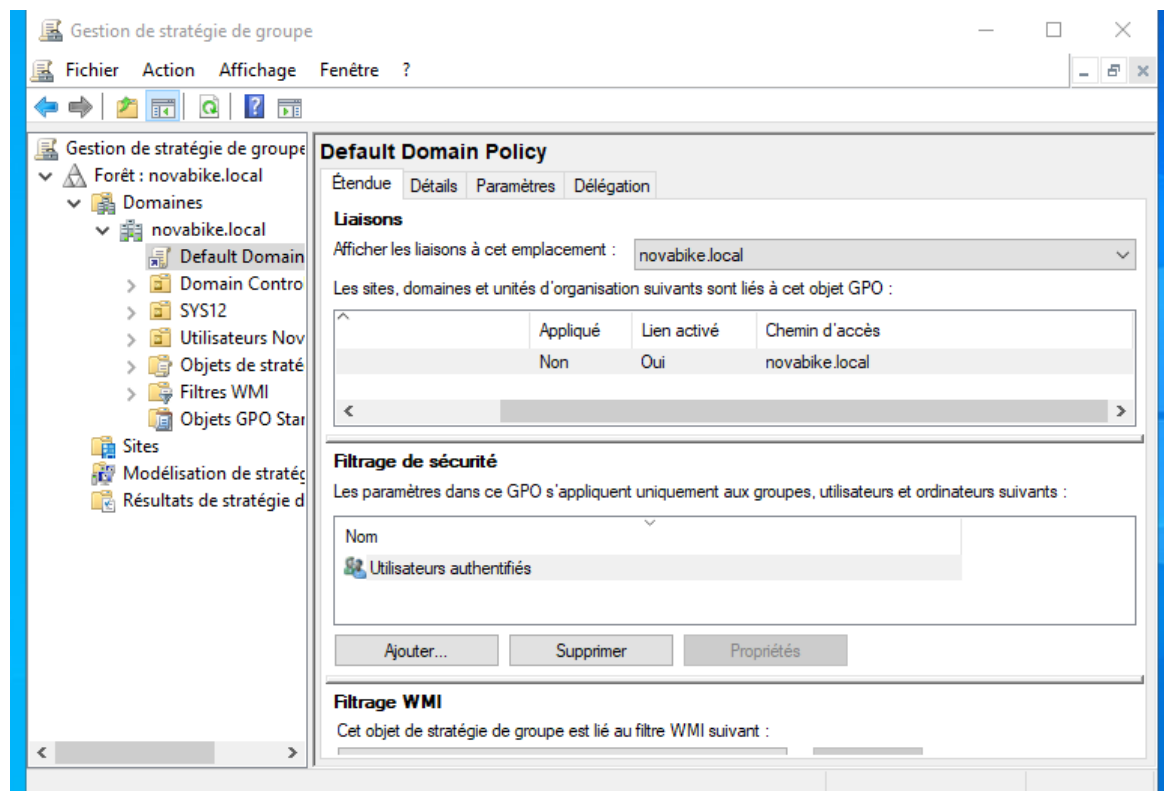
Mettre au minimum :

- **Longueur minimale d'un mot de passe** : 8.
- **Politiques de complexité de mot de passe** : Activé.
- **Durée maximum de mot de passe**: 30 jours ou 60 jours.
- **Activer historique de mot de passe**: 5 ou 10.

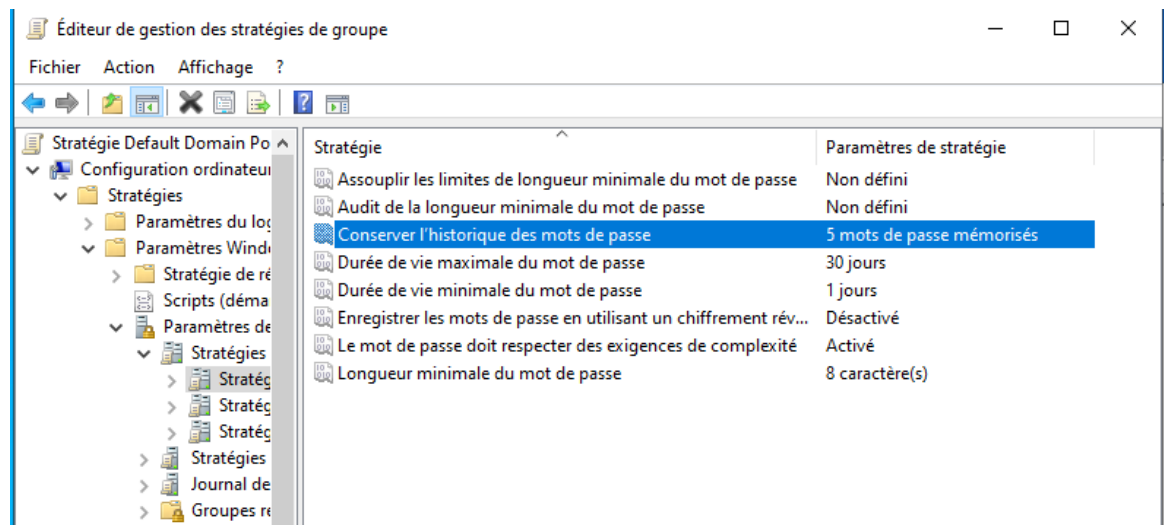
Ce qui doit s'afficher

Vous devez voir les paramètres de sécurité avec les valeurs que vous avez choisies. La stratégie de mot de passe de domaine s'applique globalement via la Default Domain Policy.

La console **GPMC** avec le domaine ouvert.

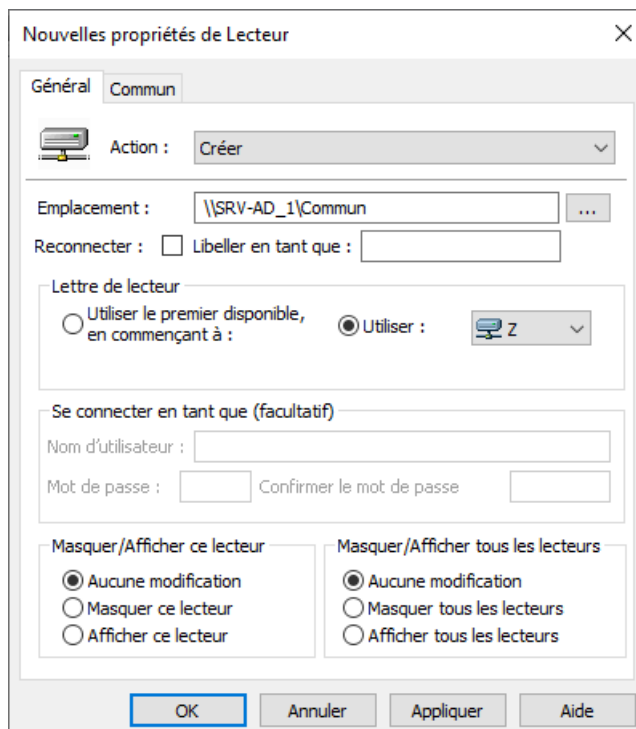


La fenêtre **Password Policy** montrant les valeurs.



2. GPO de mappage de lecteur (Drive Maps)

- Sur SRV-AD_1 : dans la même console GPMC, clic droit sur “Objets de stratégie de groupe” - **Nouveau**.
- Nom : GPO_Mappage_Commune.
- Clic droit sur cette GPO -**Modifier**.
- Allez dans :
 - User Configuration
 - Preferences
 - Windows Settings
 - **Drive Maps**.
- Clic droit - **New - Mapped Drive**.
- Renseigne :
 - Action : Create
 - Location : \\SRV-AD_1\Commun (on créera le partage juste après)
 - Drive Letter : Z:
 - Label : Commun.
- Ferme l’éditeur.
- Dans GPMC, fais glisser la GPO sur l’OU où seront tes **postes** (par ex. OU Postes) pour la lier.
- **Capture** :
- écran Drive Maps avec le lecteur Z: configuré.



Texte rapport :

Une GPO de type Group Policy Preferences a été créée pour déployer automatiquement un lecteur réseau Z: mappé sur le partage Commun du serveur de fichiers. Cette approche centralise la configuration des lecteurs pour tous les postes du domaine.

La commande **gpresult /r** a été utilisée pour vérifier l'application des stratégies de groupe sur un poste client. Avant l'intégration au domaine, le poste reste en mode local et aucune GPO de domaine n'est appliquée. Cette vérification permet de disposer d'une preuve de référence avant la jonction au domaine, puis de comparer le comportement après authentification dans l'annuaire.

Texte à mettre dans le rapport

Une politique de mot de passe a été mise en au niveau du domaine via la Default Domain Policy. Elle impose une longueur place minimale, une complexité renforcée et une durée de validité limitée afin de réduire le risque de compromission des comptes.

3. Serveur fichiers sur SRV-AD_1

1. Sur SRV-AD_1, ouvrez **PowerShell admin**.

2. Installe le rôle File Server :

powershell

```
Install-WindowsFeature FS-FileServer -IncludeManagementTools
```

3. Créez un dossier de partage :

powershell

```
New-Item -Path "C:\Partage_Commune" -ItemType Directory
```

4. Créez le partage SMB :

powershell

```
New-SmbShare -Name "Commune" -Path "C:\Partage_Commune" -FullAccess  
"NOVABIKE\Administrateurs"
```

5. Dans l'Explorateur sur SRV-AD_1, clic droit sur C:\Partage_Commune - Propriétés - Sécurité, ajoute par exemple GG_Direction, GG_Technique avec les droits que tu veux.

Captures :

Résultat de Get-WindowsFeature FS-FileServer montrant Installed

```
Installez la dernière version de PowerShell pour de nouvelles fonctionnalités et améliorations ! https://aka.ms/PSWindows
PS C:\Users\Administrateur> Install-WindowsFeature FS-FileServer -IncludeManagementTools

Success Restart Needed Exit Code      Feature Result
-----
True      No          NoChangeNeeded {}

PS C:\Users\Administrateur>
```

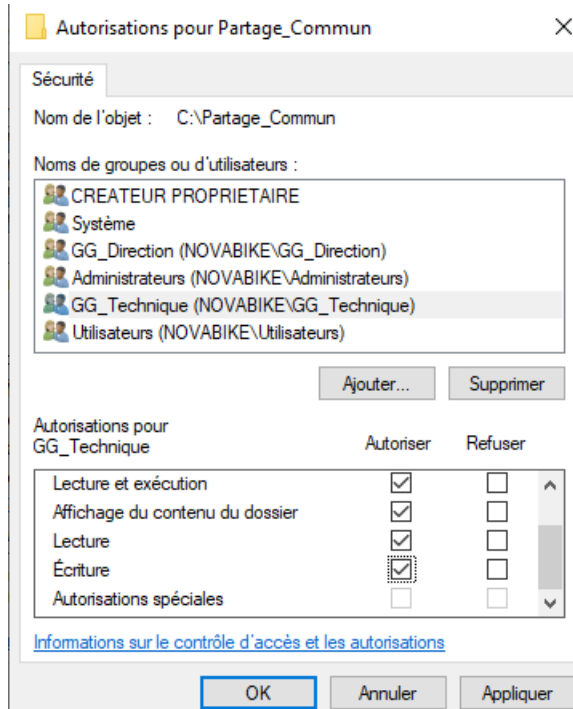
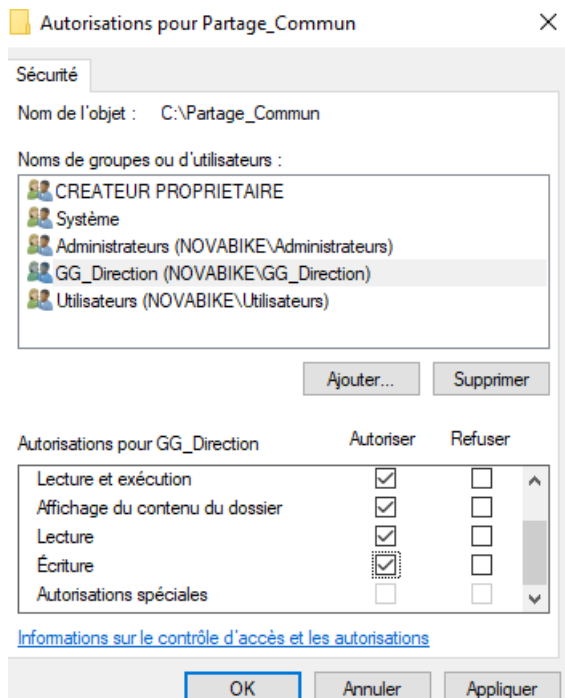
Get-SmbShare ou net share montrant Commune,

```
PS C:\Users\Administrateur> New-Item -Path "C:\Partage_Commune" -ItemType Directory

Répertoire : C:\

Mode                LastWriteTime         Length Name
----                -
d-----          03/04/2026      14:53         Partage_Commune
```

Propriétés de sécurité du dossier avec tes groupes AD.



Texte rapport :

Le rôle serveur de fichiers a été ajouté sur SRV-AD_1. Un partage SMB “Commun” a été créé et les droits NTFS sont gérés à partir des groupes de sécurité Direction, Technique, etc., ce qui permet d'appliquer les autorisations par service.

4. FTP (sur le même serveur)

1. Toujours sur SRV-AD_1, installe IIS + FTP :

powershell

```
Install-WindowsFeature Web-Server, Web-FTP-Server -IncludeManagementTools
```

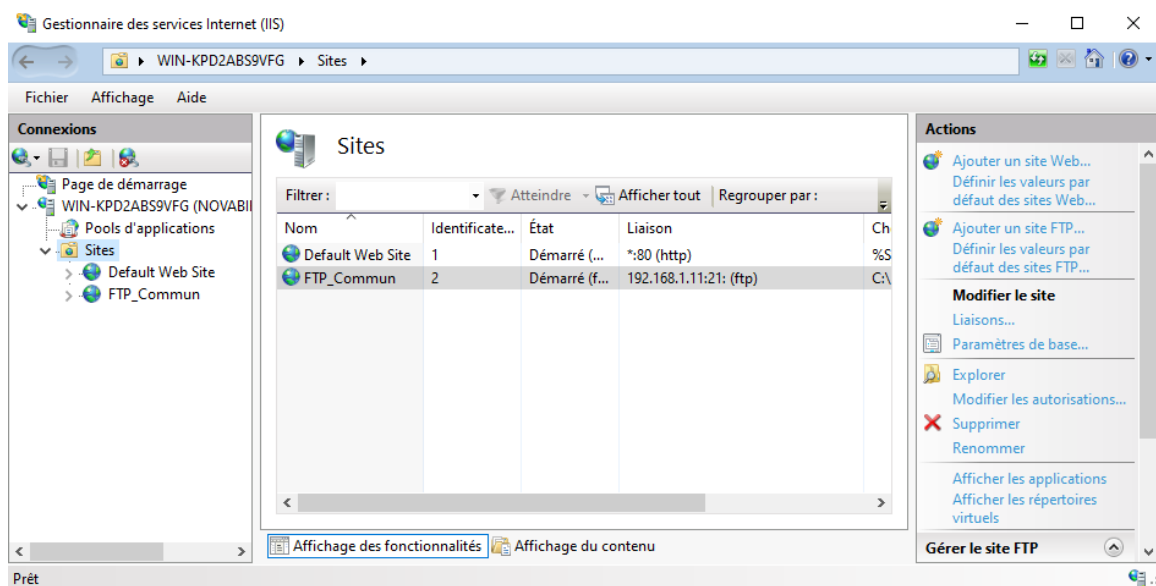
2. Ouvre **IIS Manager** (inetmgr).
3. Dans la colonne de gauche, clic droit sur **Sites** → **Add FTP Site....**
4. Nom du site : FTP_Commune.
5. Physical path : C:\Partage_Commune.
6. Binding :
 - a. IP: IP de SRV-AD_1
 - b. Port : 21
 - c. SSL : No SSL (pour le labo).
7. Onglet Authentication/Authorization :
 - a. Authentification : Basic
 - b. Authorization : Specified roles or user groups → indique NOVABIKE\GG_Postes par exemple.

sur SRV-AD_1, installer IIS + FTP

```
PS C:\Users\Administrateur> Install-WindowsFeature Web-Server, Web-FTP-Server -IncludeManagementTools
```

Success	Restart	Needed	Exit Code	Feature Result
True	No		Success	{Fonctionnalités HTTP communes, Document p...

IIS Manager avec FTP_Commune dans Sites,



Fenêtre de configuration du site FTP.

Ajouter un site FTP ? X

 **Informations sur les autorisations et l'authentification**

Authentification

☐ Anonyme

☒ De base

Autorisation

Autoriser l'accès à :

Rôles ou groupes d'utilisateurs définis ▼

GG_Postes

Autorisations

☒ Lecture

☒ Écriture

Précédent Suivant Terminer Annuler

Un site FTP IIS a été configuré sur SRV-AD_1 en s'appuyant sur le même répertoire que le partage Commun. L'authentification est déléguée à Active Directory et les autorisations d'accès sont filtrées par groupe, ce qui permet d'exposer les fichiers également via FTP.

5. IIS Web (SRV_WEB)

1. Sur la VM SRV_WEB :

powershell

`Install-WindowsFeature Web-Server -IncludeManagementTools`

2. Édite le fichier C:\inetpub\wwwroot\index.html :

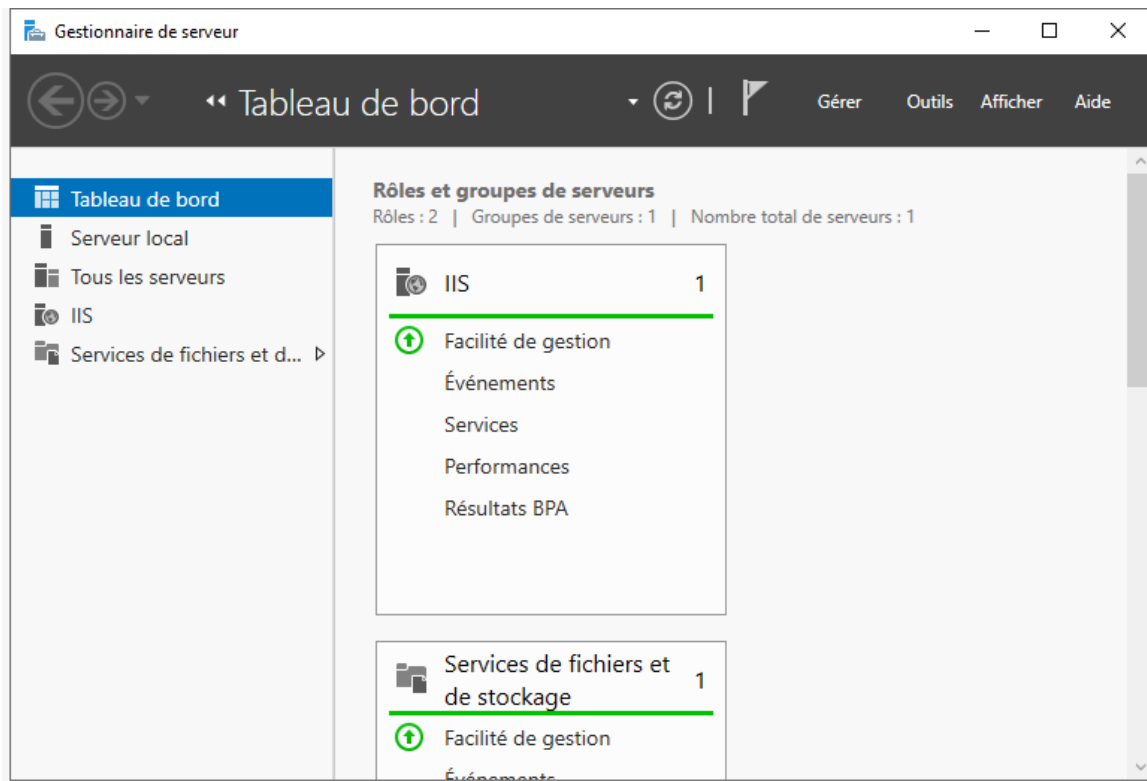
xml

```
<h1>Projet SYS12 - NovaBike</h1>      111
<p>Serveur Web IIS opérationnel. </p>
```

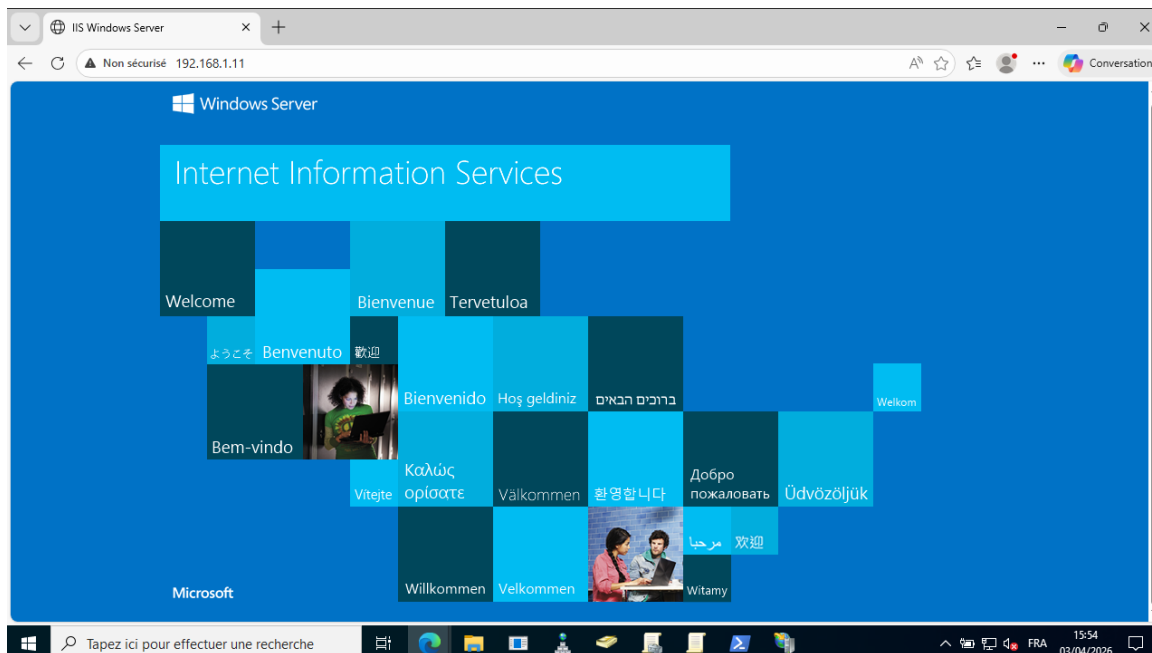
3. Depuis n'importe quel poste/serveur du LAN, ouvre un navigateur et teste :
http://<IP_de_SRV_WEB>

Captures :

Server Manager montrant le rôle Web Server (IIS),



Page IIS dans le navigateur.



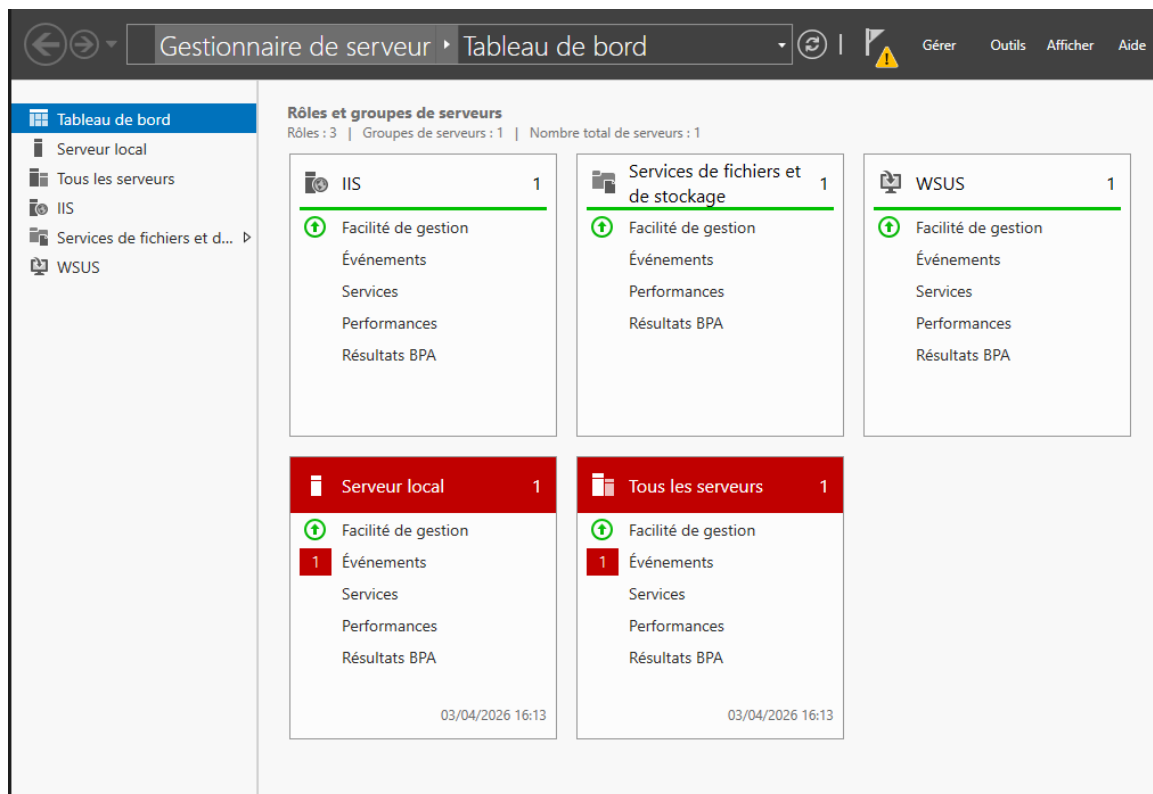
Le serveur SRV_WEB héberge un site Web de test sous IIS, accessible depuis le réseau interne.

Il sert à valider la mise en place d'un service HTTP dédié, distinct des contrôleurs de domaine

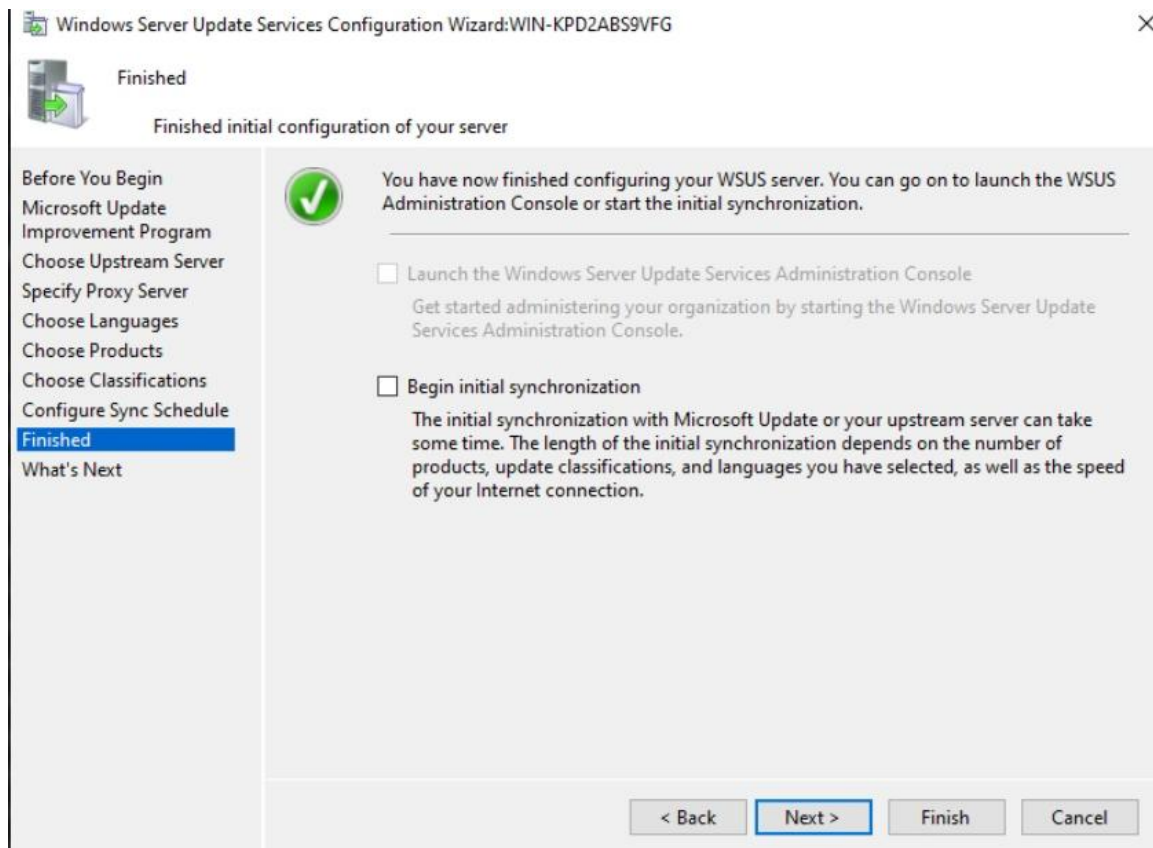
6. WSUS (SRV_WSUS)

1. Sur SRV_WSUS :
 - a. Ouvrez Server Manager – Ajouter role et fonctionnalités.
 - b. Cochez **Windows Server Update Services**.
 - c. Suis l'assistant, choisis un dossier de stockage (par exemple D:\WSUS).
2. Une fois installé, lance la **console WSUS**.
3. Suis l'assistant de configuration :
 - a. Sélection du serveur en amont (Microsoft Update),
 - b. Types de produits (Windows 10/11, Server 2022...),
 - c. Classifications (Critical, Security, etc.),
 - d. Première synchronisation.
4. Quand la sync est finie, sélectionne quelques mises à jour - clic droit **Approve** → "Approved for Install" pour le groupe "All Computers".

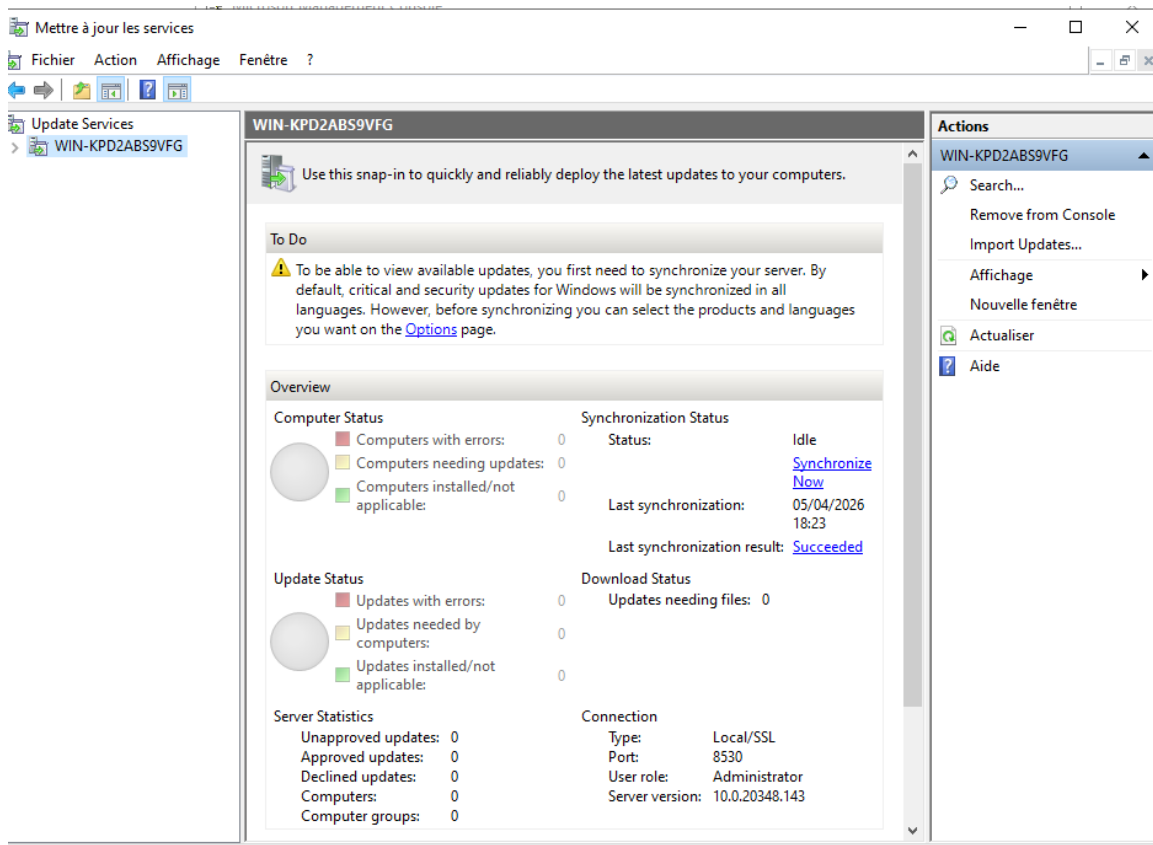
Rôle WSUS installé dans Server Manager,



Synchronisation réussie au niveau de la console WSUS.



Fenêtre d'approbation des mises à jour :

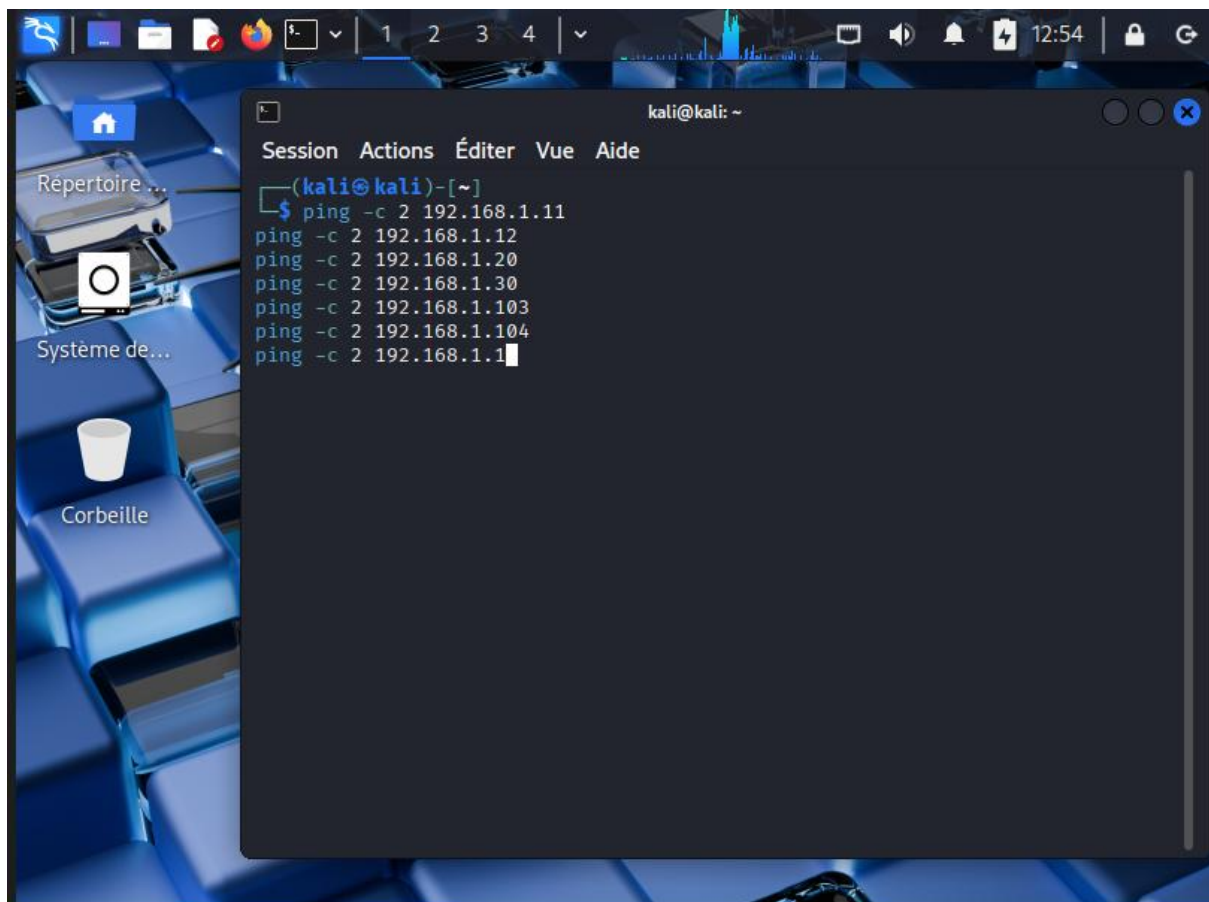


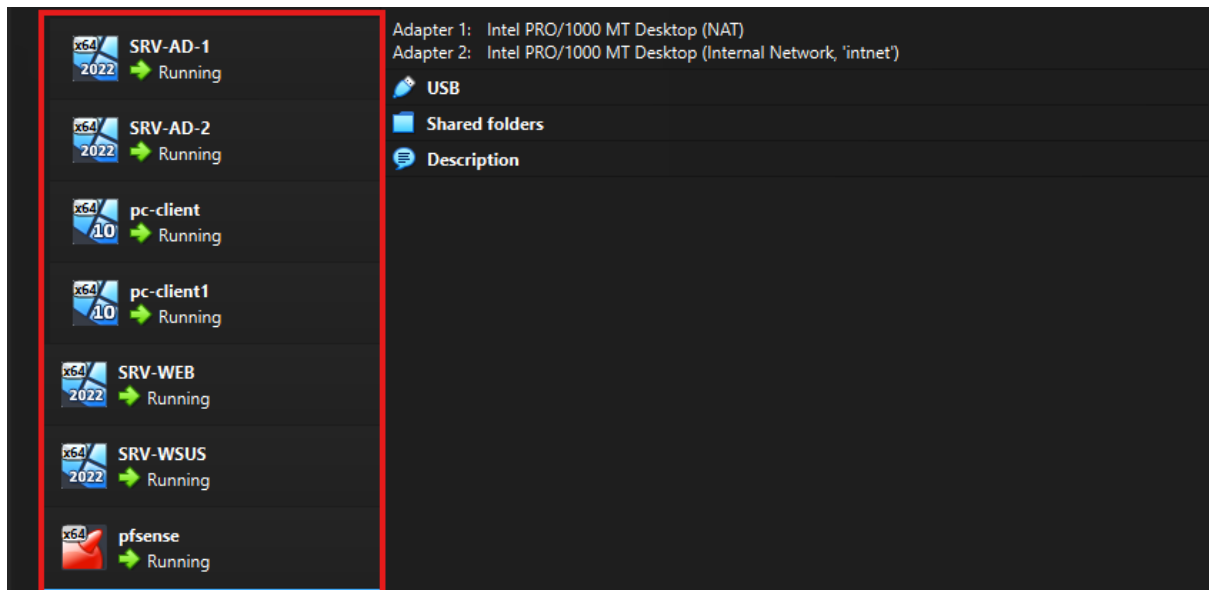
Le serveur WSUS centralise le téléchargement des mises à jour Microsoft et permet de les approuver manuellement avant déploiement. Cette solution répond à l'exigence de déployer les correctifs quand nous le souhaitons.

Audit :

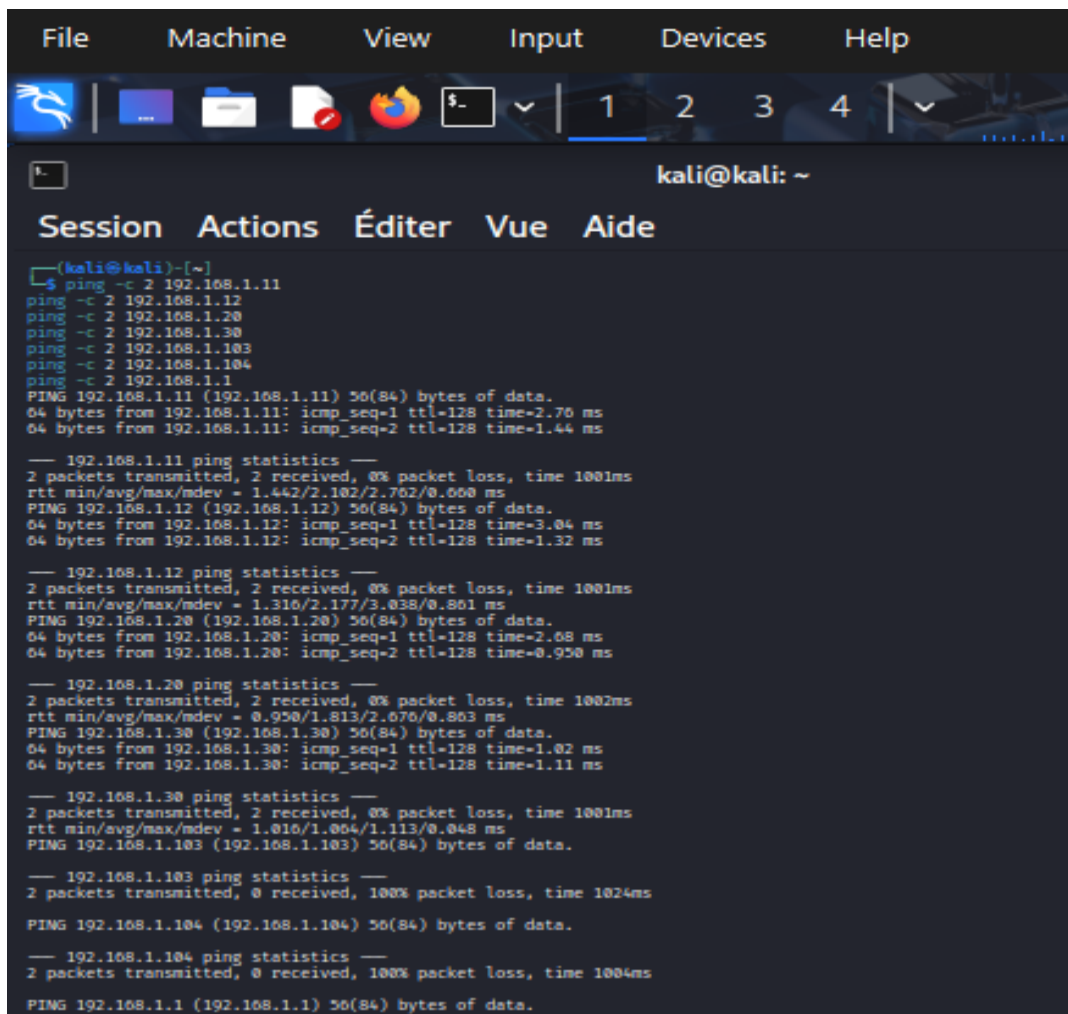
Etape 1 : Analyse de l'infrastructure réseau depuis Kali-Linux

Scan du réseau local par Kali Linux :





Toutes les machines sont visibles par **Kali** :



```
File Machine View Input Devices Help
kali@kali: ~
Session Actions Éditer Vue Aide

(kali@kali)-[~]
$ ping -c 2 192.168.1.11
ping -c 2 192.168.1.12
ping -c 2 192.168.1.20
ping -c 2 192.168.1.30
ping -c 2 192.168.1.103
ping -c 2 192.168.1.104
ping -c 2 192.168.1.1
PING 192.168.1.11 (192.168.1.11) 56(84) bytes of data.
64 bytes from 192.168.1.11: icmp_seq=1 ttl=128 time=2.70 ms
64 bytes from 192.168.1.11: icmp_seq=2 ttl=128 time=1.44 ms

— 192.168.1.11 ping statistics —
2 packets transmitted, 2 received, 0% packet loss, time 100ms
rtt min/avg/max/mdev = 1.442/2.102/2.702/0.060 ms
PING 192.168.1.12 (192.168.1.12) 56(84) bytes of data.
64 bytes from 192.168.1.12: icmp_seq=1 ttl=128 time=3.04 ms
64 bytes from 192.168.1.12: icmp_seq=2 ttl=128 time=1.32 ms

— 192.168.1.12 ping statistics —
2 packets transmitted, 2 received, 0% packet loss, time 100ms
rtt min/avg/max/mdev = 1.310/2.177/3.038/0.801 ms
PING 192.168.1.20 (192.168.1.20) 56(84) bytes of data.
64 bytes from 192.168.1.20: icmp_seq=1 ttl=128 time=2.08 ms
64 bytes from 192.168.1.20: icmp_seq=2 ttl=128 time=0.950 ms

— 192.168.1.20 ping statistics —
2 packets transmitted, 2 received, 0% packet loss, time 100ms
rtt min/avg/max/mdev = 0.950/1.813/2.076/0.803 ms
PING 192.168.1.30 (192.168.1.30) 56(84) bytes of data.
64 bytes from 192.168.1.30: icmp_seq=1 ttl=128 time=1.02 ms
64 bytes from 192.168.1.30: icmp_seq=2 ttl=128 time=1.11 ms

— 192.168.1.30 ping statistics —
2 packets transmitted, 2 received, 0% packet loss, time 100ms
rtt min/avg/max/mdev = 1.010/1.004/1.113/0.048 ms
PING 192.168.1.103 (192.168.1.103) 56(84) bytes of data.

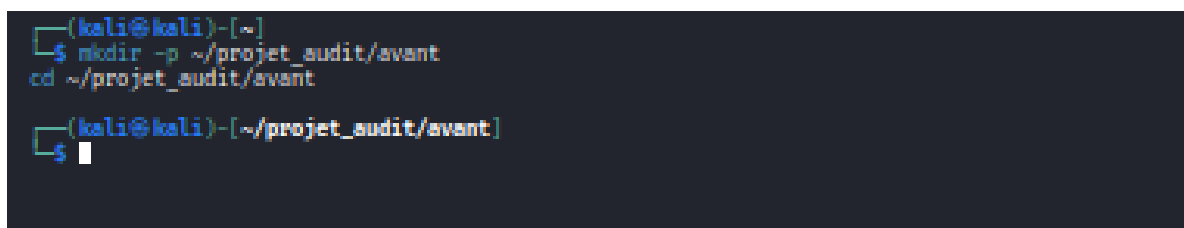
— 192.168.1.103 ping statistics —
2 packets transmitted, 0 received, 100% packet loss, time 1024ms
PING 192.168.1.104 (192.168.1.104) 56(84) bytes of data.

— 192.168.1.104 ping statistics —
2 packets transmitted, 0 received, 100% packet loss, time 1004ms
PING 192.168.1.1 (192.168.1.1) 56(84) bytes of data.
```

Création du dossier pour stocker les résultats du premier audit :

`mkdir -p ~/projet_audit/avant`

`cd ~/projet_audit/avant`



```
(kali@kali)-[~]
$ mkdir -p ~/projet_audit/avant
cd ~/projet_audit/avant
(kali@kali)-[~/projet_audit/avant]
$
```

Etape 2 : Audit avant implémentation des vulnérabilités

Lancer le scan complet :

`sudo nmap -sV -sC -O -p- 192.168.1.0/24 -oA audit_avant`

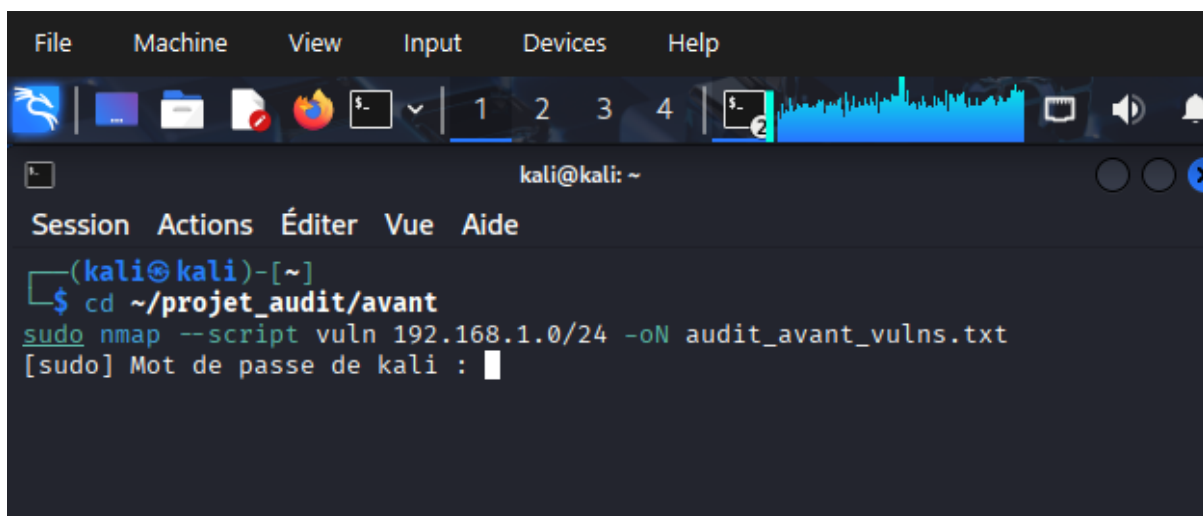
```
(kali@kali)-[~/projet_audit/avant]
$ sudo nmap -sV -sC -O -p- 192.168.1.0/24 -oA audit_avant
[sudo] Mot de passe de kali : █
```

Saisir mot de passe puis entrer.

Le **premier** scan dure environ 5 à 10 minutes.

```
(kali@kali)-[~/projet_audit/avant]
$ sudo nmap -sV -sC -O -p- 192.168.1.0/24 -oA audit_avant
[sudo] Mot de passe de kali :
Starting Nmap 7.95 ( https://nmap.org ) at 2020-04-30 13:10 CEST
█
```

Lancer le **deuxième** scan qui lui est plus rapide dans un autre terminal :



```
(kali@kali)-[~]
$ cd ~/projet_audit/avant
sudo nmap --script vuln 192.168.1.0/24 -oN audit_avant_vulns.txt
[sudo] Mot de passe de kali : █
```

Saisir mot de passe puis entrer.

Etape 3 : résultat des audits

Résultat du premier scan :


```

(kali@kali)-[~]
$ mkdir -p ~/projet_audit/avant
cd ~/projet_audit/avant

(kali@kali)-[~/projet_audit/avant]
$ sudo nmap -sV -sc -O -p- 192.168.1.0/24 -oA audit_avant
[sudo] Mot de passe de kali :
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-30 13:10 CEST
Nmap scan report for pfSense.labo.test (192.168.1.1)
Host is up (0.0017s latency).
Not shown: 65532 filtered tcp ports (no-response) ← PF
PORT      STATE SERVICE VERSION
53/tcp    open  domain Unbound
80/tcp    open  http   nginx
|_http-title: Did not follow redirect to https://pfSense.labo.test/
443/tcp   open  ssl/http nginx
|_tls-alpn:
|_  h2
|_  http/1.1
|_ssl-cert: Subject: commonName=pfSense-69b97178676af/organizationName=pfSense webConfigurator Self-Signed Certificate
|_ Subject Alternative Name: DNS:pfSense-69b97178676af
|_ Not valid before: 2026-03-17T15:21:28
|_ Not valid after: 2027-04-19T15:21:28
|_tls-nextprotoneg:
|_  h2
|_  http/1.1
|_http-title: pfSense - Login
|_ssl-date: TLS randomness does not represent time
MAC Address: 08:00:27:0F:FA:96 (PCS Systemtechnik/Oracle Virtualbox virtual NIC)
Warning: OSscan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSED): FreeBSD 11.X (97%)
OS CPE: cpe:/o:freebsd:freebsd:11.2
Aggressive OS guesses: FreeBSD 11.2-RELEASE (97%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

Nmap scan report for 192.168.1.11 ← AD1
Host is up (0.0016s latency).
Not shown: 65513 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      Microsoft ftpd
|_ftp-syst:
|_  SVST: Windows_NT
53/tcp    open  domain   Simple DNS Plus
80/tcp    open  http     Microsoft IIS httpd 10.0
|_http-server-header: Microsoft-IIS/10.0
|_http-title: IIS Windows Server
|_http-methods:
|_ Potentially risky methods: TRACE
88/tcp    open  kerberos-sec Microsoft_Windows_Kerberos (server time: 2026-04-30 11:15:07Z)
135/tcp   open  msrpc    Microsoft Windows RPC
139/tcp   open  netbios-ssn Microsoft Windows netbios-ssn
389/tcp   open  ldap     Microsoft Windows Active Directory LDAP (Domain: novabike.local0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap     Microsoft Windows Active Directory LDAP (Domain: novabike.local0., Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5985/tcp  open  http     Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
9389/tcp  open  mc-nmf   .NET Message Framing
49664/tcp open  msrpc    Microsoft Windows RPC
49668/tcp open  msrpc    Microsoft Windows RPC
50557/tcp open  ncacn_http Microsoft Windows RPC over HTTP 1.0
50558/tcp open  msrpc    Microsoft Windows RPC
50563/tcp open  msrpc    Microsoft Windows RPC
50571/tcp open  msrpc    Microsoft Windows RPC
50576/tcp open  msrpc    Microsoft Windows RPC
MAC Address: 08:00:27:19:1F:07 (PCS Systemtechnik/Oracle Virtualbox virtual NIC)
Warning: OSscan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSED): Microsoft Windows 2022|2016|11 (97%)
OS CPE: cpe:/o:microsoft:windows_server_2022 cpe:/o:microsoft:windows_server_2016 cpe:/o:microsoft:windows_11
Aggressive OS guesses: Microsoft Windows Server 2022 (97%), Microsoft Windows Server 2016 (91%), Microsoft Windows 11 21H2 (90%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: WIN-KPD2AB59VFG; OS: Windows; CPE: cpe:/o:microsoft:windows

```

← SRV-WEB

```
Nmap scan report for 192.168.1.20
Host is up (0.0015s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Microsoft IIS httpd 10.0
|_ http-server-header: Microsoft-IIS/10.0
|_ http-methods:
|_   Potentially risky methods: TRACE
|_   http-title: IIS Windows Server
5357/tcp  open  http      Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Service Unavailable
|_ http-server-header: Microsoft-HTTPAPI/2.0
5905/tcp  open  http      Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Not Found
|_ http-server-header: Microsoft-HTTPAPI/2.0
MAC Address: 08:00:27:04:05:C6 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSED): Microsoft Windows 2022|11|2016 (97%)
OS CPE: cpe:/o:microsoft:windows_server_2022 cpe:/o:microsoft:windows_11 cpe:/o:microsoft:windows_server_2016
Aggressive OS guesses: Microsoft Windows Server 2022 (97%), Microsoft Windows 11 21H2 (91%), Microsoft Windows Server 2016 (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Stats: 0:07:12 elapsed; 252 hosts completed (7 up), 3 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 3.48% done; ETC: 13:25 (0:08:20 remaining)
Stats: 0:07:13 elapsed; 252 hosts completed (7 up), 3 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 3.54% done; ETC: 13:25 (0:08:11 remaining)
Stats: 0:07:13 elapsed; 252 hosts completed (7 up), 3 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 3.57% done; ETC: 13:25 (0:08:33 remaining)
Stats: 0:07:14 elapsed; 252 hosts completed (7 up), 3 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 9.13% done; ETC: 13:24 (0:06:28 remaining)
Nmap scan report for 192.168.1.30
Host is up (0.0013s latency).
Not shown: 65536 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Microsoft IIS httpd 10.0
|_ http-server-header: Microsoft-IIS/10.0
|_ http-methods:
|_   Potentially risky methods: TRACE
|_   http-title: IIS Windows Server
135/tcp   open  msrpc     Microsoft Windows RPC
139/tcp   open  netbios-ssn Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
5357/tcp  open  http      Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Service Unavailable
|_ http-server-header: Microsoft-HTTPAPI/2.0
5905/tcp  open  http      Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
8530/tcp  open  http      Microsoft IIS httpd 10.0
|_ http-title: Site doesn't have a title.
|_ http-server-header: Microsoft-IIS/10.0
|_ http-methods:
|_   Potentially risky methods: TRACE
8531/tcp  open  unknown   Microsoft IIS httpd 10.0
49668/tcp open  msrpc     Microsoft Windows RPC
MAC Address: 08:00:27:8C:BD:C1 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSED): Microsoft Windows 2022|11|2016 (97%)
OS CPE: cpe:/o:microsoft:windows_server_2022 cpe:/o:microsoft:windows_11 cpe:/o:microsoft:windows_server_2016
Aggressive OS guesses: Microsoft Windows Server 2022 (97%), Microsoft Windows 11 21H2 (91%), Microsoft Windows Server 2016 (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb2-time:
|_   date: 2026-04-30T11:21:48
|_   start_date: N/A
|_ nbstat: NetBIOS name: nil, NetBIOS user: <unknown>, NetBIOS MAC: 08:00:27:8c:bd:c1 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
|_ smb2-security-mode:
|_   3.1.1:
|_     Message signing enabled but not required

Nmap scan report for 192.168.1.103
Host is up (0.0013s latency).
Not shown: 65534 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
```

← PC-CLIENT

```
Nmap scan report for 192.168.1.103
Host is up (0.0013s latency).
Not shown: 65534 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
7680/tcp  open  pando-pub?
MAC Address: 08:00:27:55:DC:D0 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSED): Microsoft Windows 10|11|2019 (92%)
OS CPE: cpe:/o:microsoft:windows_10 cpe:/o:microsoft:windows_11 cpe:/o:microsoft:windows_server_2019
Aggressive OS guesses: Microsoft Windows 10 1802 (92%), Microsoft Windows 10 1903 - 21H1 (92%), Microsoft Windows 11 (87%), Microsoft Windows 10 1909 (85%), Microsoft Windows 10 1909 - 2004 (85%), Windows Server 2019 (85%), Microsoft Windows 10 1809 (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

Nmap scan report for 192.168.1.104
Host is up (0.0043s latency).
All 65535 scanned ports on 192.168.1.104 are in ignored states.
Not shown: 65535 filtered tcp ports (no-response)
MAC Address: 08:00:27:8E:72:17 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

Nmap scan report for 192.168.1.101
Host is up (0.00028s latency).
All 65535 scanned ports on 192.168.1.101 are in ignored states.
Not shown: 65535 closed tcp ports (reset)
Too many fingerprints match this host to give specific OS details
Network Distance: 0 hops

Post-scan script results:
|_ clock-skew:
|_   0s:
|_   -192.168.1.12
|_   -192.168.1.11
|_   -192.168.1.30
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (8 hosts up) scanned in 748.24 seconds

kali@kali:~/projets/audit/avant
```

Résultat du deuxième Scan :

Vulnérabilité trouvée sur port 80,443 liaison Pfsense – Serveur Web

```
Session Actions Éditer Vue Aide
kali@kali: ~/projet_audit/avant
kali@kali:~$ cd ~/projet_audit/avant
kali@kali:~/projet_audit/avant$ sudo nmap --script vuln 192.168.1.0/24 -oN audit_avant_vulns.txt
[sudo] Mot de passe de kali :
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-30 13:11 CEST
Nmap scan report for pfSense.labo.test (192.168.1.1)
Host is up (0.0011s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
|_ http-slowloris-check:
|   VULNERABLE:
|   Slowloris DOS attack
|   State: LIKELY VULNERABLE
|   IDs: CVE:CVE-2007-6750
|   Slowloris tries to keep many connections to the target web server open and hold
|   them open as long as possible. It accomplishes this by opening connections to
|   the target web server and sending a partial request. By doing so, it starves
|   the http server's resources causing Denial Of Service.
|
|   Disclosure date: 2009-09-17
|   References:
|   http://ha.ckers.org/slowloris/
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-csrf: Couldn't find any CSRF vulnerabilities.
|_ http-fileupload-exploiter:
|   Couldn't find a file-type field.
|   Couldn't find a file-type field.
|   Couldn't find a file-type field.
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-csrf: Couldn't find any CSRF vulnerabilities.
|_ http-enum:
|   /manifest.json: Manifest JSON File
|_ MAC Address: 08:00:27:0F:FA:96 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.1.11
Host is up (0.0012s latency).
Not shown: 986 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
53/tcp    open  domain
80/tcp    open  http
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-csrf: Couldn't find any CSRF vulnerabilities.
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldaps
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
5985/tcp  open  wsmann
MAC Address: 08:00:27:91:F9:87 (PCS Systemtechnik/Oracle VirtualBox virtual
```

Slowloris est une vulnérabilité qui, lorsqu'elle est exploitée, est exploitée en attaque par déni de service. Elle maintient plusieurs connexions ouvertes très lentement, ce qui épuise les ressources du serveur web, de telle sorte que plus aucun utilisateur ne puisse se connecter.

```
Session Actions Éditer Vue Aide
NIC)
Nmap scan report for 192.168.1.11
Host is up (0.0012s latency).
Not shown: 986 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
53/tcp    open  domain
80/tcp    open  http
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldaps1
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
5985/tcp  open  wsman
MAC Address: 08:00:27:91:F9:87 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Host script results:
|_samba-vuln-cve-2012-1182: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR

Nmap scan report for 192.168.1.12
Host is up (0.0012s latency).
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldaps1
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
5985/tcp  open  wsman
MAC Address: 08:00:27:E3:71:72 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Host script results:
|_samba-vuln-cve-2012-1182: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR
|_smb-vuln-ms10-061: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR
|_smb-vuln-ms10-054: false

Nmap scan report for 192.168.1.20
Host is up (0.0014s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
5357/tcp  open  wsapi
5985/tcp  open  wsman
```

Les tests suivants n'ont pas pu être réalisés complètement en raison d'une absence de réponse SMB :

- CVE-2012-1182 (Samba)
- MS10-061 (SMB)

Cela peut indiquer que le service SMB est désactivé ou protégé par un pare-feu.

Aucune vulnérabilité SMB n'a été activement détectée.

```

Nmap scan report for 192.168.1.30 ← SRV-W5U5
Host is up (0.00090s latency).
Not shown: 994 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
5357/tcp  open  wsapi
5985/tcp  open  wsman
MAC Address: 08:00:27:8C:BD:C1 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Host script results:
|_smb-vuln-ms10-061: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR
|_smb-vuln-ms10-054: false
|_samba-vuln-cve-2012-1182: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR

Nmap scan report for 192.168.1.103 ← PC-client 1
Host is up (0.0035s latency).
All 1000 scanned ports on 192.168.1.103 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 08:00:27:55:DC:D0 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 192.168.1.104 ← PC client 2
Host is up (0.0031s latency).
All 1000 scanned ports on 192.168.1.104 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 08:00:27:8E:72:17 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 192.168.1.101
Host is up (0.0000020s latency).
All 1000 scanned ports on 192.168.1.101 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 256 IP addresses (8 hosts up) scanned in 186.89 seconds

(kali@kali)-[~/projet_audit/avant]
$

```

Fichiers d'audits :

Audit initial terminé. Début de l'implémentation des vulnérabilités.

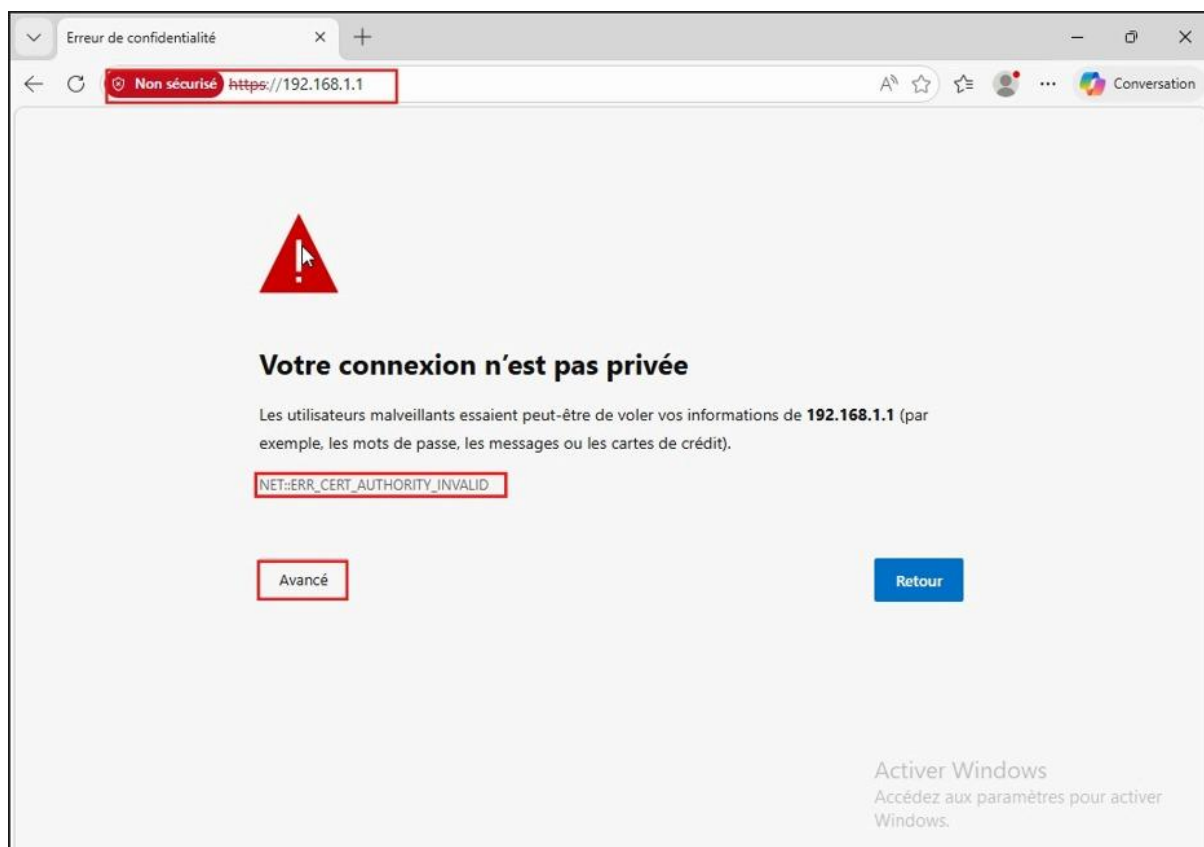
II - Projet-OFF – Introduction des vulnérabilités

Type	Vulnérabilité	Note/10	Niveau
Réseau	Règles pfSense trop permissives	8/10	Élevé
Applicatif	Injection SQL	10/10	Critique
Applicatif	XSS	6/10	Moyen
Système	Serveurs Windows non à jour	10/10	Critique
Système	Mauvaise configuration Active Directory	9/10	Critique

Implémentation de première vulnérabilité :

Vulnérabilité 1 - Réseau - Règle "tout autoriser"

Un pare-feu trop permissif permet à un attaquant qui compromet une machine quelconque de se déplacer facilement vers n'importe quelle autre machine du réseau. Cela supprime toute barrière interne et augmente considérablement l'impact d'une compromission initiale.

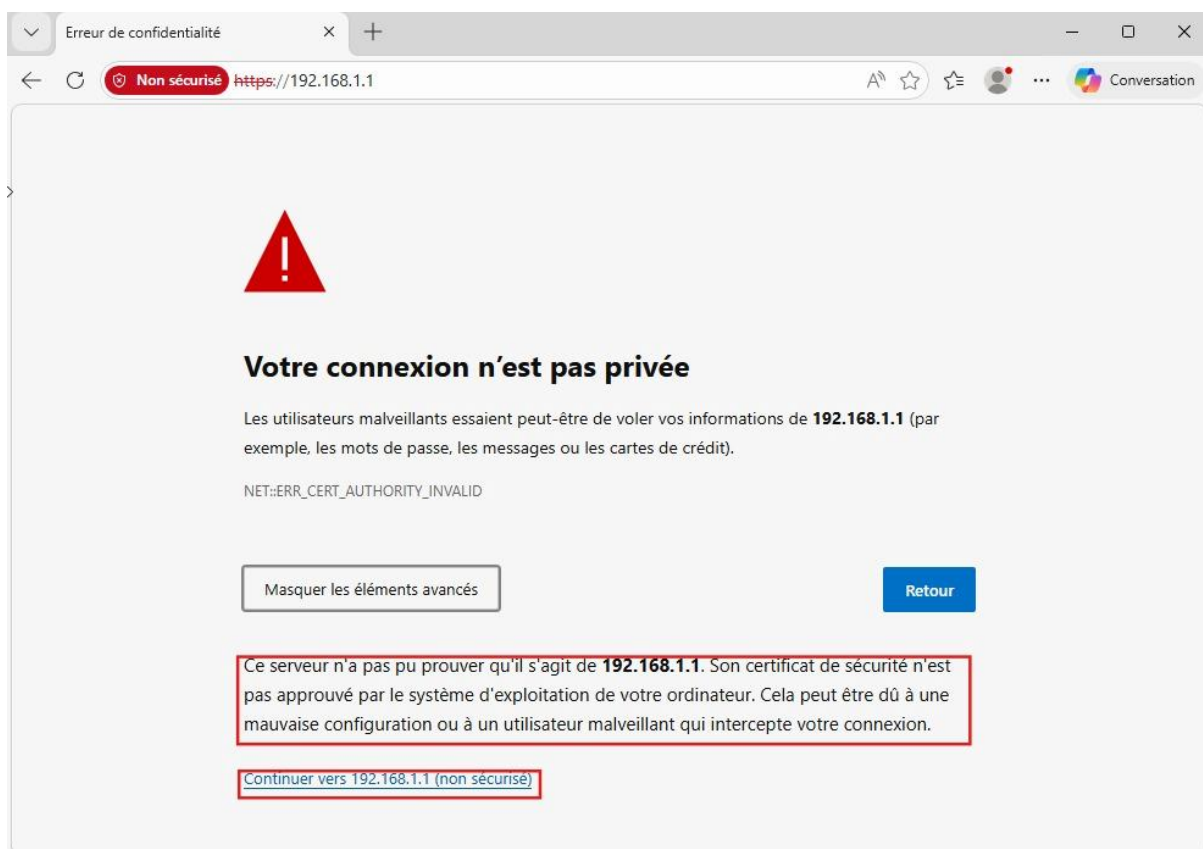


Étape 1 :

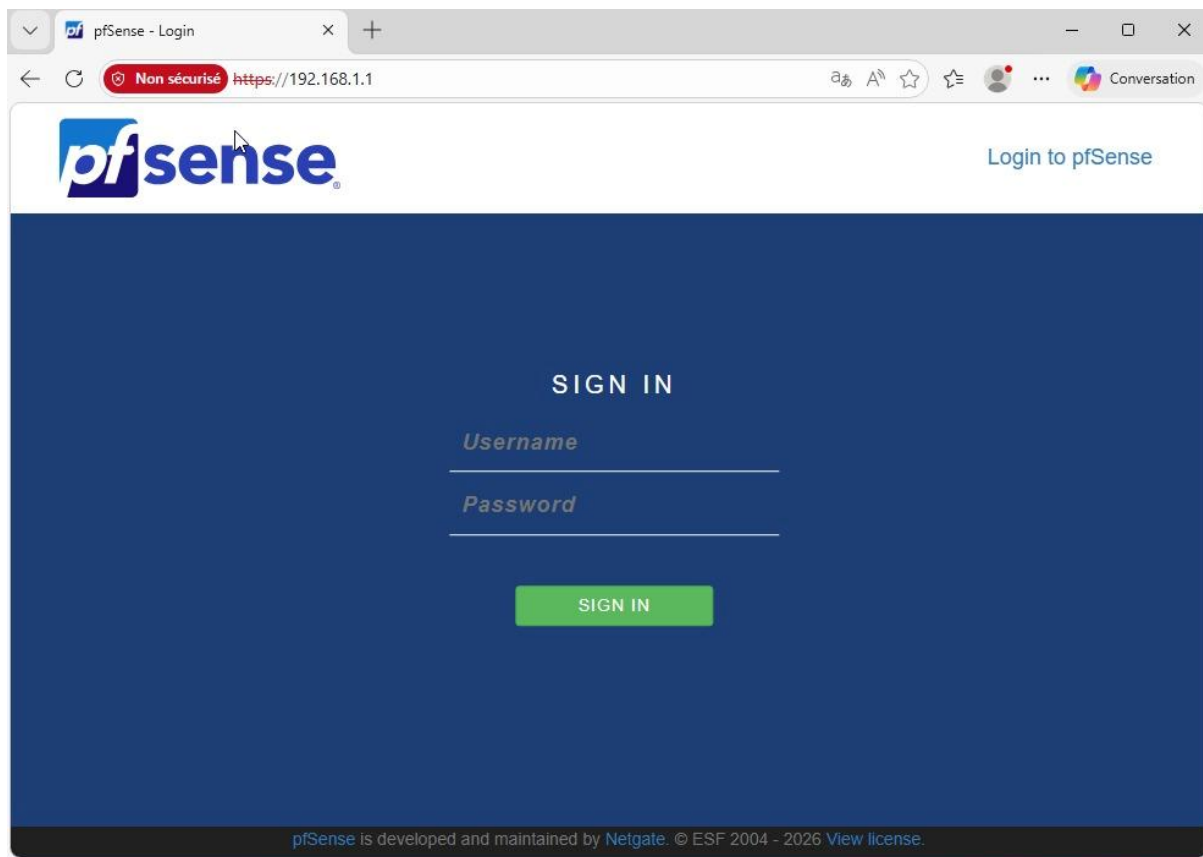
Se connecter à l'interface web de pfSense (http://192.168.1.1)

L'interface web de pfSense utilise un certificat SSL auto-signé par défaut. Cela génère une alerte de sécurité dans le navigateur car le navigateur ne sait pas de quelle autorité cela provient et ne peut donc pas nous garantir que c'est le bon site mais dans le cadre de notre laboratoire isolé (réseau interne VirtualBox), cela ne présente pas de risque réel. Cette alerte peut être ignorée en cliquant sur "Avancé".

Après avoir cliqué sur "Avancé", voici ce qui s'affiche :



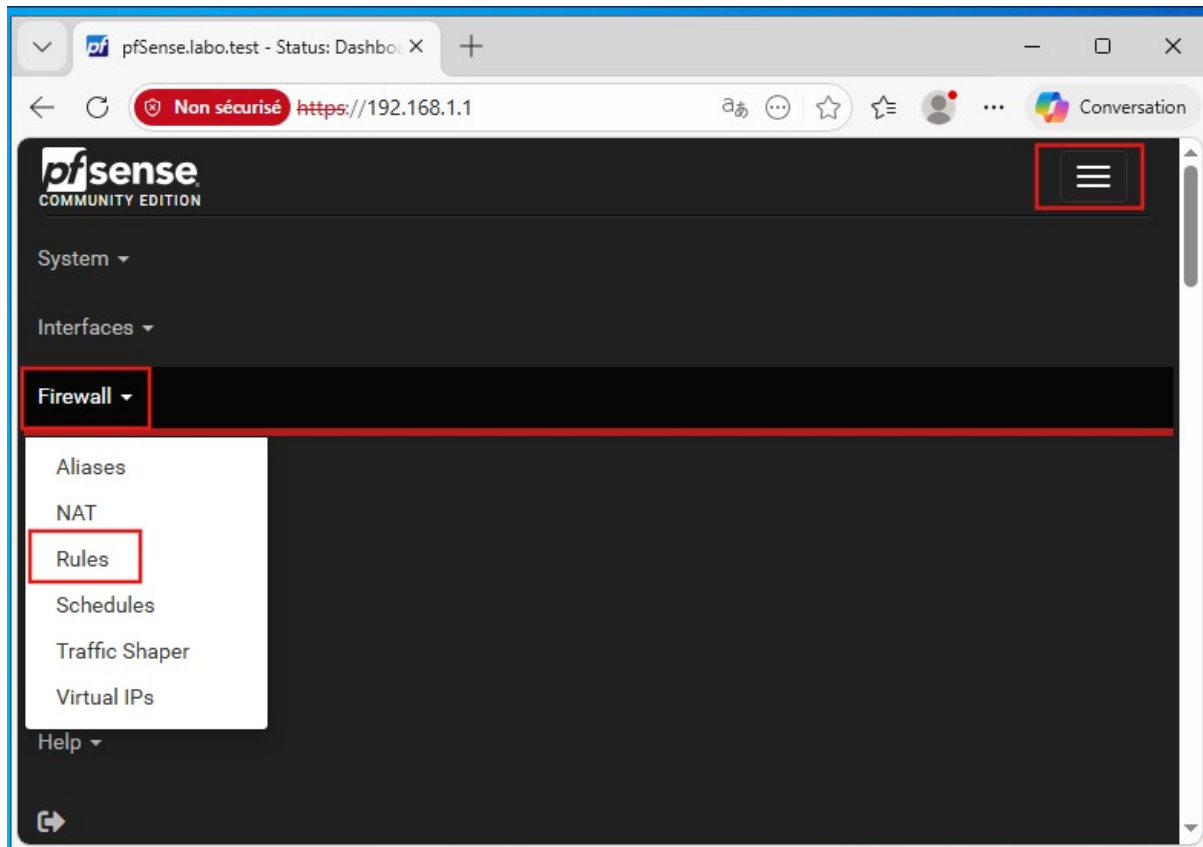
Cliquez sur continuez vers 192.168.1.1 (non sécurisé)



S'authentifier :

Username : **Samuel-admin**

Password : **Samuel635_@**



Étape 2 :

Cliquer sur les 3 barres latérales à gauche.

Allez dans l'onglet Firewall

Ensuite cliquez sur Rules

pfSense.labo.test - Firewall: Rules: X

Non sécurisé https://192.168.1.1/firewall_rules.php?if=lan

COMMUNITY EDITION

Firewall / Rules / LAN

Floating WAN LAN

Rules (Drag to Change Order)

☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	3 / 4.14 MiB	*	*	*	LAN Address	443	*	*		Anti-Lockout Rule	
☐	26 / 206.13 MiB	IPv4 *	LAN net	*	*	*	*	none		Default allow LAN to any rule	
☐	0 / 0 B	IPv6 *	LAN net	*	*	*	*	none		Default allow LAN IPv6 to any rule	

Add Add Delete Save Separator

Ensuite sur Cliquez “Add” :

The screenshot shows the 'Edit Firewall Rule' page in pfSense. The top navigation bar includes 'System', 'Interfaces', 'Firewall', 'Services', 'VPN', 'Status', 'Diagnostics', and 'Help'. The breadcrumb trail is 'Firewall / Rules / Edit'. The main form is divided into several sections:

- Edit Firewall Rule:** Contains the 'Action' dropdown (set to 'Pass'), a 'Disabled' checkbox, the 'Interface' dropdown (set to 'LAN'), the 'Address Family' dropdown (set to 'IPv4'), and the 'Protocol' dropdown (set to 'Any').
- Source:** Contains the 'Source' dropdown (set to 'any'), an 'Invert match' checkbox, and a 'Source Address' field.
- Destination:** Contains the 'Destination' dropdown (set to 'any'), an 'Invert match' checkbox, and a 'Destination Address' field.
- Extra Options:** Contains a 'Log' checkbox, a 'Description' text area, and an 'Advanced Options' button.
- Save:** A blue button at the bottom of the form.

Remplissez les différents champs :

Champ	Valeur
Action	Pass
Interface	LAN
Protocol	Any
Source	Any
Destination	Any

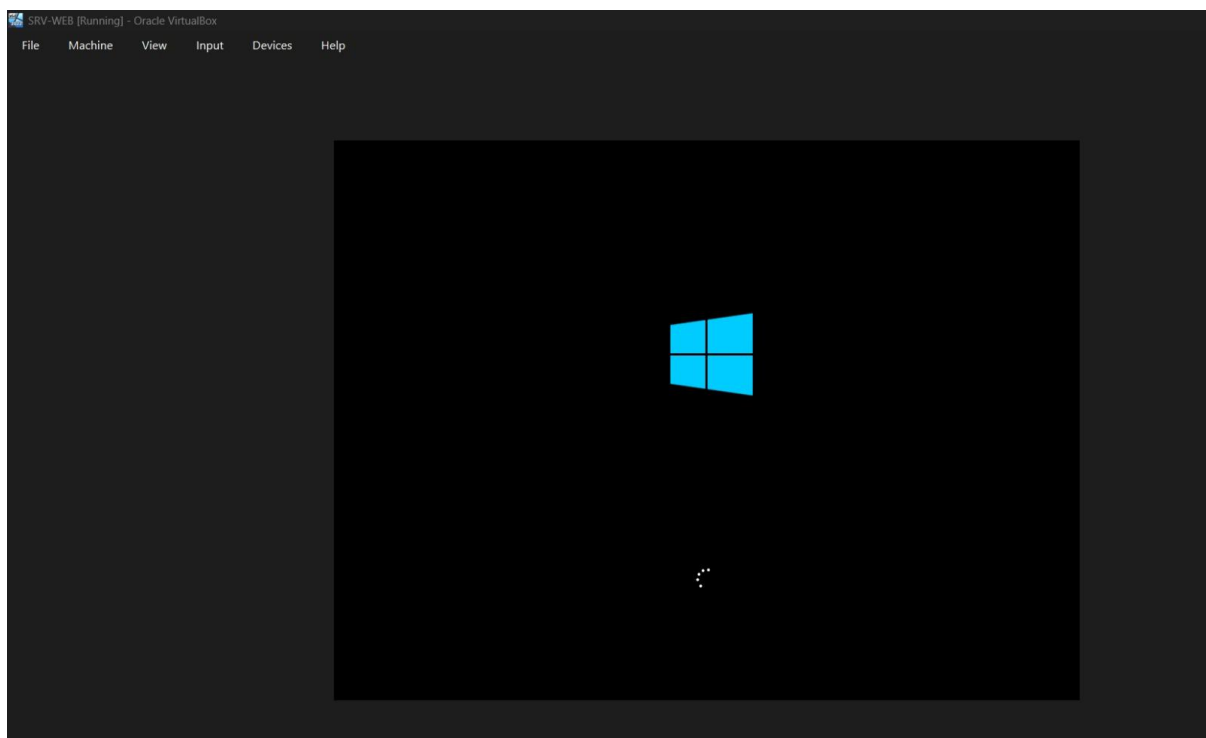
Puis cliquez sur "Save"

La règle de pare-feu que nous avons mise sur pFsense autorise tout le trafic entre les machines du réseau, ce qui illustre une vulnérabilité réseau critique car cela supprime toute barrière de sécurité entre les segments réseau. Cela viole le principe de moindre privilège et permet à un attaquant ayant compromis une machine quelconque de se déplacer latéralement vers n'importe quelle autre machine, sur n'importe quel port, sans aucune restriction.

Ainsi, le fait que tout le trafic via le pare-feu est autorisé sans aucune restriction ni distinction représente une vulnérabilité majeure donnant à un attaquant la liberté totale de se mouvoir dans le réseau une fois qu'il a compromis une première machine.

Vulnérabilité 2 – Applicatif - Injection SQL (SQLi) :

La machine SRV-WEB (192.168.1.20) héberge l'application web vulnérable.



Étape 2 — Télécharger XAMPP sur SRV-WEB

XAMPP est une solution tout-en-un qui installe automatiquement :

Apache (le serveur web qui écoute sur le port 80)

MySQL (la base de données pour stocker les informations)

PHP (le langage pour créer des pages web dynamiques)

Avec XAMPP, on a tout ce qu'il faut pour créer une application web vulnérable en quelques minutes.

Depuis SRV-WEB, ouvrir un terminal (clic droit -"Open Terminal" ou cherche "Terminal" dans les applications).

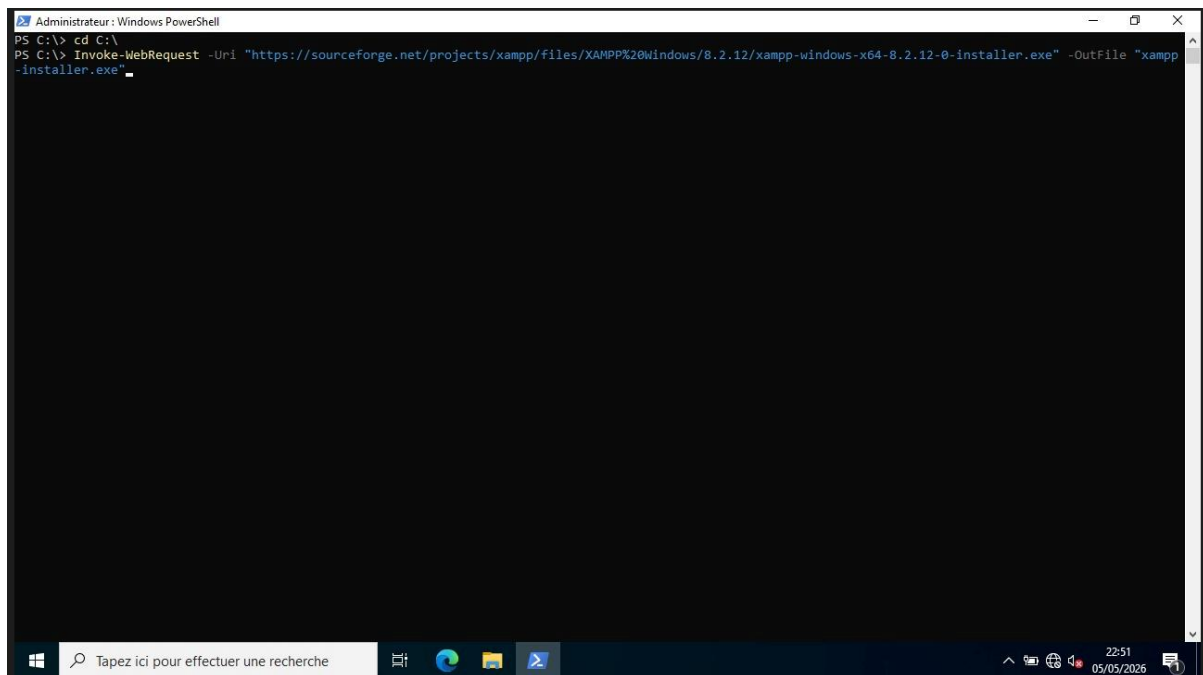
Coller cette commande :

```
cd C:\  
  
curl -o xampp-installer.exe  
https://sourceforge.net/projects/xampp/files/XAMPP%20Windows/8.2.12/xampp-windows-  
x64-8.2.12-0-installer.exe
```

cd /tmp : se déplacer dans le dossier temporaire (pour ne pas encombrer)

wget : télécharger le fichier depuis internet

sinon se rendre directement sur le site internet et télécharger l'installer (Plus fiable) :



```
Administrateur : Windows PowerShell
PS C:\> cd C:\
PS C:\> Invoke-WebRequest -Uri "https://sourceforge.net/projects/xampp/files/XAMPP%20Windows/8.2.12/xampp-windows-x64-8.2.12-0-installer.exe" -OutFile "xampp-installer.exe"
```

Le fichier xampp-installer.exe est bien présent à la racine C:\.

Étape 3 — Installer XAMPP

L'installation va déployer automatiquement :

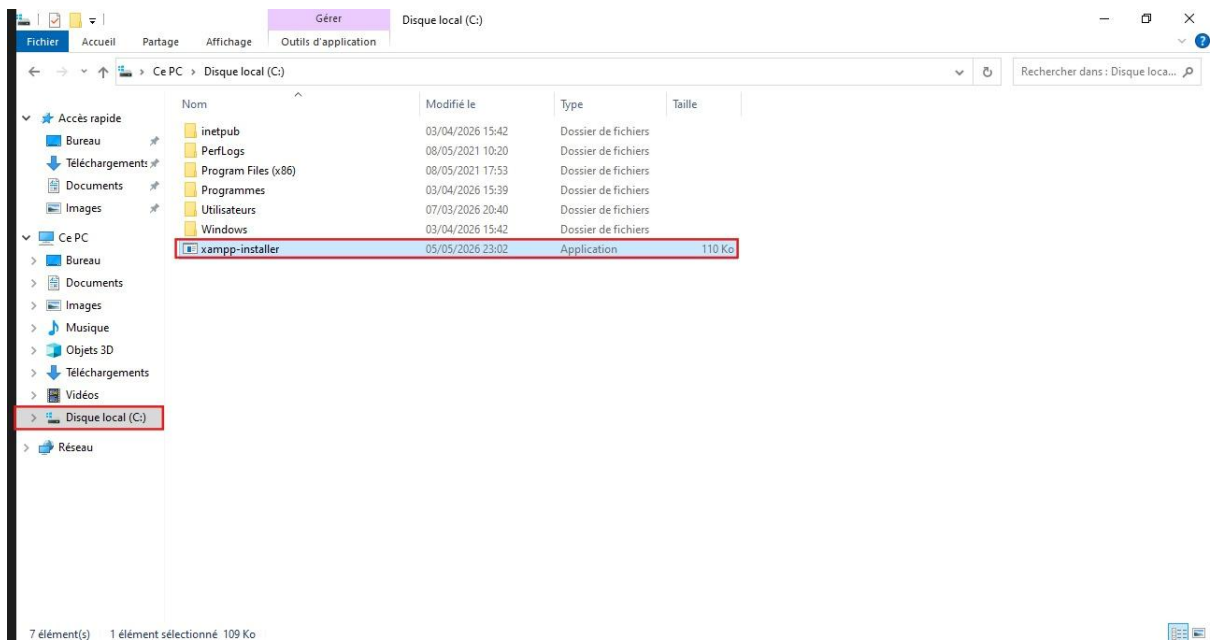
Apache (serveur web, port 80)

MySQL (base de données, port 3306)

PHP (langage pour les pages dynamiques)

Ces trois composants sont nécessaires pour créer notre application web vulnérable.

On passe à l'étape suivante.



Double-cliquez sur xampp-installer.exe à la racine C:\



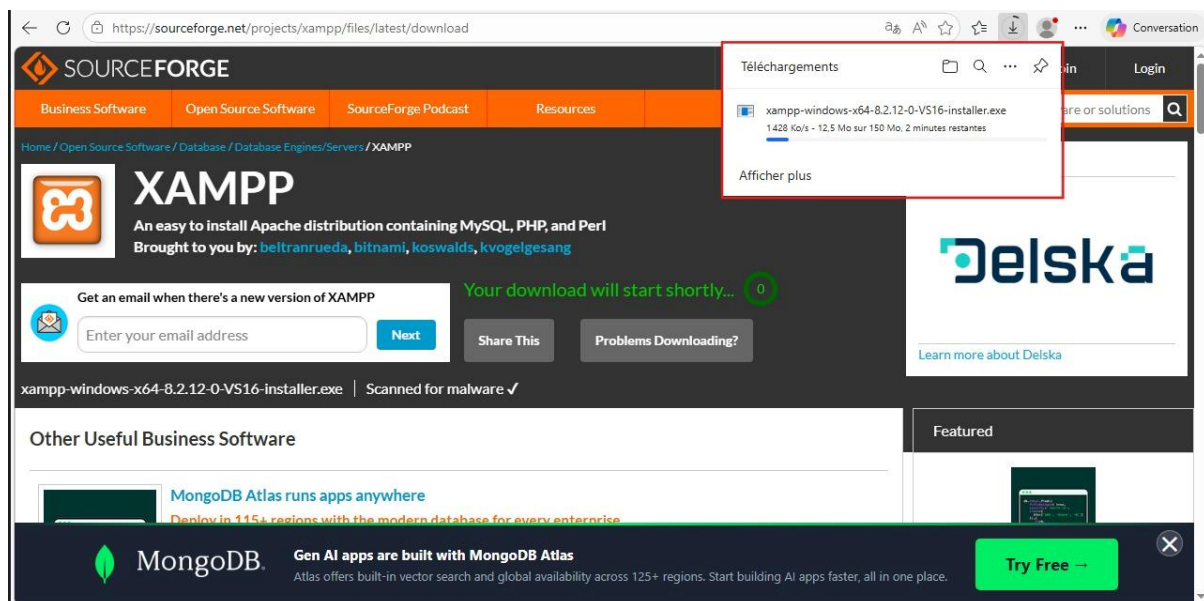
<https://www.apachefriends.org/fr/index.html>

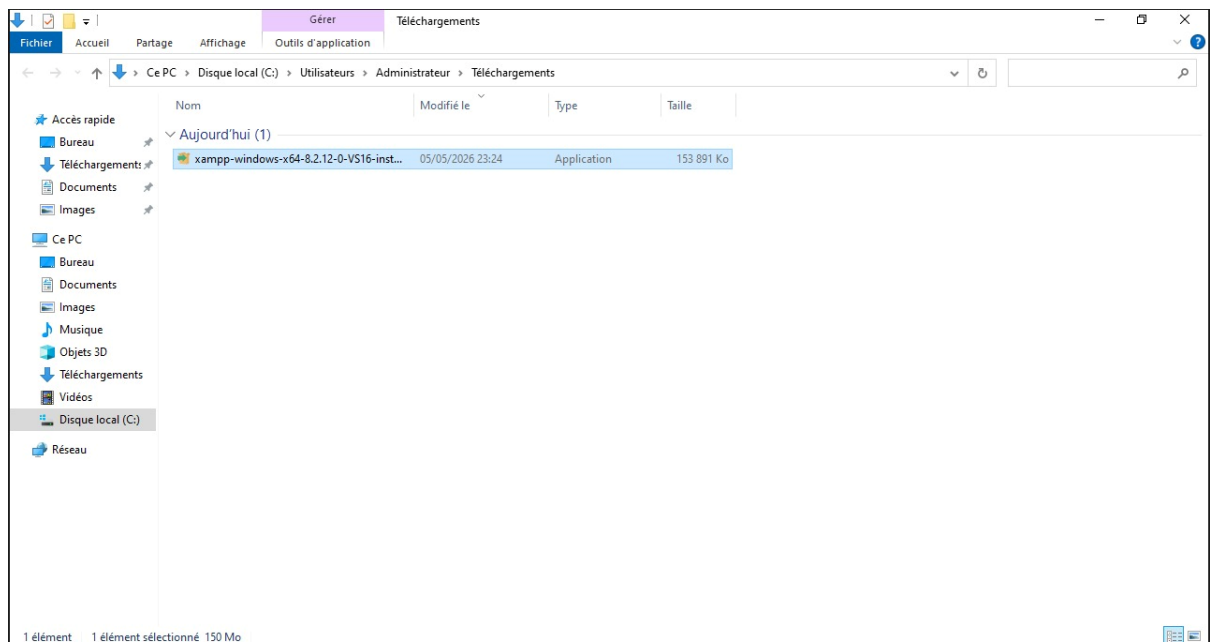
Cliquez sur "Télécharger" pour la version Windows (x64, 8.2.12)

Sauvegardez le fichier dans C:\

Une fois terminé, vérifiez que l'icône du fichier est normale (pas une icône blanche ou corrompue)

Installation en cours :





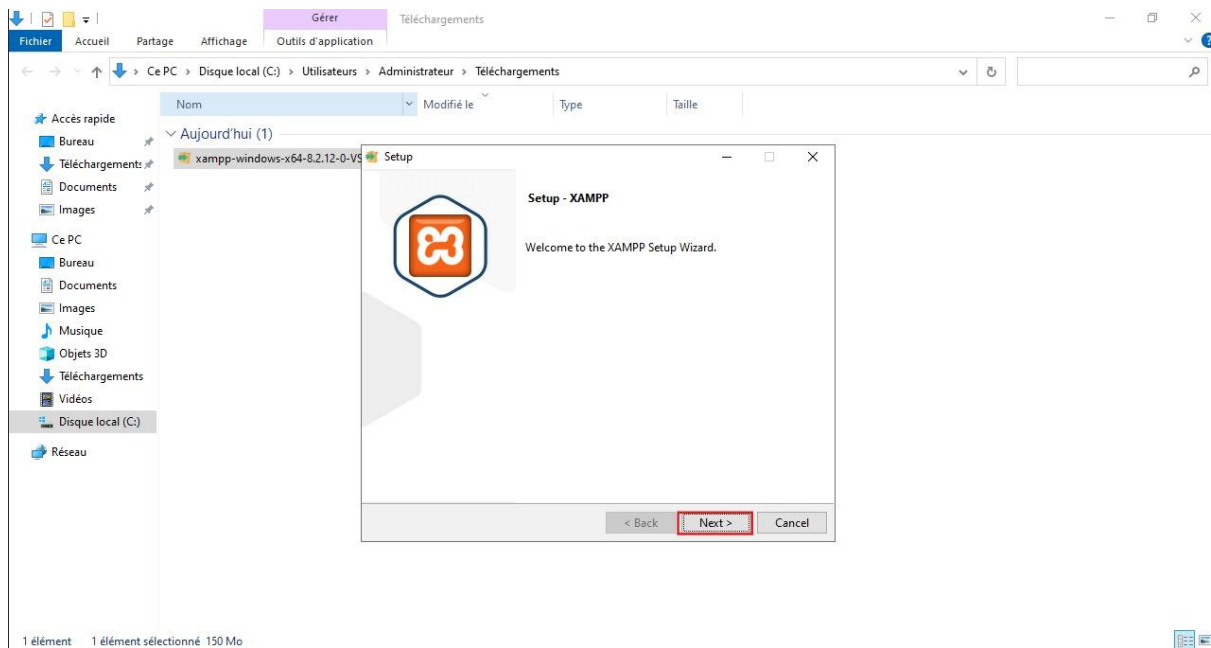
Double-cliquez sur xampp-windows-x64-8.2.12-0-installer.exe

Suivez les étapes d'installation :

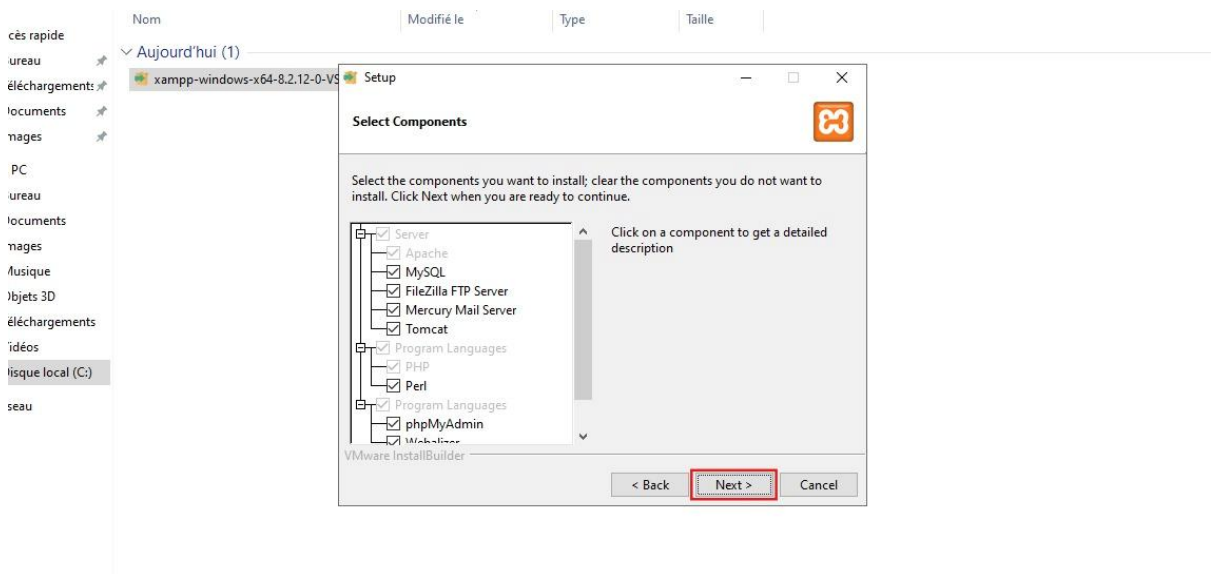
Next - Next (composants par défaut)

Dossier : C:\xampp

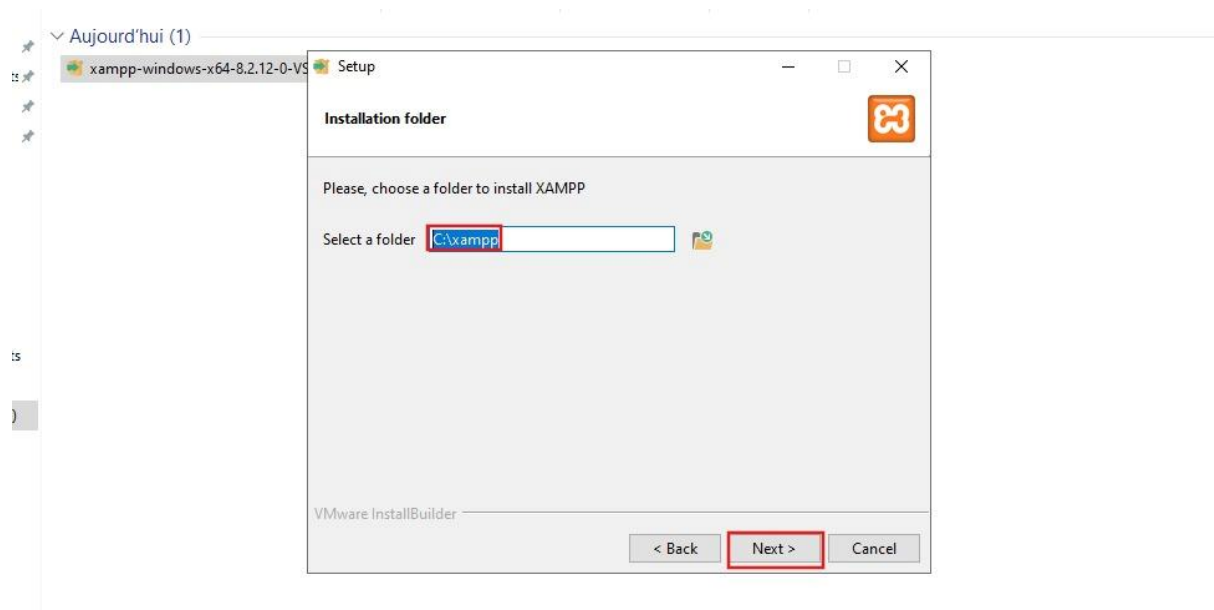
Next - Next - Finish (décochez "Launch XAMPP" pour l'instant)



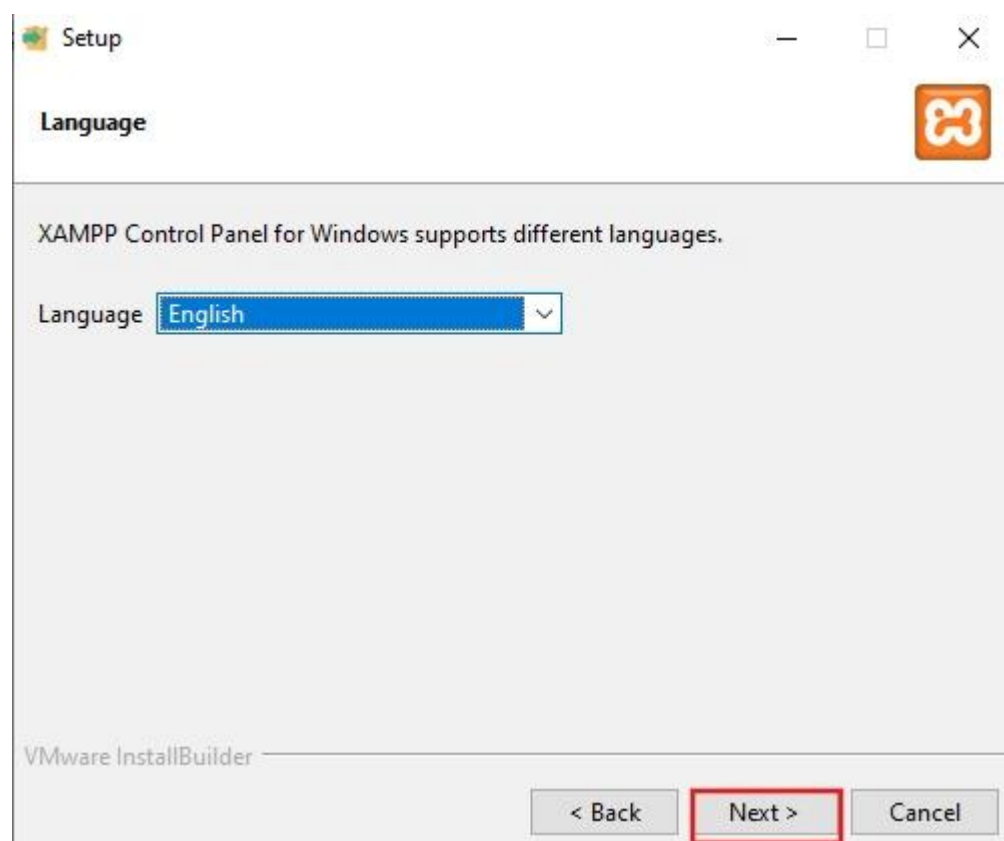
Cliquez sur Next



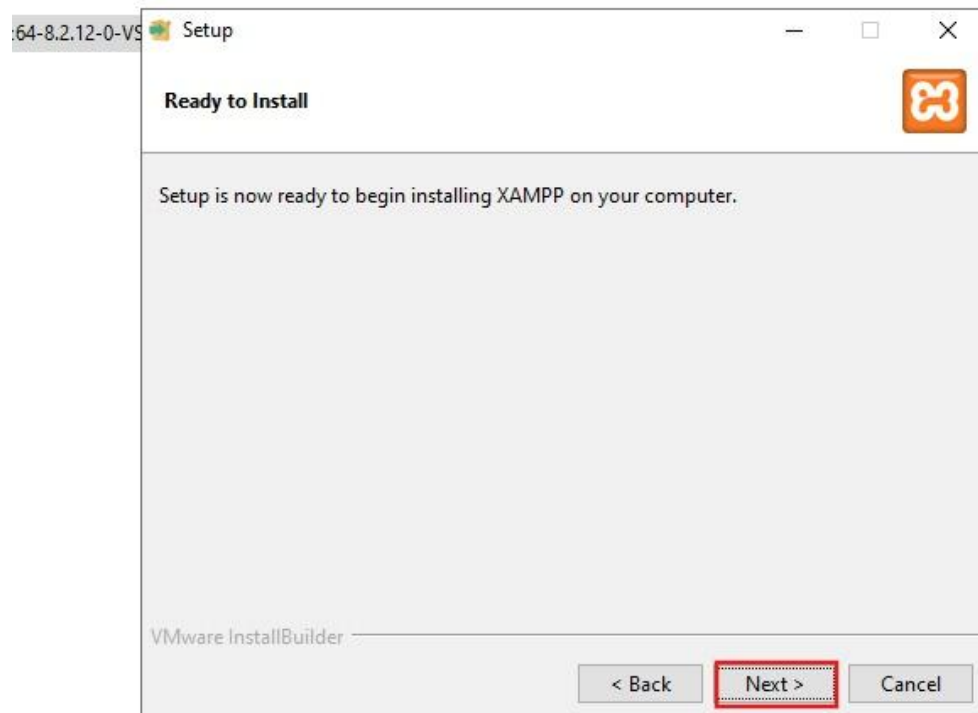
Cliquez sur Next



Laissez le dossier d'installation par défaut, cliquez sur Next



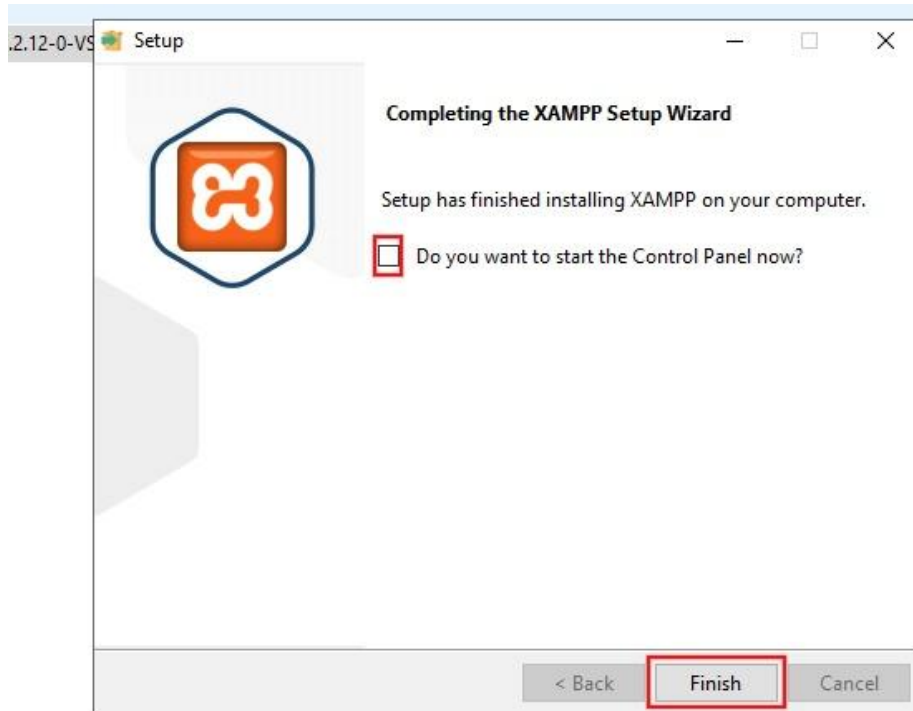
Cliquez sur Next



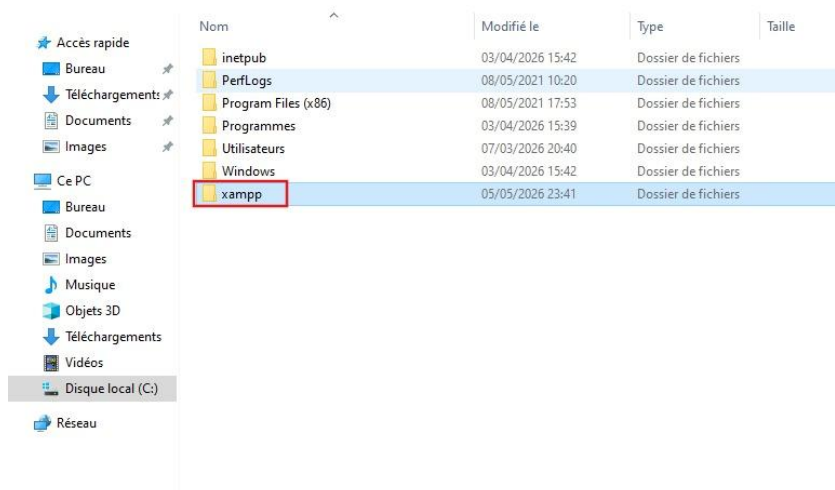
Cliquez sur Next



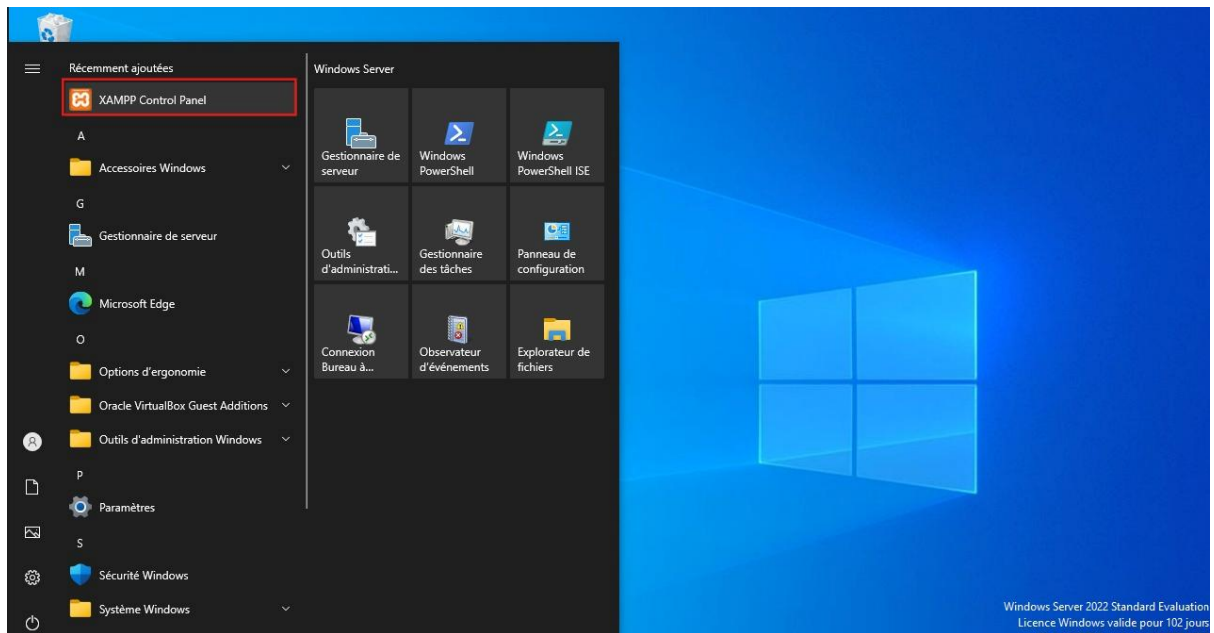
Installation en cours



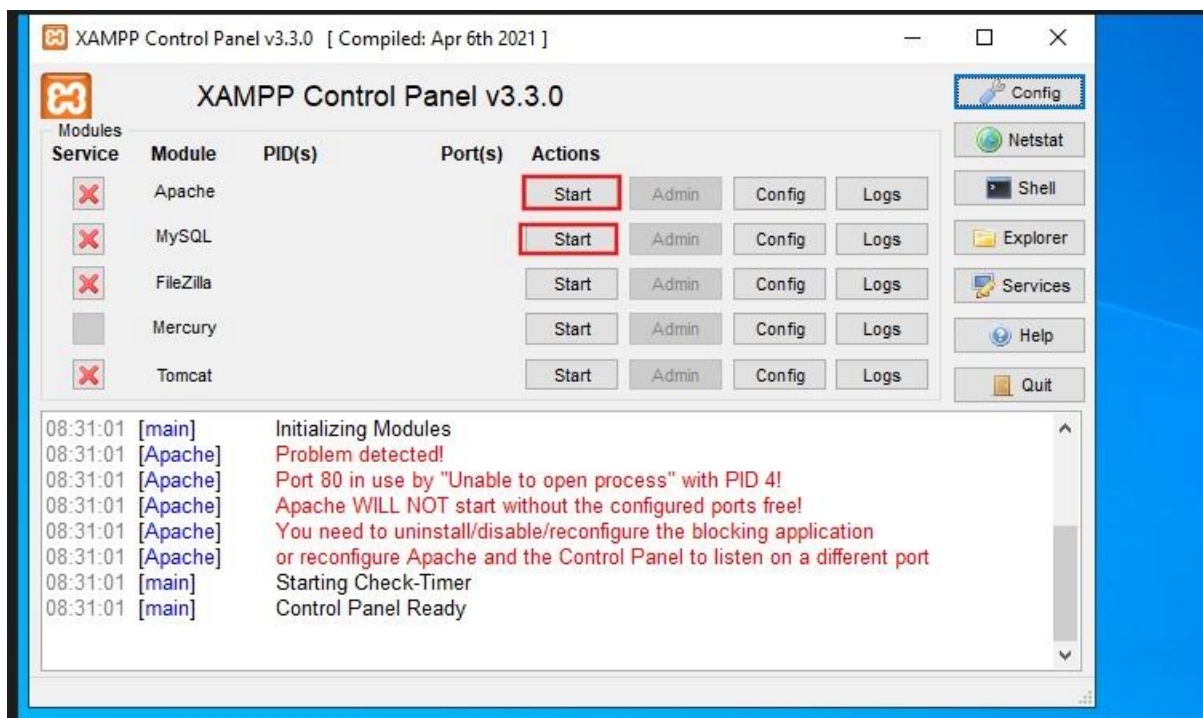
Décochez cette case que nous ne voulons pas directement lancer le panneau de contrôle et cliquez sur finish



Installation réussie à merveille.



Double-clique sur xampp-control.exe (icône orange)

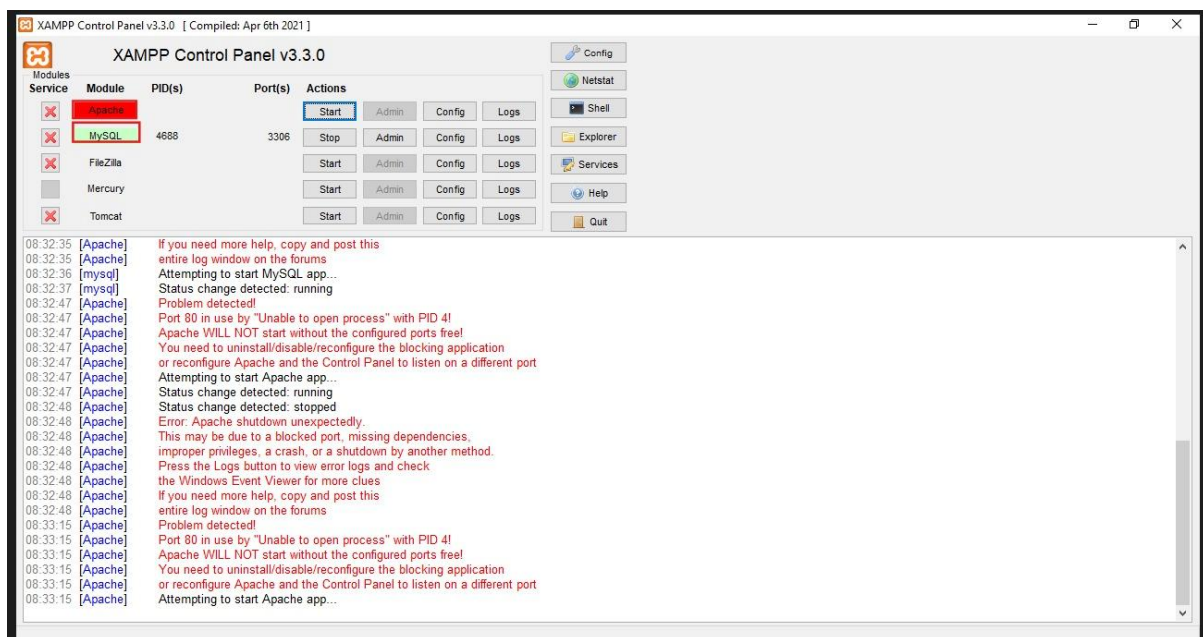


Dans le panneau de contrôle XAMPP :

Cliquez sur "Start" pour Apache (ligne "Apache")

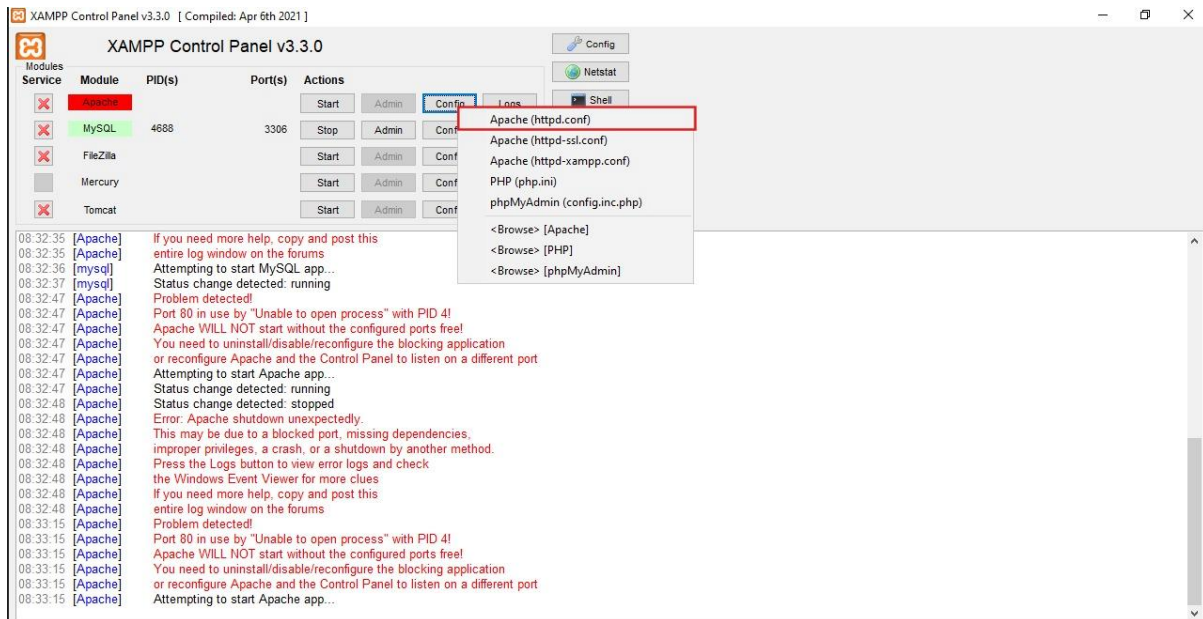
Cliquez sur "Start" pour MySQL (ligne "MySQL")

Ne touchez pas aux autres services



Le port 80 est déjà utilisé. Très probablement par IIS.

Au lieu de désinstaller IIS, nous allons dire à Apache d'écouter sur un autre port comme 8080



Dans XAMPP Control Panel, cliquez sur Config (Apache) -Apache (httpd.conf)

```

httpd.conf - Bloc-notes
Fichier Edition Format Affichage Aide

#
# Mutex: Allows you to set the mutex mechanism and mutex file directory
# for individual mutexes, or change the global defaults
#
# Uncomment and change the directory if mutexes are file-based and the default
# mutex file directory is not on a local disk or is not appropriate for some
# other reason.
#
# Mutex default:logs
#
#
# Listen: Allows you to bind Apache to specific IP addresses and/or
# ports, instead of the default. See also the <VirtualHost>
# directive.
#
# Change this to Listen on specific IP addresses as shown below to
# prevent Apache from glomming onto all bound IP addresses.
#
#Listen 12.34.56.78:80
Listen 80

#
# Dynamic Shared Object (DSO) Support
#
# To be able to use the functionality of a module which was built as a DSO you
# have to place corresponding 'LoadModule' lines at this location so the
# directives contained in it are actually available before they are used.
# Statically compiled modules (those listed by 'httpd -l') do not need
# to be loaded here.
#
# Example:
# LoadModule foo_module modules/mod_foo.so

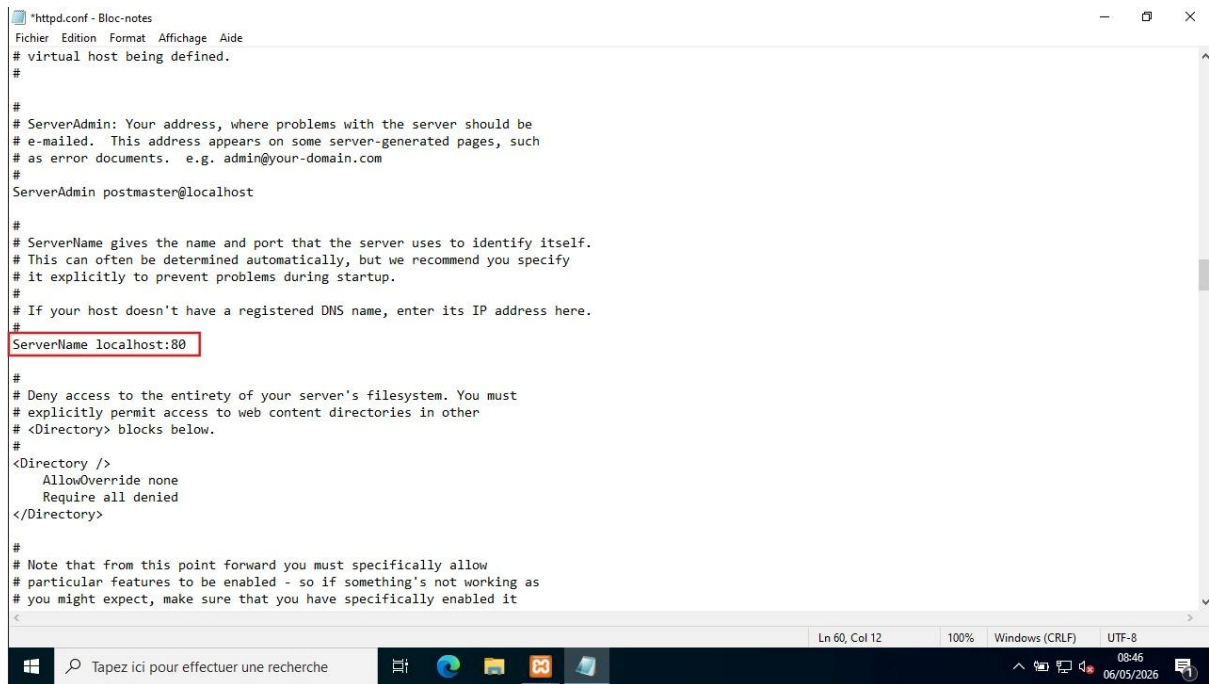
```

Dans le fichier qui s'ouvre, cherchez la ligne :

Listen 80

Remplacez par :

Listen 8080



```
*httpd.conf - Bloc-notes
Fichier Edition Format Affichage Aide
# virtual host being defined.
#
#
# ServerAdmin: Your address, where problems with the server should be
# e-mailed. This address appears on some server-generated pages, such
# as error documents. e.g. admin@your-domain.com
#
ServerAdmin postmaster@localhost
#
# ServerName gives the name and port that the server uses to identify itself.
# This can often be determined automatically, but we recommend you specify
# it explicitly to prevent problems during startup.
#
# If your host doesn't have a registered DNS name, enter its IP address here.
#
ServerName localhost:80
#
# Deny access to the entirety of your server's filesystem. You must
# explicitly permit access to web content directories in other
# <Directory> blocks below.
#
<Directory />
    AllowOverride none
    Require all denied
</Directory>
#
# Note that from this point forward you must specifically allow
# particular features to be enabled - so if something's not working as
# you might expect, make sure that you have specifically enabled it
```

Cherchez aussi la ligne :

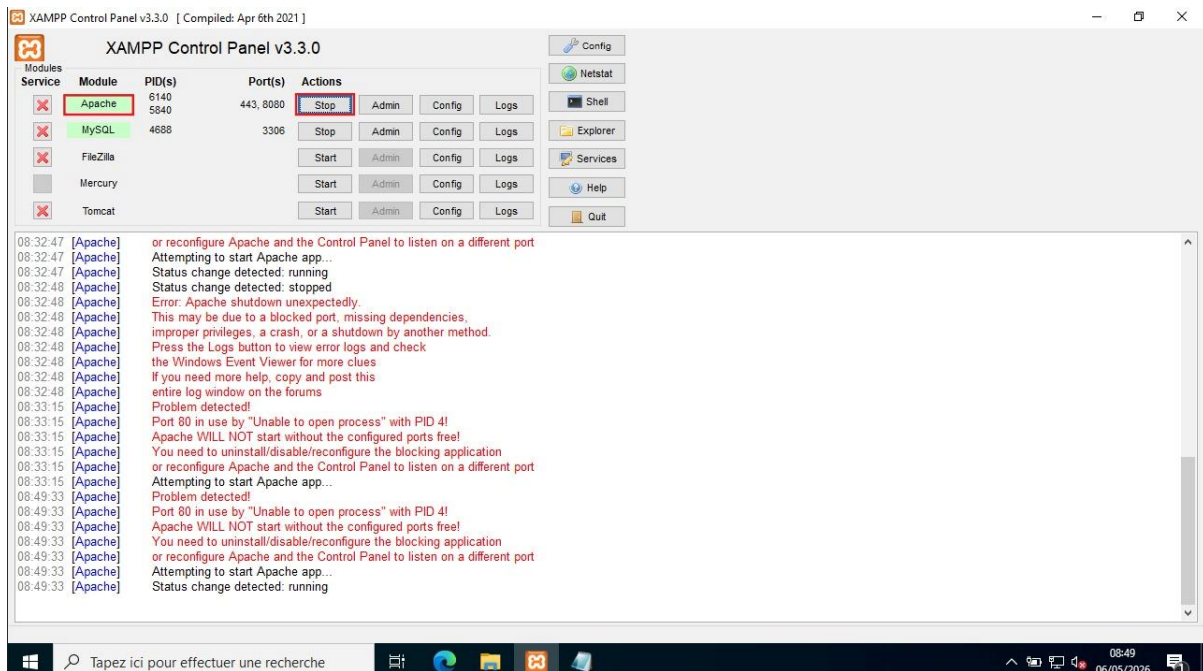
ServerName localhost:80

Remplacez par :

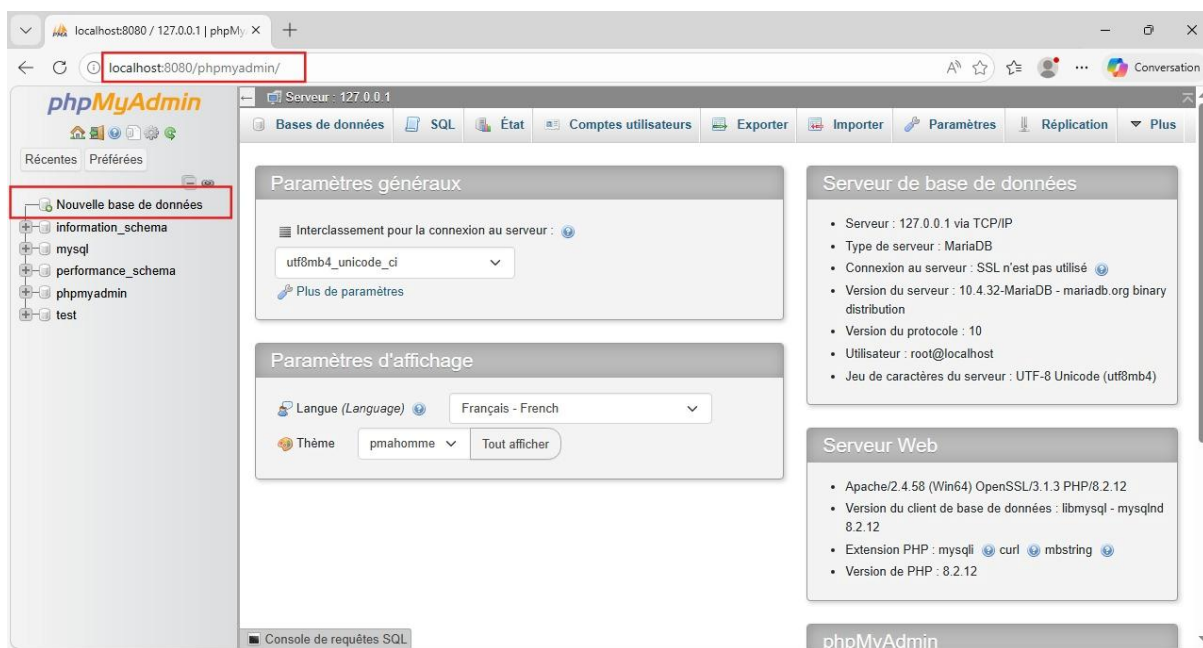
ServerName localhost:8080

Sauvegardez le fichier (Ctrl+S)

Retournez dans XAMPP Control Panel - clique Start sur Apache.



Les correctifs ont été appliqué et tout est maintenant fonctionnel.



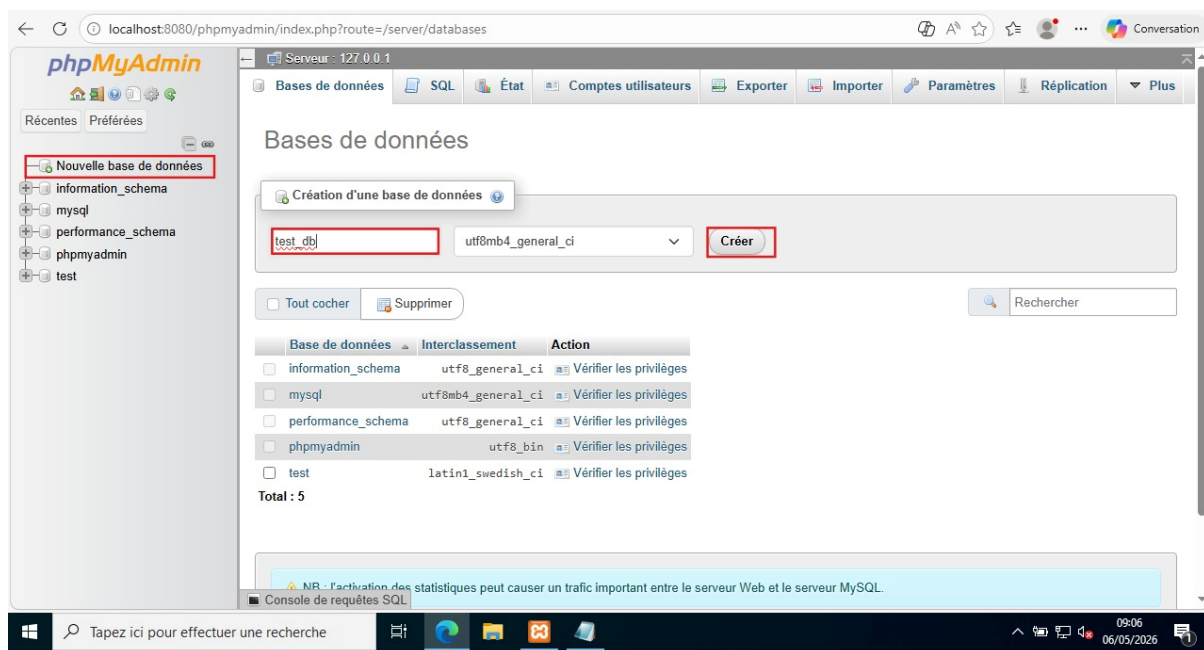
Étape 5 - Créer la base de données vulnérable

Nous devons créer une base de données avec des utilisateurs. L'application web interrogera cette base. La vulnérabilité SQLi permettra à un attaquant de modifier les requêtes pour voir des données non autorisées.

Accéder à phpMyAdmin

Dans un navigateur sur SRV-WEB, allez sur :

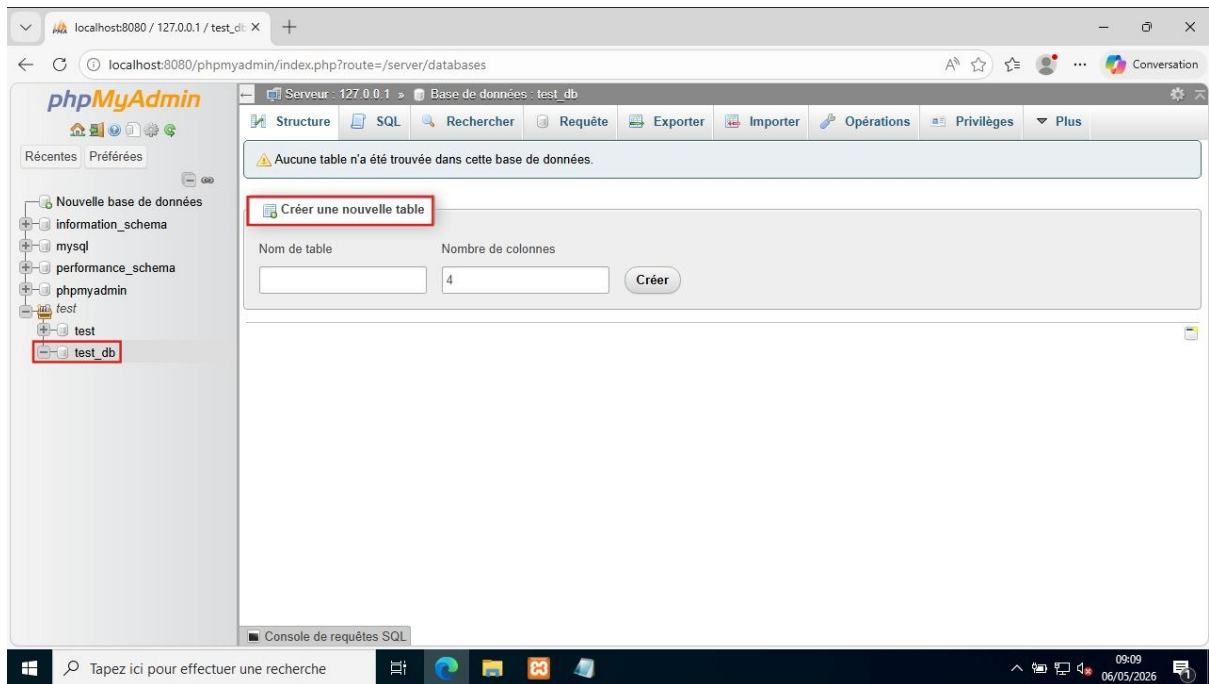
<http://localhost:8080/phpmyadmin>



Cliquez sur l'onglet "Nouvelle base de données" ou "New"

Nom de la base : test_db

Cliquez sur "Créer"



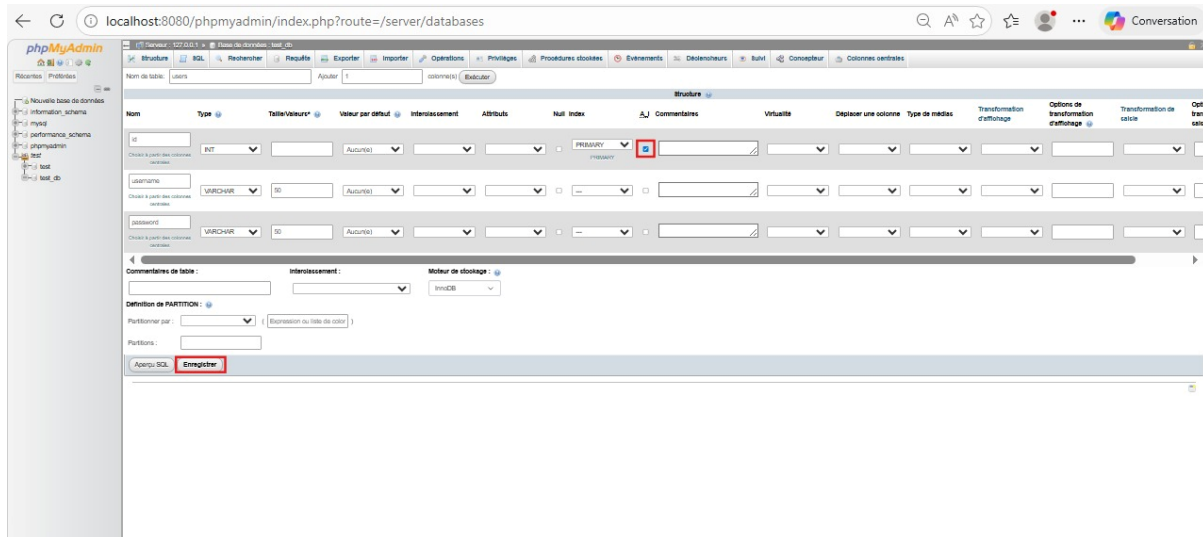
Créer la table users

Dans la base test_db, cliquez sur "Créer une table"

Nom de la table : users

Nombre de colonnes : 3

Cliquez sur "Exécuter"

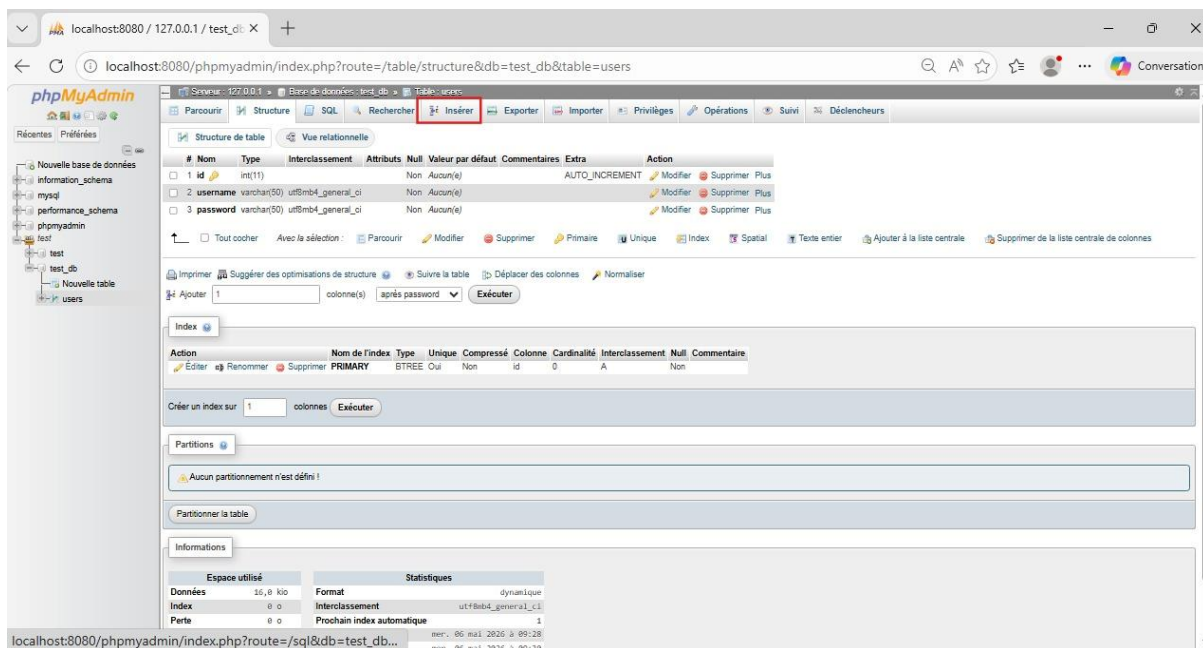


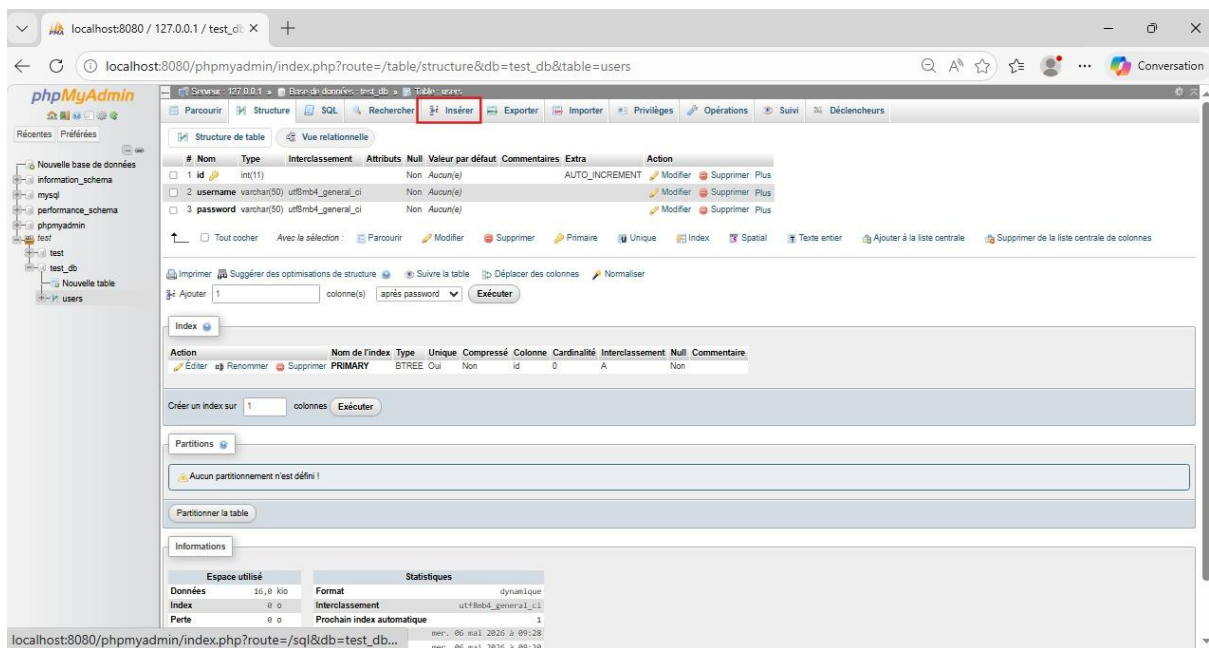
Définir les colonnes

Nom du champ	Type	Longueur/Valeurs
ID	INT	Laisser vide
username	VARCHAR	50
Password	VARCHAR	50

Coche A_I (Auto-Increment) pour id

Cliquez sur "Enregistrer"





Insérer des données

Cliquez sur l'onglet "Insérer" et ajoutez :

id	username	password
1	admin	admin123
2	user	password

localhost:8080/phpmyadmin/index.php?route=/table/change&db=test_db&table=users

phpMyAdmin

Récentes Préférences

Nouvelle base de données

- information_schema
- mysql
- performance_schema
- phpmyadmin
- test
- test_db
 - Nouvelle table
 - users

Colonne	Type	Fonction	Null	Valeur
id	int(11)			1
username	varchar(50)			admin
password	varchar(50)			admin123

Exécuter

☐ Ignorer

Colonne	Type	Fonction	Null	Valeur
id	int(11)			2
username	varchar(50)			user
password	varchar(50)			password

Exécuter

Insérer comme une nouvelle ligne et ensuite Retourner à la page précédente

Aperçu SQL Réinitialiser Exécuter

Continuer l'insertion avec 2 lignes

localhost:8080/phpmyadmin/index.php?lang=fr

phpMyAdmin

Récentes Préférences

Nouvelle base de données

- information_schema
- mysql
- performance_schema
- phpmyadmin
- test
- test_db
 - Nouvelle table
 - users

2 lignes insérées.

```
INSERT INTO `users` (`id`, `username`, `password`) VALUES ('1', 'admin', 'admin123'), ('2', 'user', 'password');
```

Exécuter une ou des requêtes SQL sur la table « test_db.users »

```
1 INSERT INTO `users` (`id`, `username`, `password`) VALUES ('1', 'admin', 'admin123'), ('2', 'user', 'password');
```

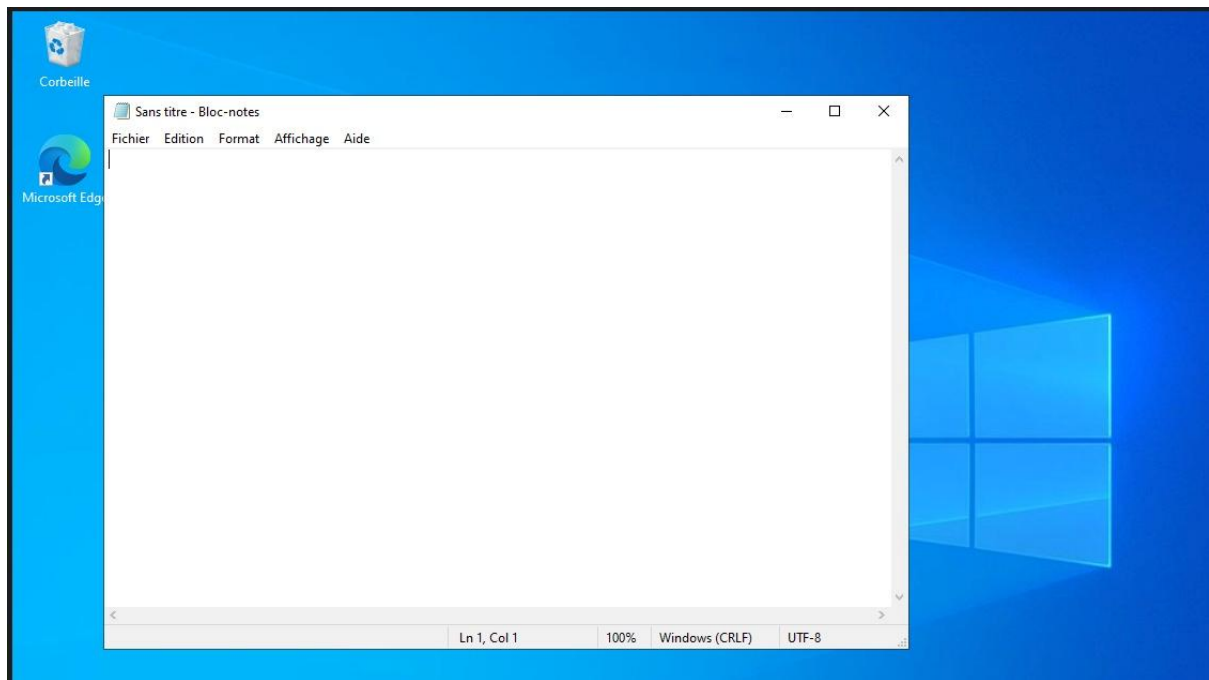
SELECT * SELECT INSERT UPDATE DELETE Effacer Format Récupérer la requête auto-sauvegardée

☐ Lier les paramètres

Conserver cette requête SQL dans les signets :

Délimiteur : Afficher à nouveau la requête après exécution Conserver la boîte de requêtes ROLLBACK à la fin Activer la vérification des clés étrangères Exécuter

Données bien insérées dans PhpMyAdmin



Étape 6 : Créer le fichier PHP

1. Sur SRV-WEB, ouvrez Bloc-notes (Notepad)

2. Copiez-collez ce code :

```
<?php
```

```
$conn = mysqli_connect("localhost", "root", "", "test_db");
```

```
$id = $_GET['id'];
```

```
$query = "SELECT * FROM users WHERE id = $id";
```

```
echo "Requête exécutée : " . $query . "<br><br>";
```

```
$result = mysqli_query($conn, $query);
```

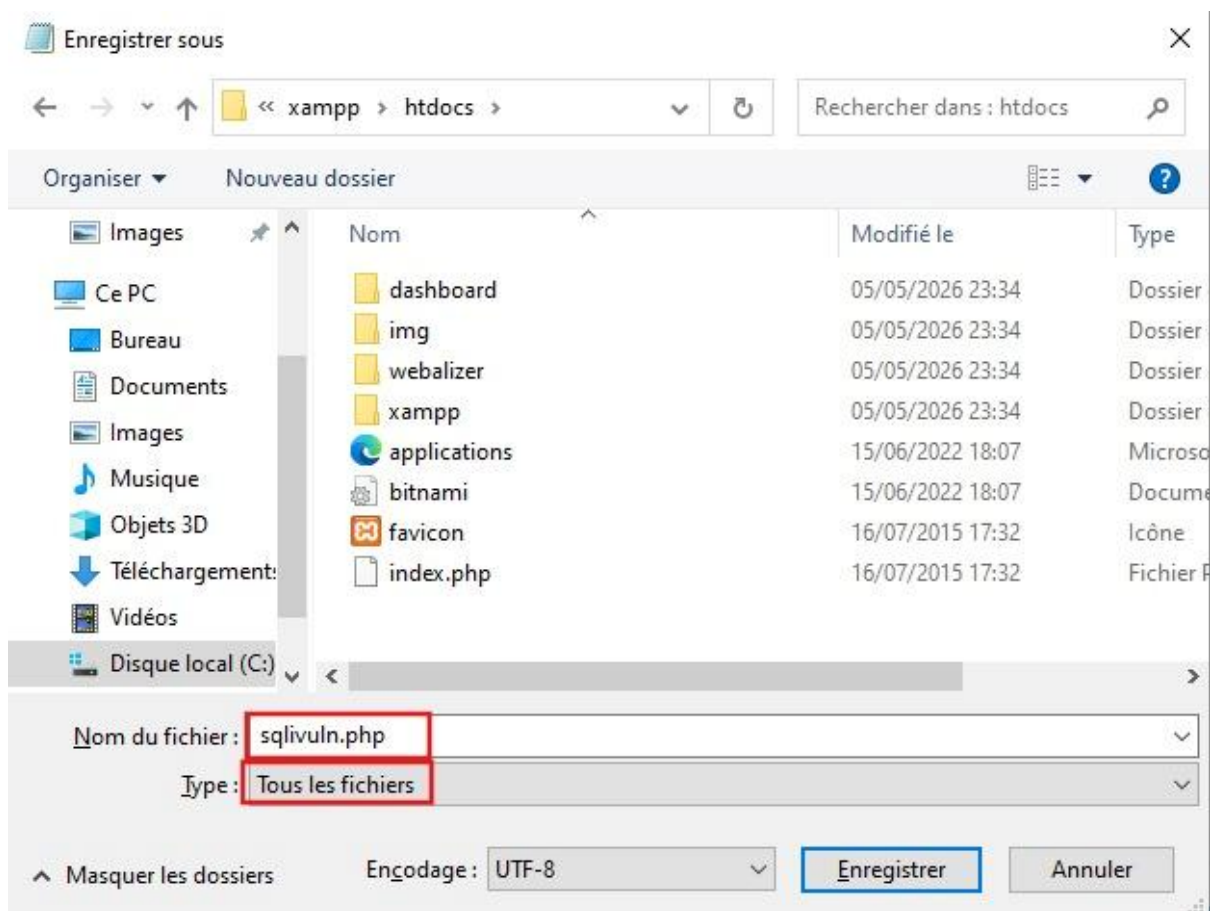
```
if ($result) {
```

```
    while($row = mysqli_fetch_assoc($result)) {
```

```

        echo "Nom d'utilisateur : " . $row['username'] . "<br>";
        echo "Mot de passe : " . $row['password'] . "<br><br>";
    }
} else {
    echo "Erreur SQL : " . mysqli_error($conn);
}
?>

```



Enregistrer le fichier :

Fichier : Enregistrer sous

Type : "Tous les fichiers (.)"

Nom : sqlivuln.php

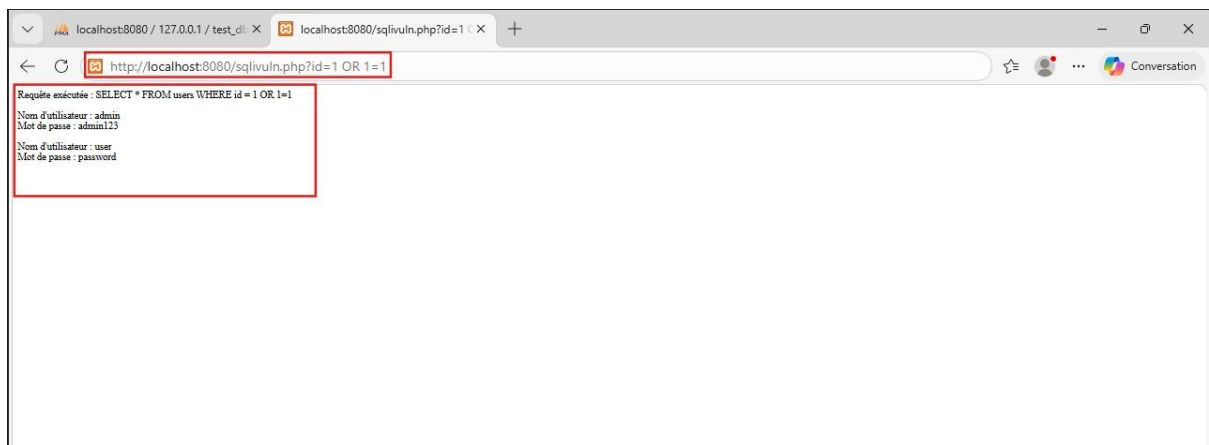
Emplacement : C:\xampp\htdocs\



Testez dans le navigateur :

Aller sur : `http://localhost:8080/sqlivuln.php?id=1`

On voit la requête SQL, les infos de l'utilisateur admin ainsi que le reste des comptes utilisateurs existants.



Vulnérabilité 2 implémenté avec succès :

L'implémentation de la vulnérabilité SQLi a consisté à :

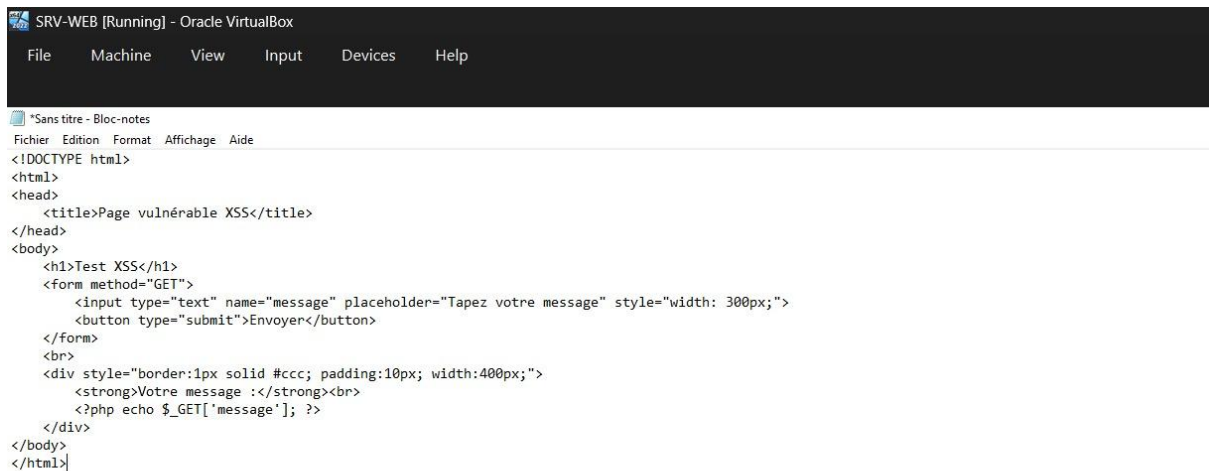
Installer XAMPP sur SRV-WEB pour disposer d'un serveur web (Apache, port 8080) et d'une base de données (MySQL) ; *

Créer une base de données test_db contenant une table users avec deux comptes ;

Développer une page PHP (sqlivuln.php) construisant une requête SQL en concaténant directement le paramètre utilisateur id sans aucun filtrage.

Cette absence de validation permet à un attaquant de modifier la structure de la requête. La preuve est apportée en comparant une requête normale (id=1) qui retourne un seul utilisateur, et une requête injectée (id=1 OR 1=1) qui retourne tous les utilisateurs. Cette différence démontre le caractère critique de la vulnérabilité.

Implémentation vulnérabilité 3 :



```
<!DOCTYPE html>
<html>
<head>
  <title>Page vulnérable XSS</title>
</head>
<body>
  <h1>Test XSS</h1>
  <form method="GET">
    <input type="text" name="message" placeholder="Tapez votre message" style="width: 300px;">
    <button type="submit">Envoyer</button>
  </form>
  <br>
  <div style="border:1px solid #ccc; padding:10px; width:400px;">
    <strong>Votre message :</strong><br>
    <?php echo $_GET['message']; ?>
  </div>
</body>
</html>
```

VULNÉRABILITÉ 3 - Applicatif - XSS (Cross-Site Scripting)

Le XSS permet à un attaquant d'injecter du code JavaScript malveillant dans une page web. Ce code s'exécute dans le navigateur de la victime et peut :

voler des cookies récupérant ainsi les sessions utilisateur, capturer les frappes clavier enregistrant ainsi les mots de passe saisis, rediriger vers un site piégé afin de voler toutes les informations désirées et dégrader l'expérience ce qui envoie des pop-ups indésirés et des redirections involontaires.

Étape 1 — Créer la page PHP vulnérable au XSS

Sur SRV-WEB, ouvrez Bloc-notes (Notepad) en administrateur

Copier-coller ce code :

```
<!DOCTYPE html>
```

```
<html>
```

```
<head>
```

```
  <title>Page vulnérable XSS</title>
```

```
</head>

<body>

  <h1>Test XSS</h1>

  <form method="GET">

    <input type="text" name="message" placeholder="Tapez votre message" style="width:
300px;">

    <button type="submit">Envoyer</button>

  </form>

  <br>

  <div style="border:1px solid #ccc; padding:10px; width:400px;">

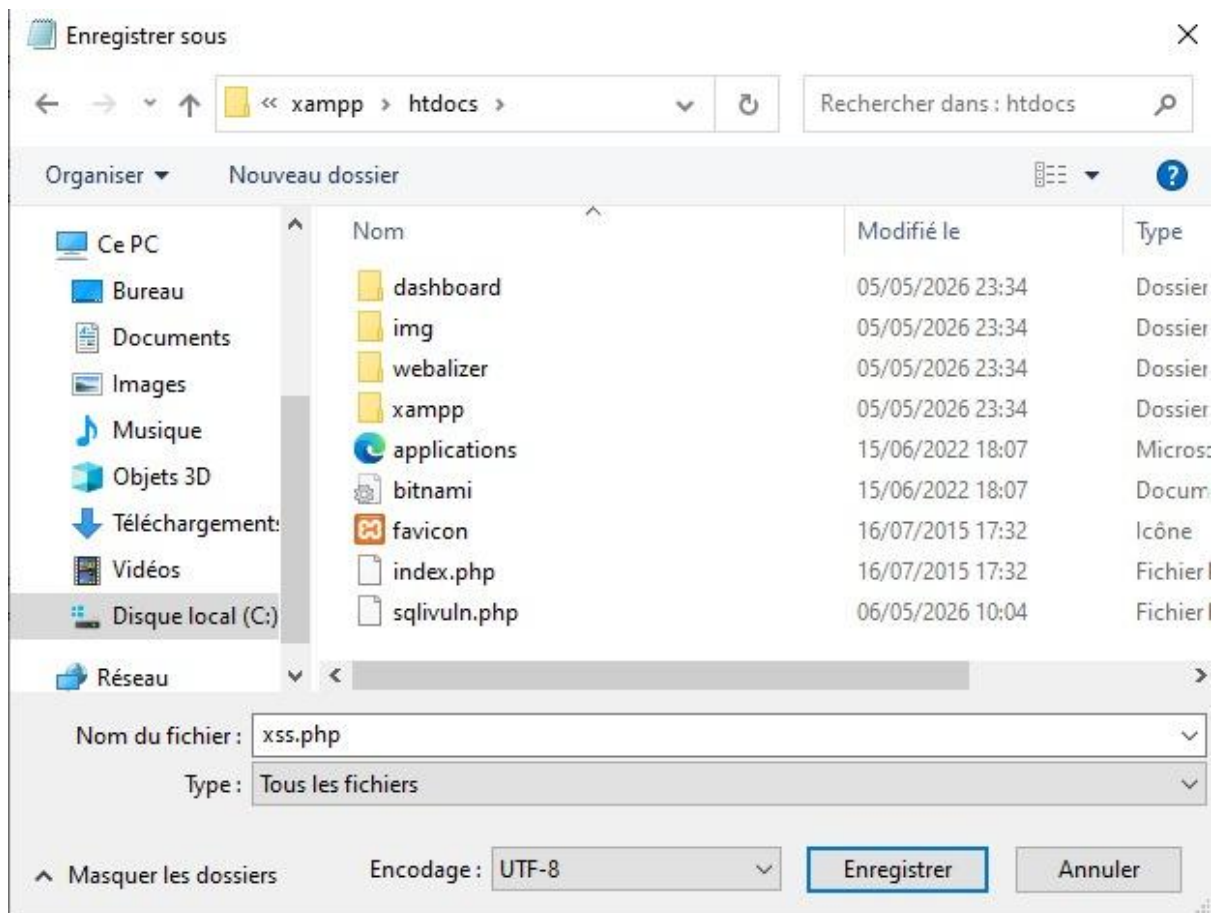
    <strong>Votre message :</strong><br>

    <?php echo $_GET['message']; ?>

  </div>

</body>

</html>
```



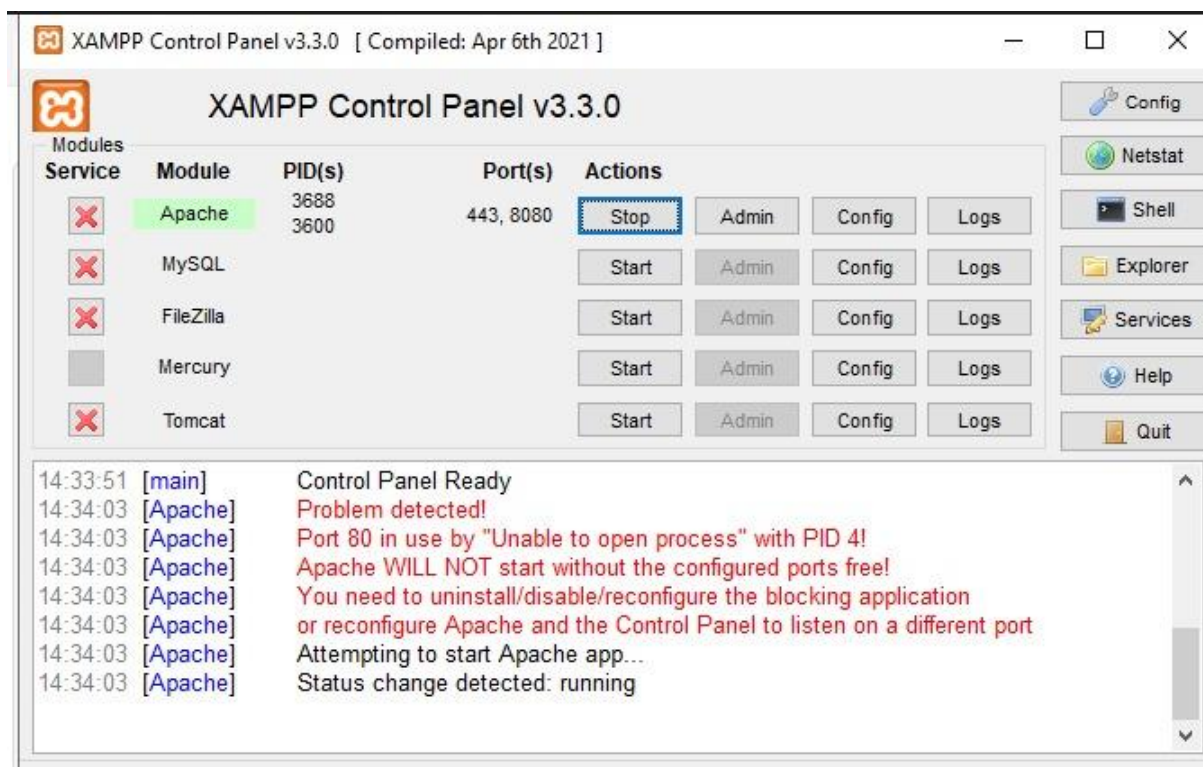
Enregistrer le fichier :

Fichier - Enregistrer sous

Type : "Tous les fichiers (.)"

Nom : xss.php

Emplacement : C:\xampp\htdocs\



Activez à nouveau le serveur web Apache afin d'accéder à la page web XSS servie.

Ouvrez le XAMPP Control Panel (raccourci sur le bureau ou C:\xampp\xampp-control.exe)

Vérifiez qu'Apache a un bouton vert "Running" (entouré en vert)

Si Apache n'est pas vert :

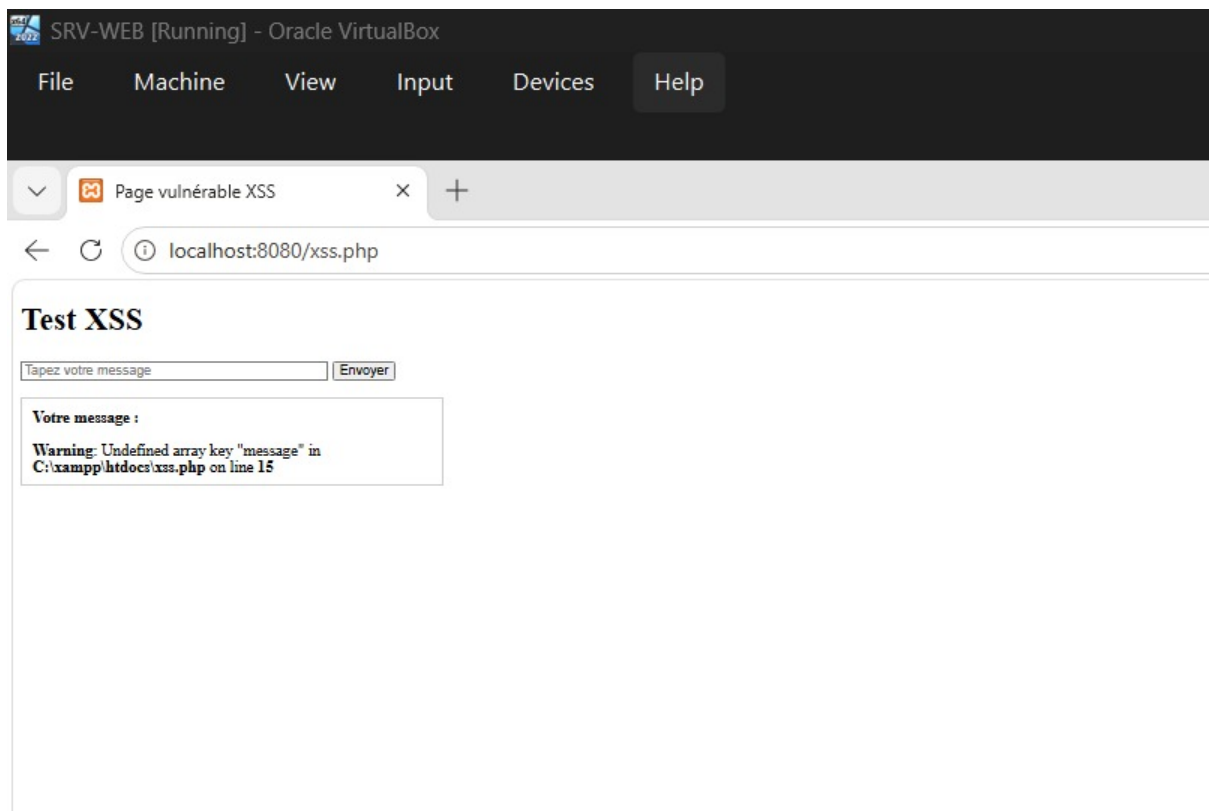
Cliquez sur Start à côté d'Apache

Si Apache a un problème (bouton jaune/rouge) :

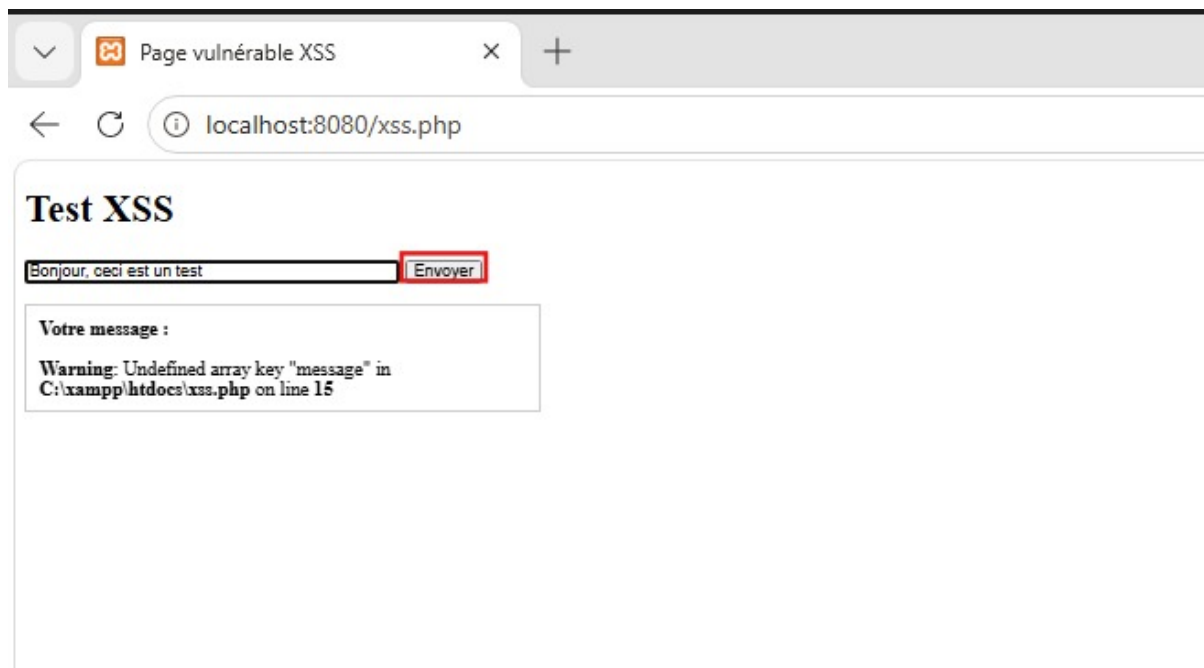
Cliquez sur Stop (si actif)

Attendez 2 secondes

Cliquez sur Start



La page XSS est fonctionnelle. L'avertissement "Undefined array key" est normal car c'est la première connexion et aucun message n'a encore été envoyé.

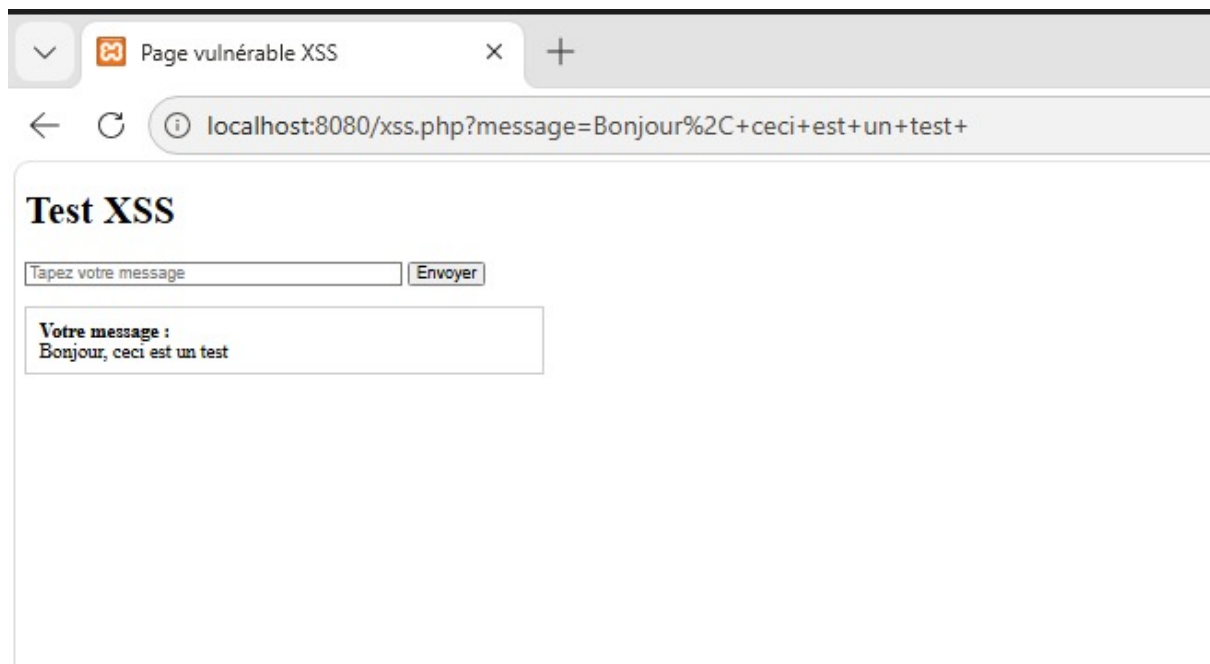


Tester la vulnérabilité XSS.

Dans le champ, taper : Bonjour, ceci est un test

Cliquer sur Envoyer.

Résultat :

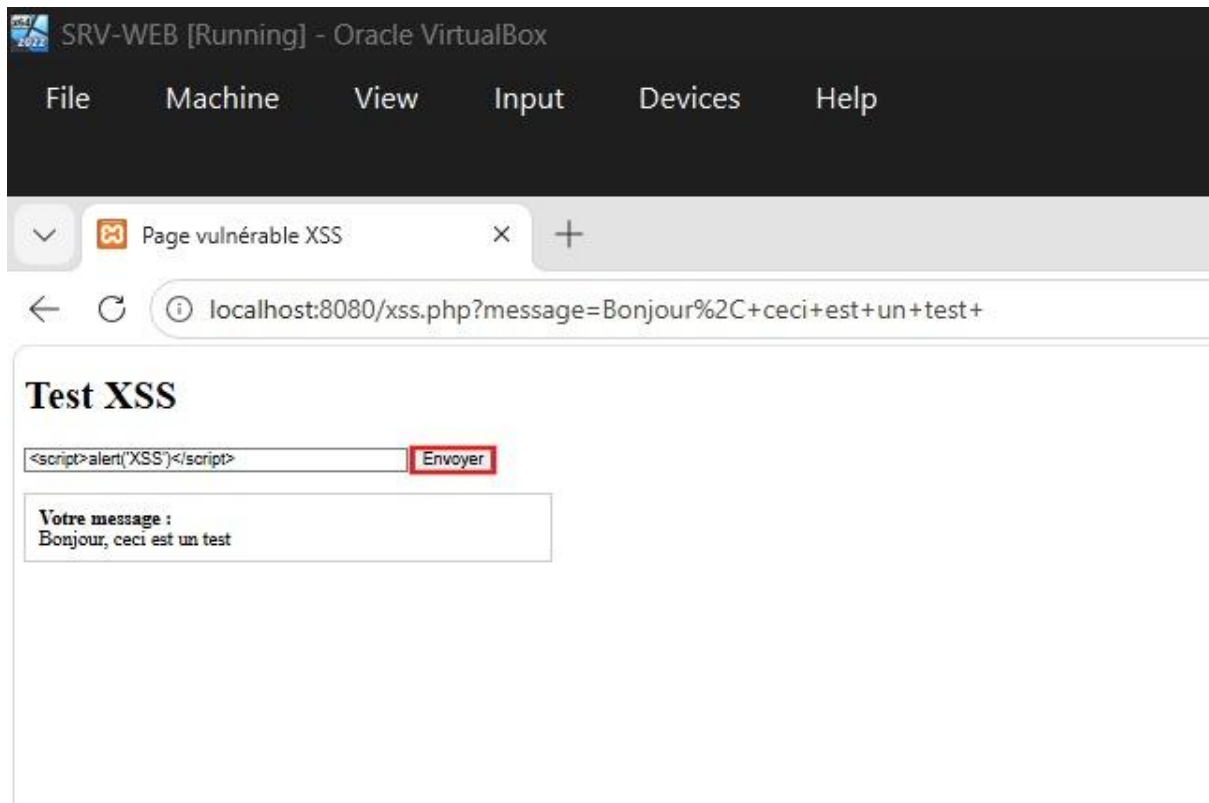


Tester l'injection XSS :

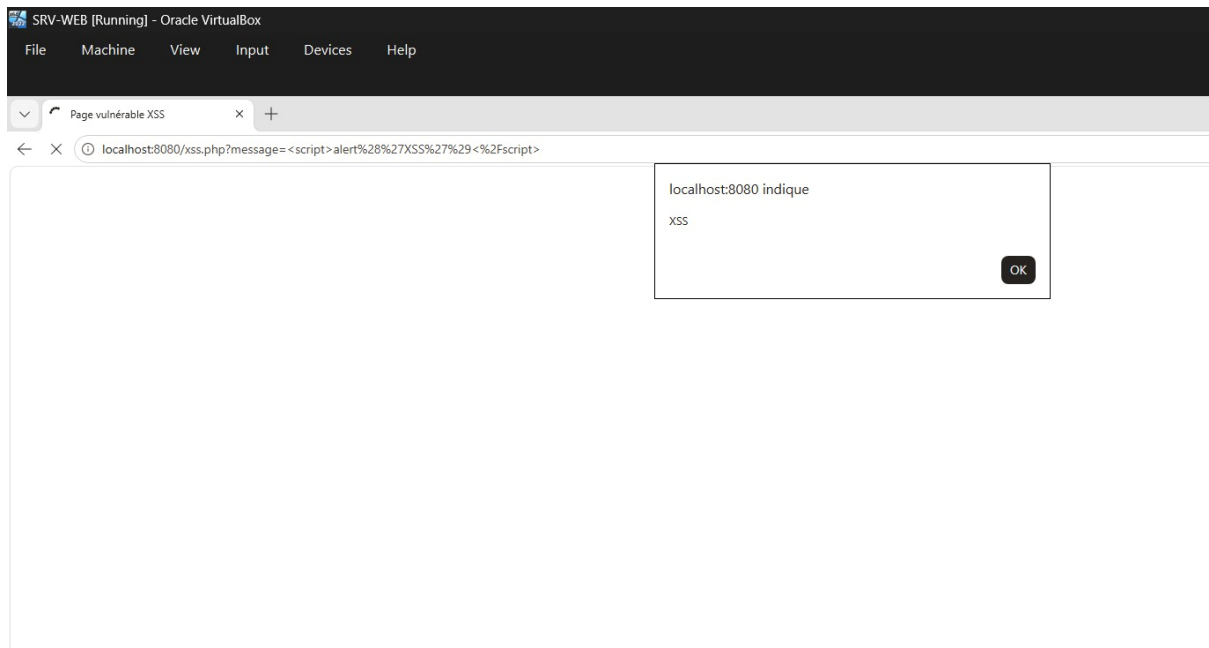
Dans le champ, taper exactement :

```
<script>alert('XSS')</script>
```

Cliquer sur Envoyer



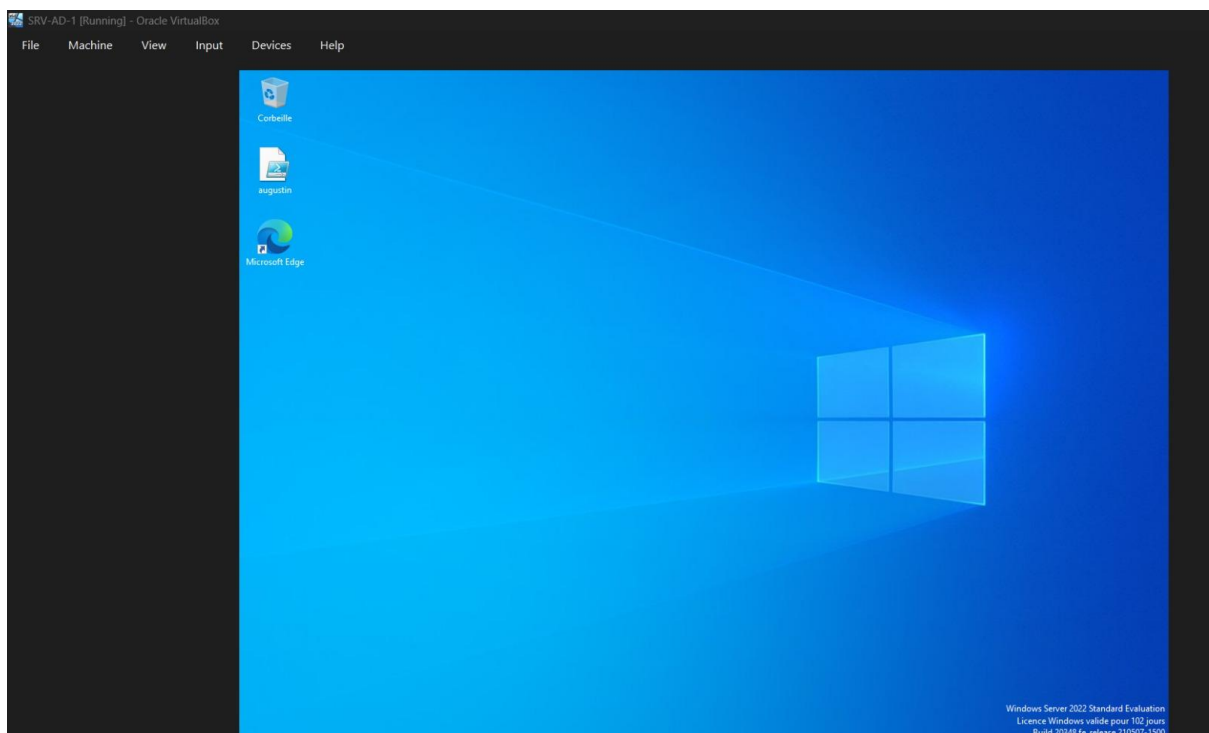
Résultat :



Une faille de type XSS a été implantée sur le serveur web SRV-WEB. Elle permet à un attaquant d'injecter et d'exécuter du code JavaScript de son choix dans le navigateur de la victime.

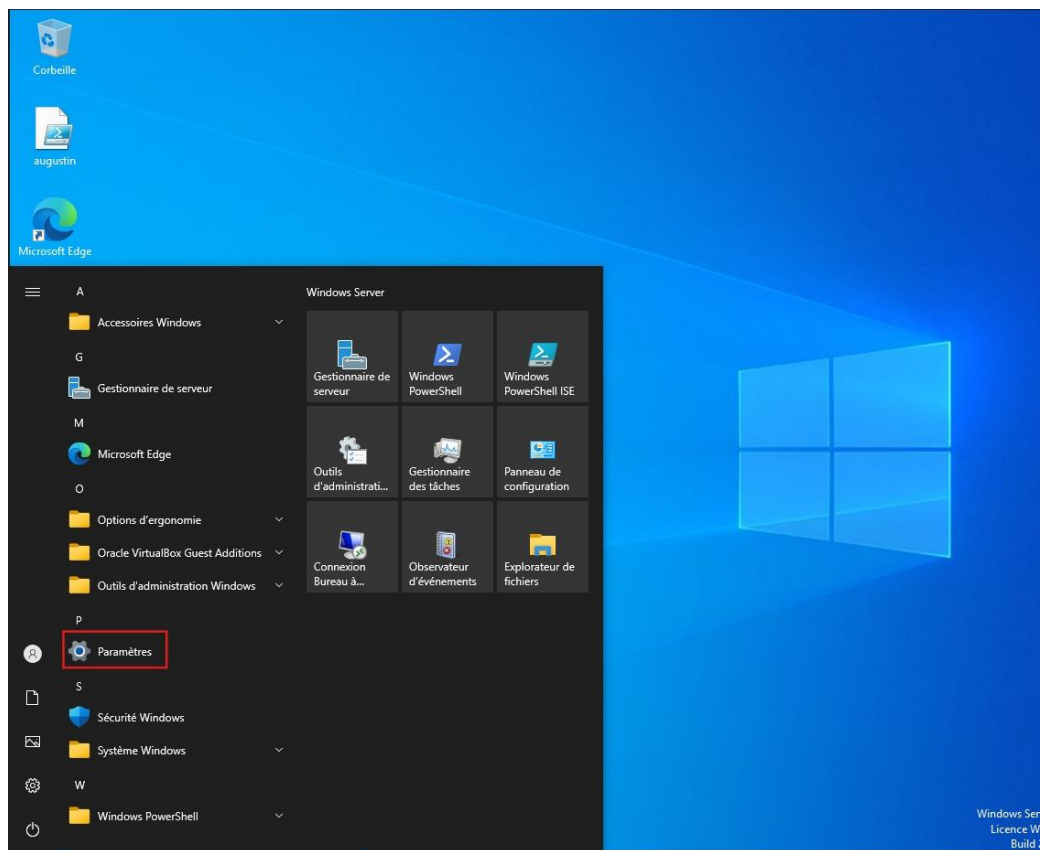
Vulnérabilité 4 – Système - Serveurs Windows non à jour

Étape 1 - Accéder à SRV-AD-1

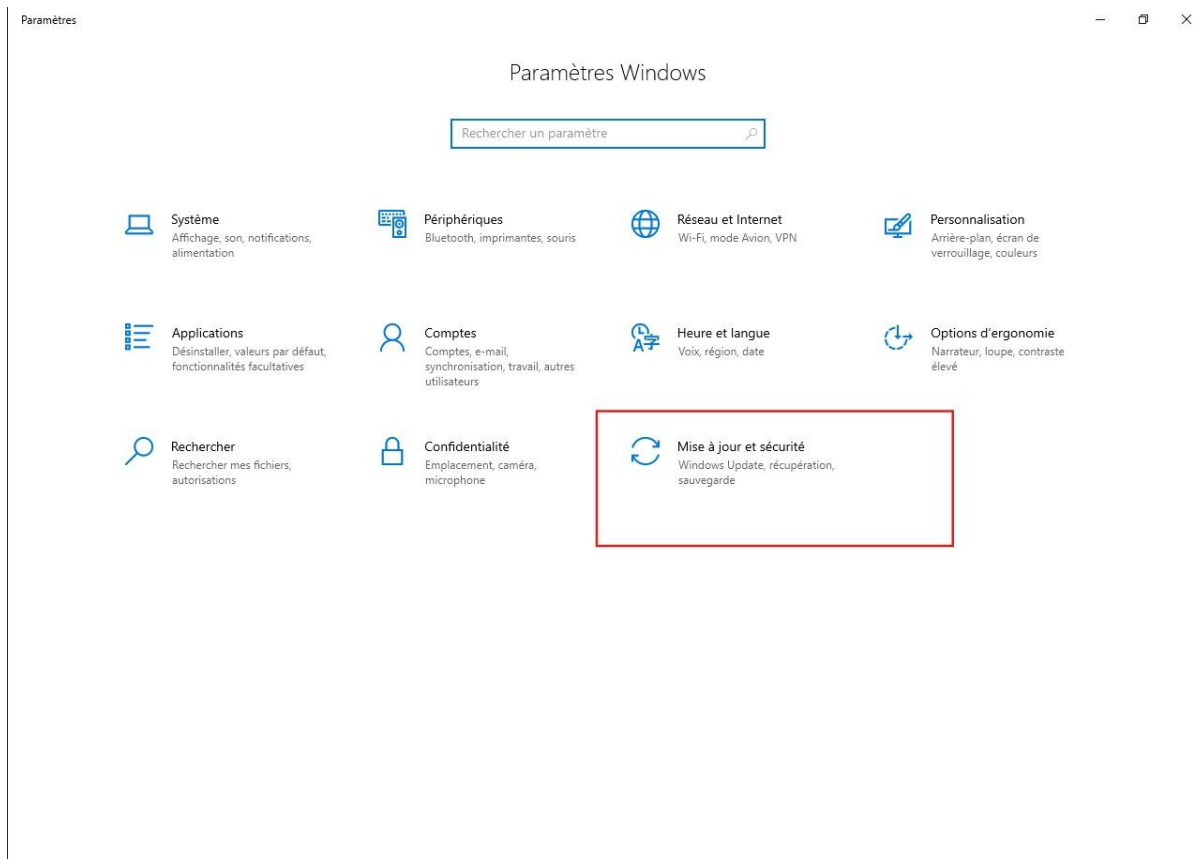


Étape 2 — Vérifier l'état des mises à jour

Paramètres Windows (menu Démarrer - engrenage)

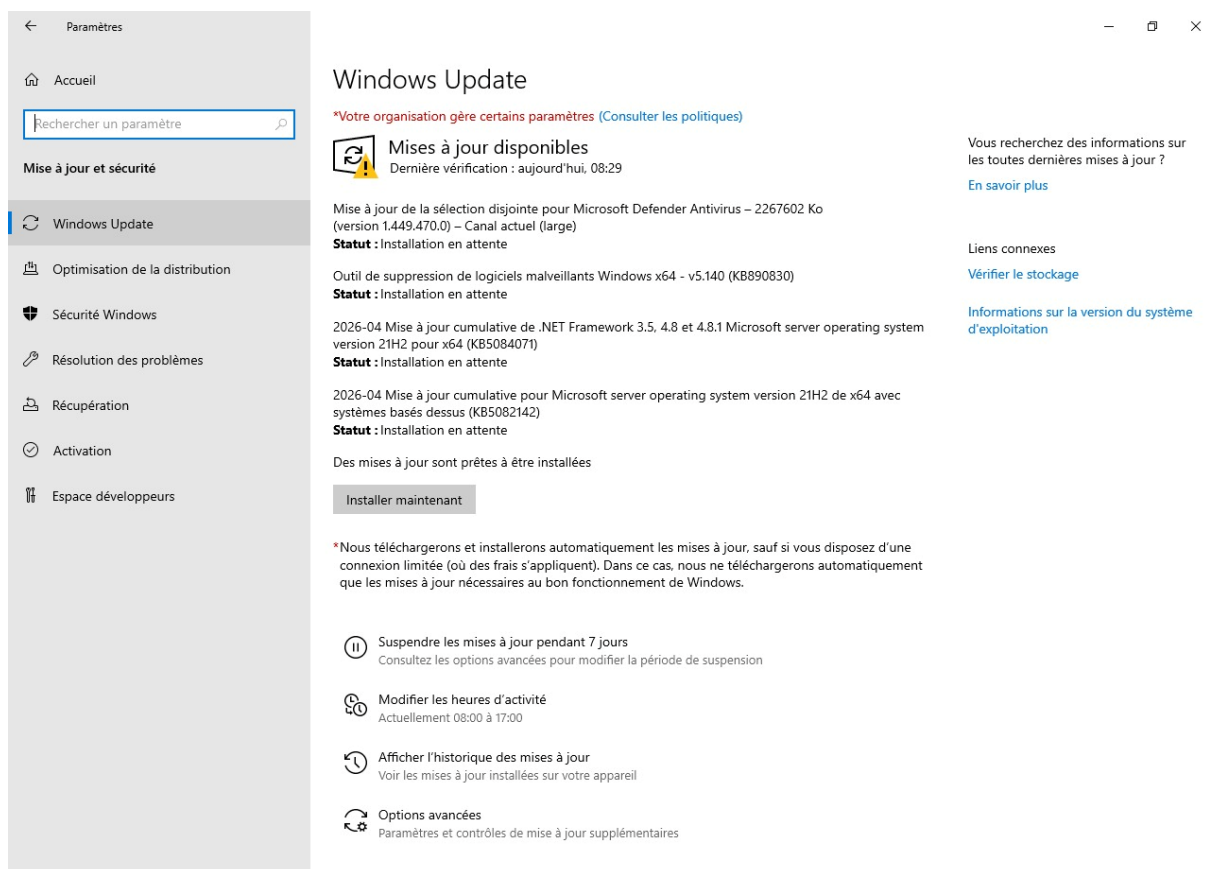


Mise à jour et sécurité - Windows Update :



Etape 3 - Constater les mises à jour disponibles

On constate des mises à jour de sécurité en attente et des mises à jour cumulatives.



Sur le serveur SRV-AD-1 (192.168.1.11), plusieurs mises à jour critiques sont en attente d'installation, notamment la mise à jour cumulative KB5082142 ainsi que des correctifs pour .NET Framework (KB5084071) et l'outil de suppression de logiciels malveillants (KB890830).

L'absence de ces correctifs expose le système à des vulnérabilités documentées (CVE) dont les impacts potentiels sont majeurs :

Prise de contrôle totale à distance du serveur sans authentification (ex: CVE-2024-38063) ;

Contournement des sécurités avancées du noyau (Virtualization-Based Security) via des attaques par "downgrade" (CVE-2024-21302) ;

Instabilité critique du contrôleur de domaine pouvant entraîner son indisponibilité ;

Exécution de code malveillant via des données ou pages web piégées (failles .NET Framework).

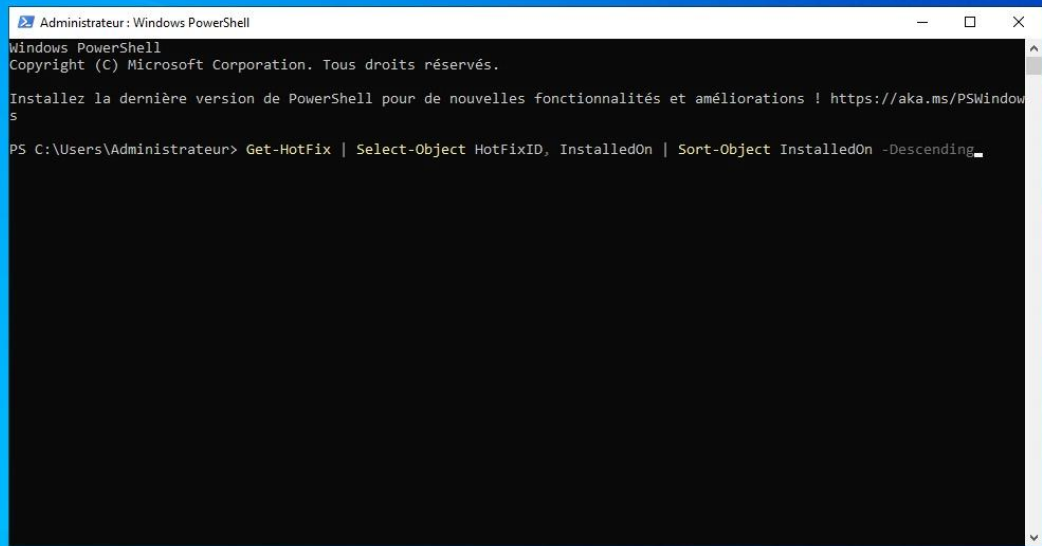
Cette absence de "patching" constitue une vulnérabilité système critique, car un attaquant positionné sur le réseau pourrait exploiter ces failles pour prendre le contrôle du serveur, compromettre l'ensemble du domaine Active Directory, et se propager latéralement à toutes les machines de l'infrastructure.

Preuve d'exploitabilité :

Depuis serveur AD-1 (Powershell Administrateur) :

Tapez cette commande :

Get-HotFix | Select-Object HotFixID, InstalledOn | Sort-Object InstalledOn -Descending

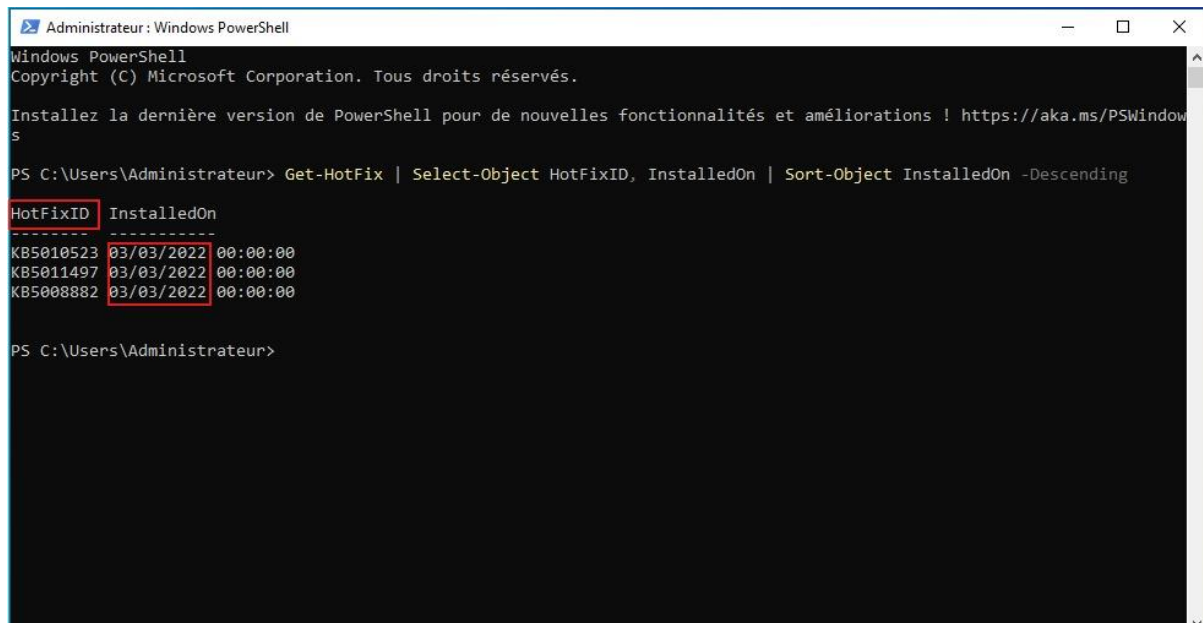


```
Administrateur : Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. Tous droits réservés.

Installez la dernière version de PowerShell pour de nouvelles fonctionnalités et améliorations ! https://aka.ms/PSWindows
s

PS C:\Users\Administrateur> Get-HotFix | Select-Object HotFixID, InstalledOn | Sort-Object InstalledOn -Descending
```

La commande **Get-HotFix** exécutée sur SRV-AD-1 révèle que les dernières mises à jour installées datent de mars 2022. Les correctifs critiques publiés depuis, notamment la mise à jour cumulative KB5082142 (avril 2026), ne sont pas présents. Cette absence prolongée de "patching" expose le serveur à l'ensemble des vulnérabilités corrigées par Microsoft au cours des quatre dernières années, dont les failles majeures CVE-2024-38063 (RCE sur pile TCP/IP) et CVE-2024-21302 (contournement VBS).



```
Administrateur : Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. Tous droits réservés.

Installez la dernière version de PowerShell pour de nouvelles fonctionnalités et améliorations ! https://aka.ms/PSWindows
PS C:\Users\Administrateur> Get-HotFix | Select-Object HotFixID, InstalledOn | Sort-Object InstalledOn -Descending

HotFixID InstalledOn
-----
KB5010523 03/03/2022 00:00:00
KB5011497 03/03/2022 00:00:00
KB5008882 03/03/2022 00:00:00

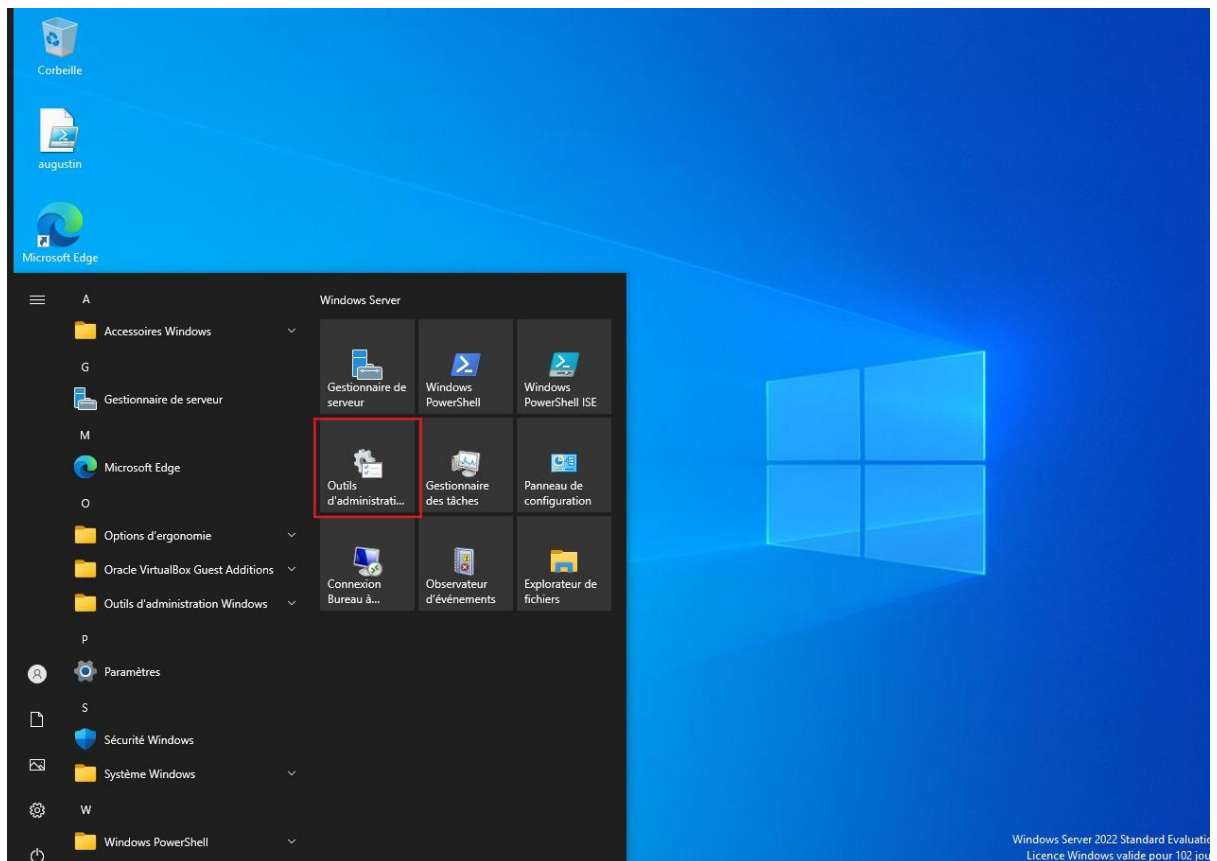
PS C:\Users\Administrateur>
```

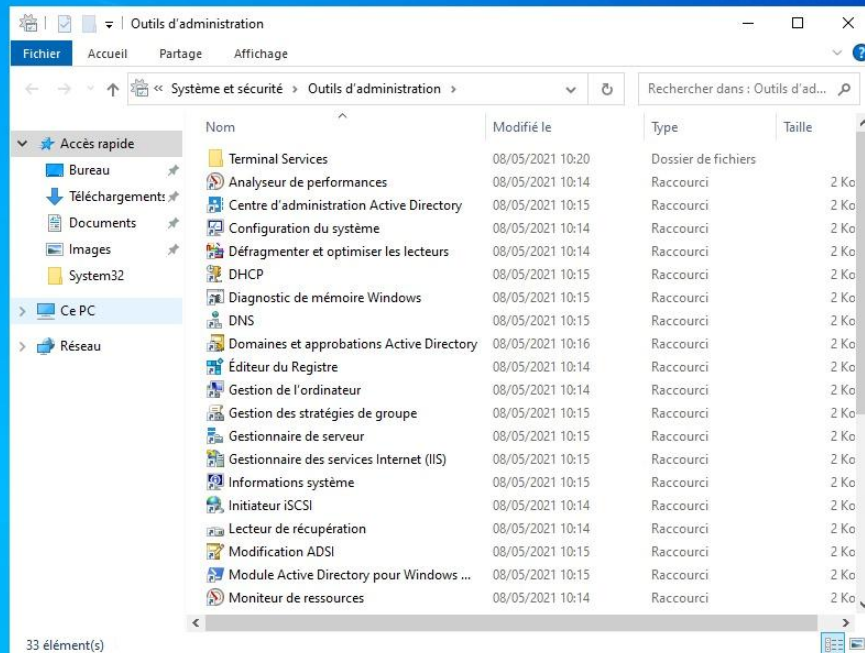
VULNÉRABILITÉ 5 - Compte administrateur Active Directory faible

Étape 1 — Ouvrir les outils d'administration AD

Sur SRV-AD-1:

Menu Démarrer - Windows Administrative Tools - Active Directory Users and Computers



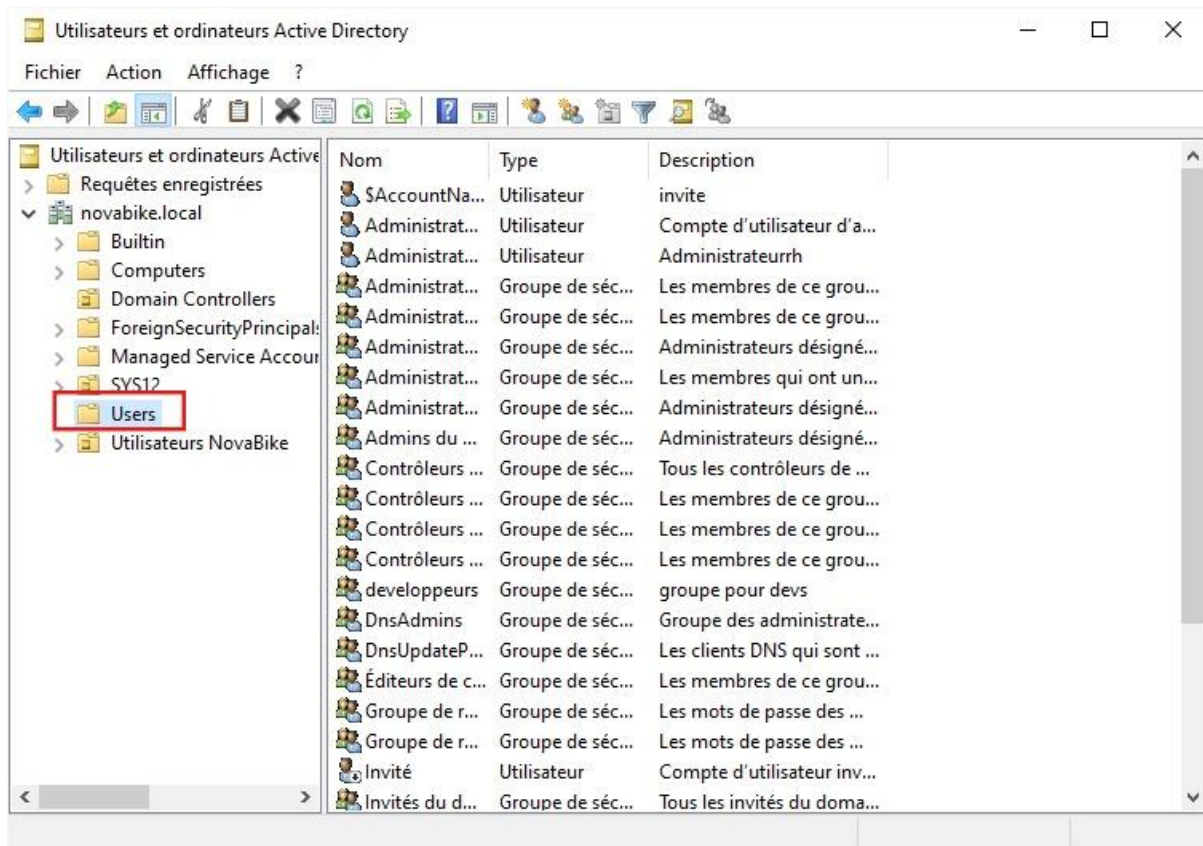


\Cherchez et cliquez sur Utilisateurs et ordinateurs Active Directory

Windows Explorer window showing the 'Outils d'administration' (Administrative Tools) folder. The left sidebar shows the 'Accès rapide' (QuickTime) section with 'Bureau', 'Téléchargements', 'Documents', 'Images', 'System32', 'Ce PC', and 'Réseau'. The main pane displays a list of administrative tools, including 'Terminal Services', 'Analyseur de performances', 'Centre d'administration Active Directory', 'Configuration du système', 'Défragmenter et optimiser les lecteurs', 'DHCP', 'Diagnostic de mémoire Windows', 'DNS', 'Domaines et approbations Active Directory', 'Éditeur du Registre', 'Gestion de l'ordinateur', 'Gestion des stratégies de groupe', 'Gestionnaire de serveur', 'Gestionnaire des services Internet (IIS)', 'Informations système', 'Initiateur iSCSI', 'Lecteur de récupération', 'Modification ADSI', 'Module Active Directory pour Windows ...', 'Moniteur de ressources', 'Nettoyage de disque', 'Observateur d'événements', 'ODBC Data Sources (32-bit)', 'Pare-feu Windows Defender avec fonction...', 'Planificateur de tâches', 'Sauvegarde Windows Server', 'Services de composants', 'Services Microsoft Azure', 'Services', 'Sites et services Active Directory', 'Sources de données ODBC (64 bits)', 'Stratégie de sécurité locale', and 'Utilisateurs et ordinateurs Active Directory'. The 'Utilisateurs et ordinateurs Active Directory' item is highlighted with a red box. The bottom status bar indicates '33 élément(s)'.

Nom	Modifié le	Type	Taille
Terminal Services	08/05/2021 10:20	Dossier de fichiers	
Analyseur de performances	08/05/2021 10:14	Raccourci	2 Ko
Centre d'administration Active Directory	08/05/2021 10:15	Raccourci	2 Ko
Configuration du système	08/05/2021 10:14	Raccourci	2 Ko
Défragmenter et optimiser les lecteurs	08/05/2021 10:14	Raccourci	2 Ko
DHCP	08/05/2021 10:15	Raccourci	2 Ko
Diagnostic de mémoire Windows	08/05/2021 10:15	Raccourci	2 Ko
DNS	08/05/2021 10:15	Raccourci	2 Ko
Domaines et approbations Active Directory	08/05/2021 10:16	Raccourci	2 Ko
Éditeur du Registre	08/05/2021 10:14	Raccourci	2 Ko
Gestion de l'ordinateur	08/05/2021 10:14	Raccourci	2 Ko
Gestion des stratégies de groupe	08/05/2021 10:15	Raccourci	2 Ko
Gestionnaire de serveur	08/05/2021 10:15	Raccourci	2 Ko
Gestionnaire des services Internet (IIS)	08/05/2021 10:15	Raccourci	2 Ko
Informations système	08/05/2021 10:15	Raccourci	2 Ko
Initiateur iSCSI	08/05/2021 10:14	Raccourci	2 Ko
Lecteur de récupération	08/05/2021 10:14	Raccourci	2 Ko
Modification ADSI	08/05/2021 10:15	Raccourci	2 Ko
Module Active Directory pour Windows ...	08/05/2021 10:15	Raccourci	2 Ko
Moniteur de ressources	08/05/2021 10:14	Raccourci	2 Ko
Nettoyage de disque	08/05/2021 10:14	Raccourci	2 Ko
Observateur d'événements	08/05/2021 10:14	Raccourci	2 Ko
ODBC Data Sources (32-bit)	08/05/2021 10:13	Raccourci	2 Ko
Pare-feu Windows Defender avec fonction...	08/05/2021 10:14	Raccourci	2 Ko
Planificateur de tâches	08/05/2021 10:14	Raccourci	2 Ko
Sauvegarde Windows Server	08/05/2021 10:16	Raccourci	2 Ko
Services de composants	08/05/2021 10:14	Raccourci	2 Ko
Services Microsoft Azure	08/05/2021 10:15	Raccourci	2 Ko
Services	08/05/2021 10:14	Raccourci	2 Ko
Sites et services Active Directory	08/05/2021 10:15	Raccourci	2 Ko
Sources de données ODBC (64 bits)	08/05/2021 10:14	Raccourci	2 Ko
Stratégie de sécurité locale	08/05/2021 10:15	Raccourci	2 Ko
Utilisateurs et ordinateurs Active Directory	08/05/2021 10:16	Raccourci	2 Ko

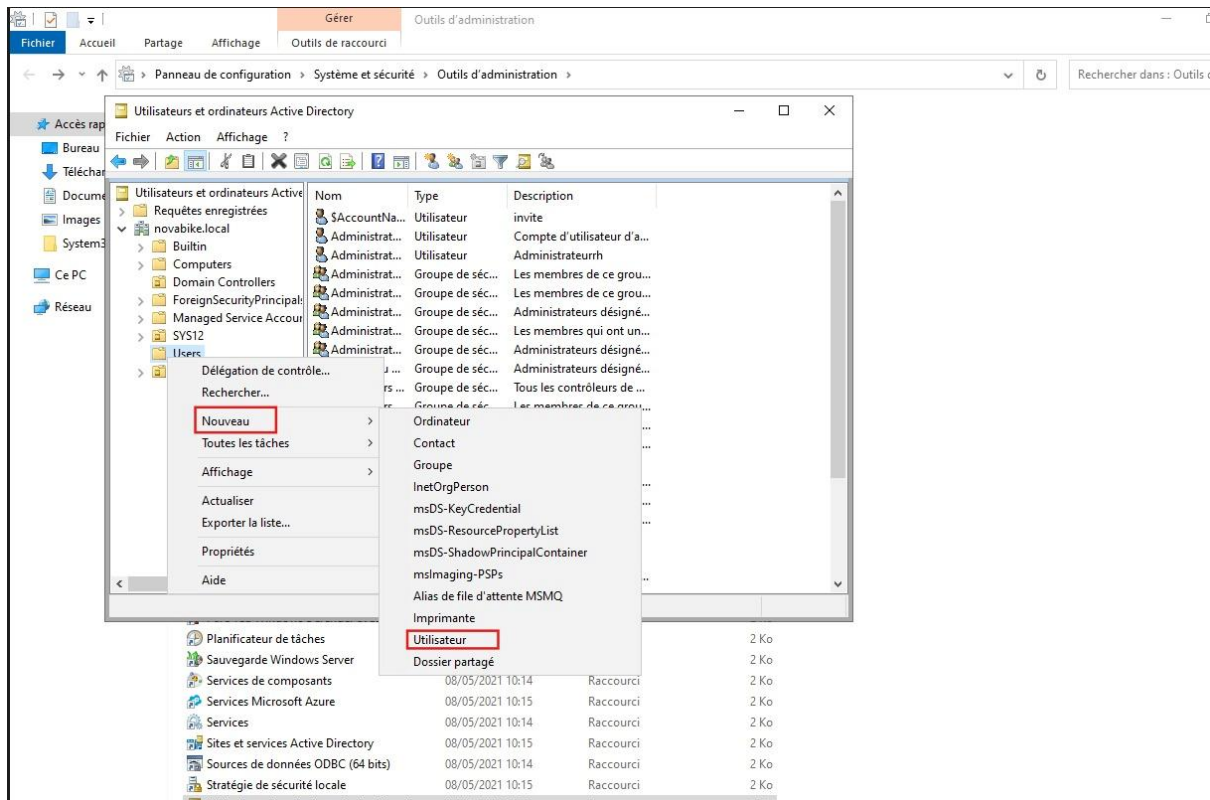
Dans l'arborescence de gauche, cliquez sur le dossier Users :



Étape 2 - Créer un nouvel utilisateur

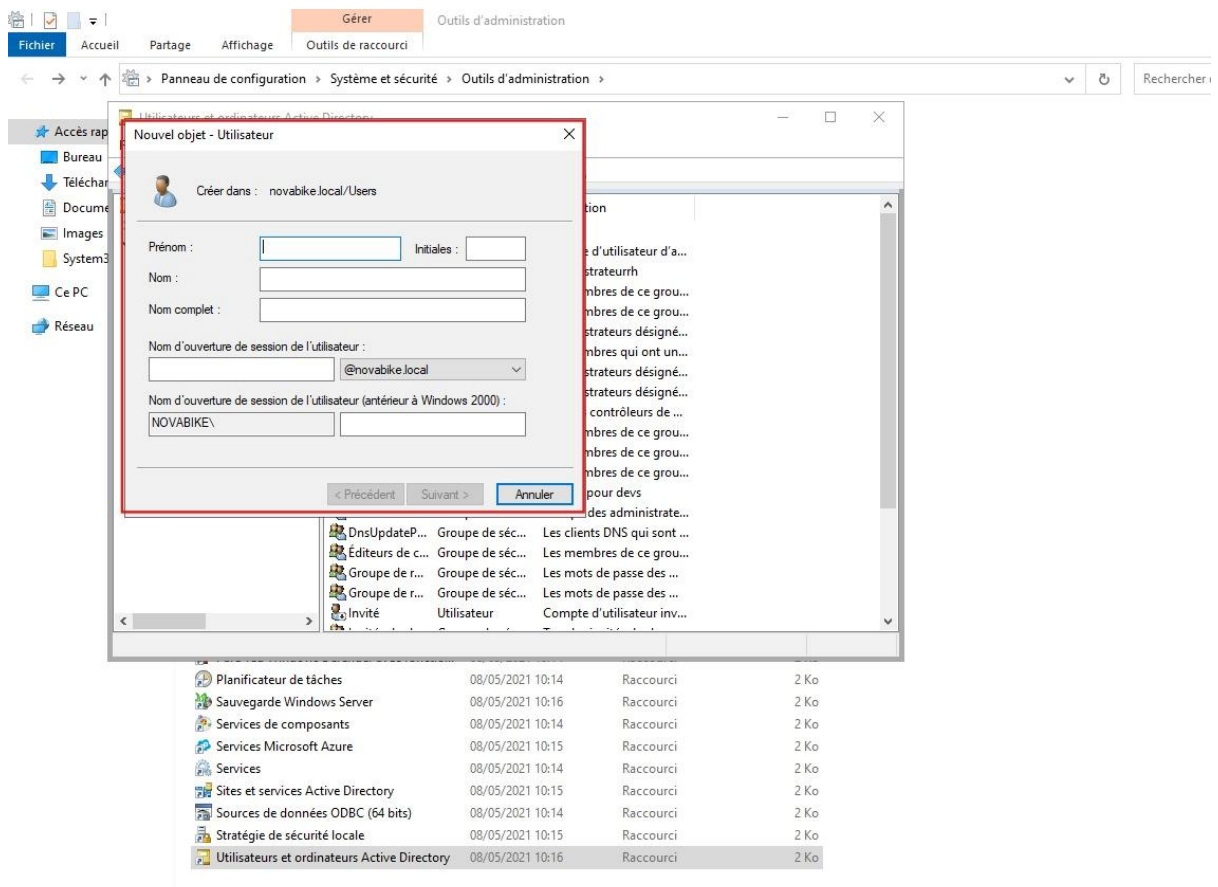
Clic droit sur le dossier Users (dans la liste de gauche, pas dans la liste des utilisateurs)

New - User

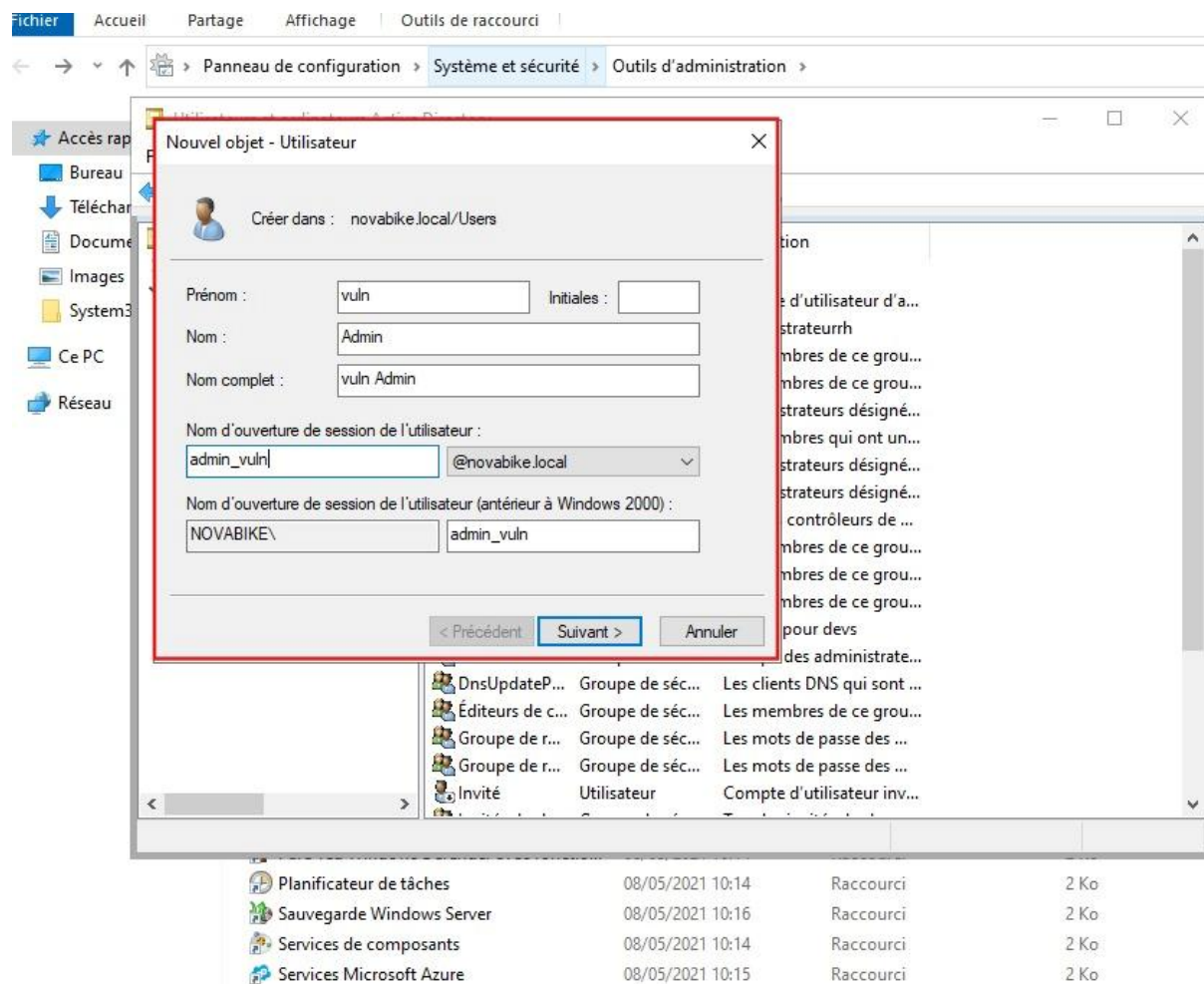


Étape 3 - Remplir les informations

Champ	Valeur
Prénom	Vuln
Nom	Admin
Nom d'ouverture de session	admin_vuln



Cliquez sur suivant :



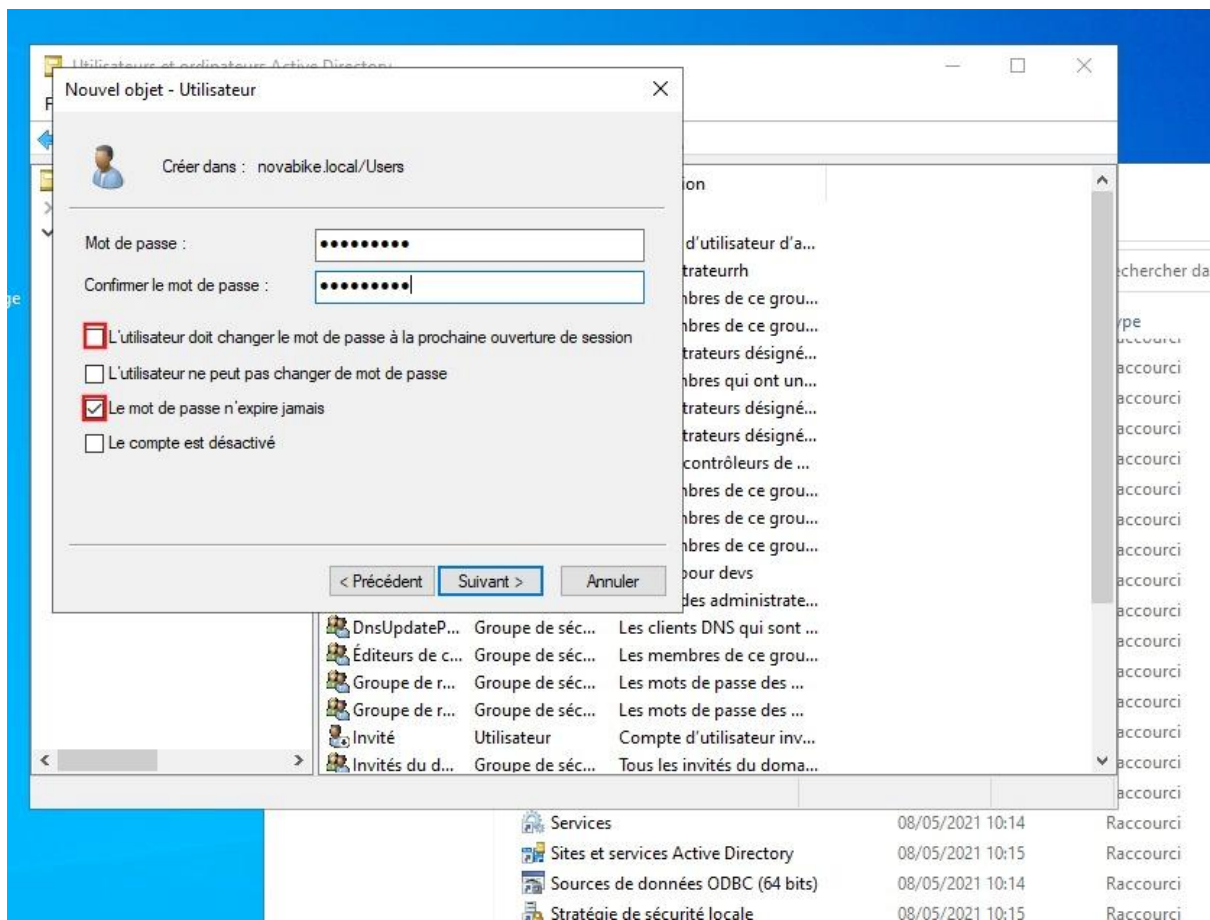
Étape 4 — Définir le mot de passe

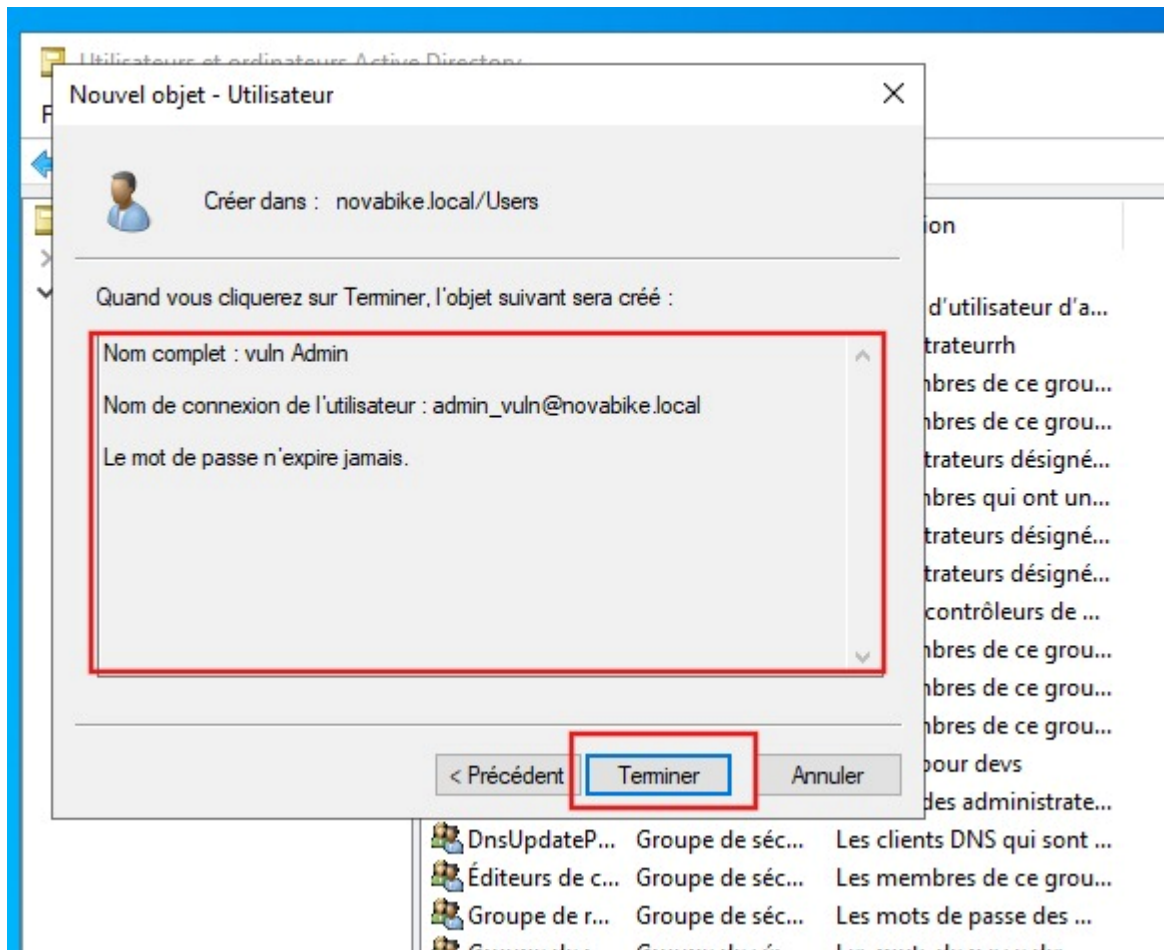
champ	Valeur
Mot de passe	admin1234
Confirmer le mot de passe	admin1234

Décochez : "L'utilisateur doit changer le mot de passe à la prochaine ouverture de session "

Cochez : "Le mot de passe n'expire jamais"

Clique sur Next – Finish



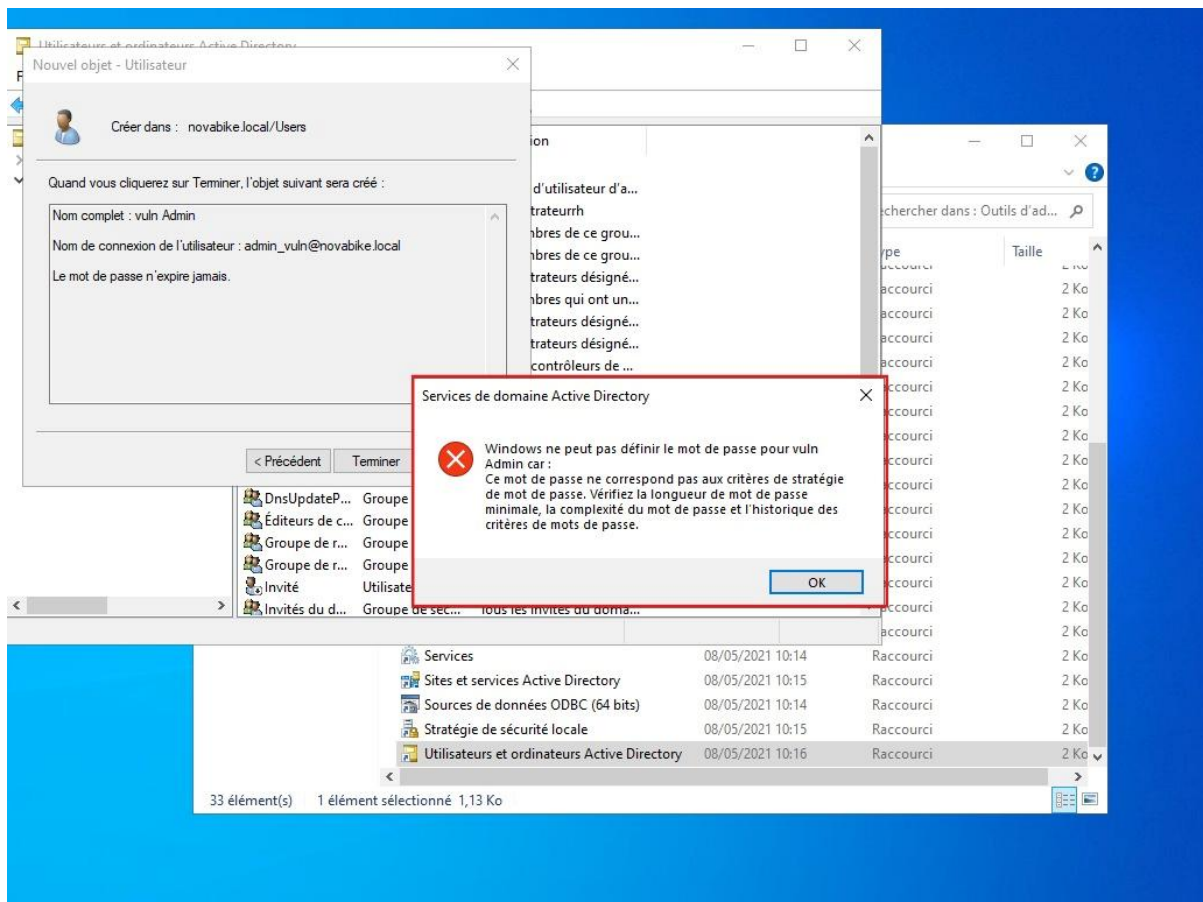


Le mot de passe Admin1234 est trop court et contient le mot Admin. Ainsi il ne respecte pas la politique de complexité donc au lieu de rendre le mot de passe complexe et faible, nous allons en faire une vraie vulnérabilité en désactivant la politique de complexité afin que ce simple mot de passe ne respectant pas les exigences soit enregistré dans le système permettant ainsi à un attaquant de le déceler facilement par ingénierie sociale ou force brute.

Donc, on désactive la politique de complexité.

Étape 1 - Ouvrir "Gestion des stratégies de groupe"

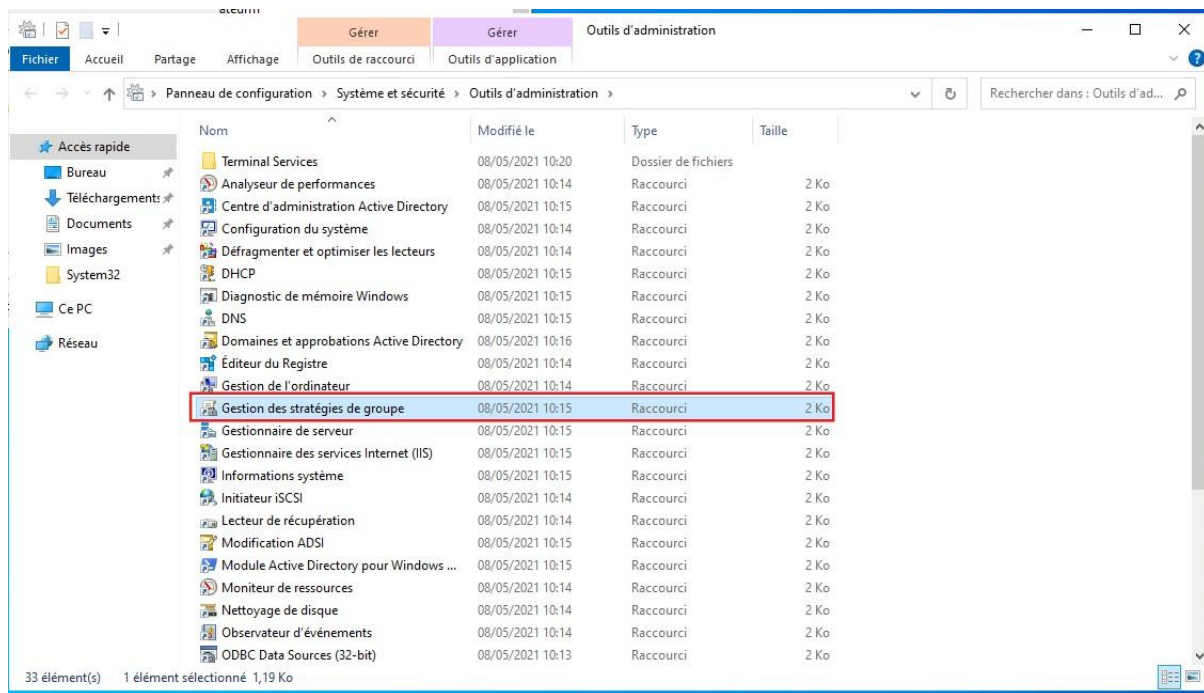
Sur SRV-AD-1, chercher et ouvrir "Group Policy Management" (Gestion des stratégies de groupes).



Donc, on désactive la politique de complexité

Étape 1 - Ouvrir "Gestion des stratégies de groupe"

Sur SRV-AD-1, chercher et ouvrir "Group Policy Management" (Gestion des stratégies de groupes).



Ouvrir Gestionnaire de Serveur :

Gestionnaire de serveur

Tableau de bord

Gérer Outils Afficher Aide

Tableau de bord

- Serveur local
- Tous les serveurs
- AD DS
- DHCP
- DNS
- IIS
- Services de fichiers et d... >

Rôles et groupes de serveurs

Rôles : 5 | Groupes de serveurs : 1 | Nombre total de serveurs : 1

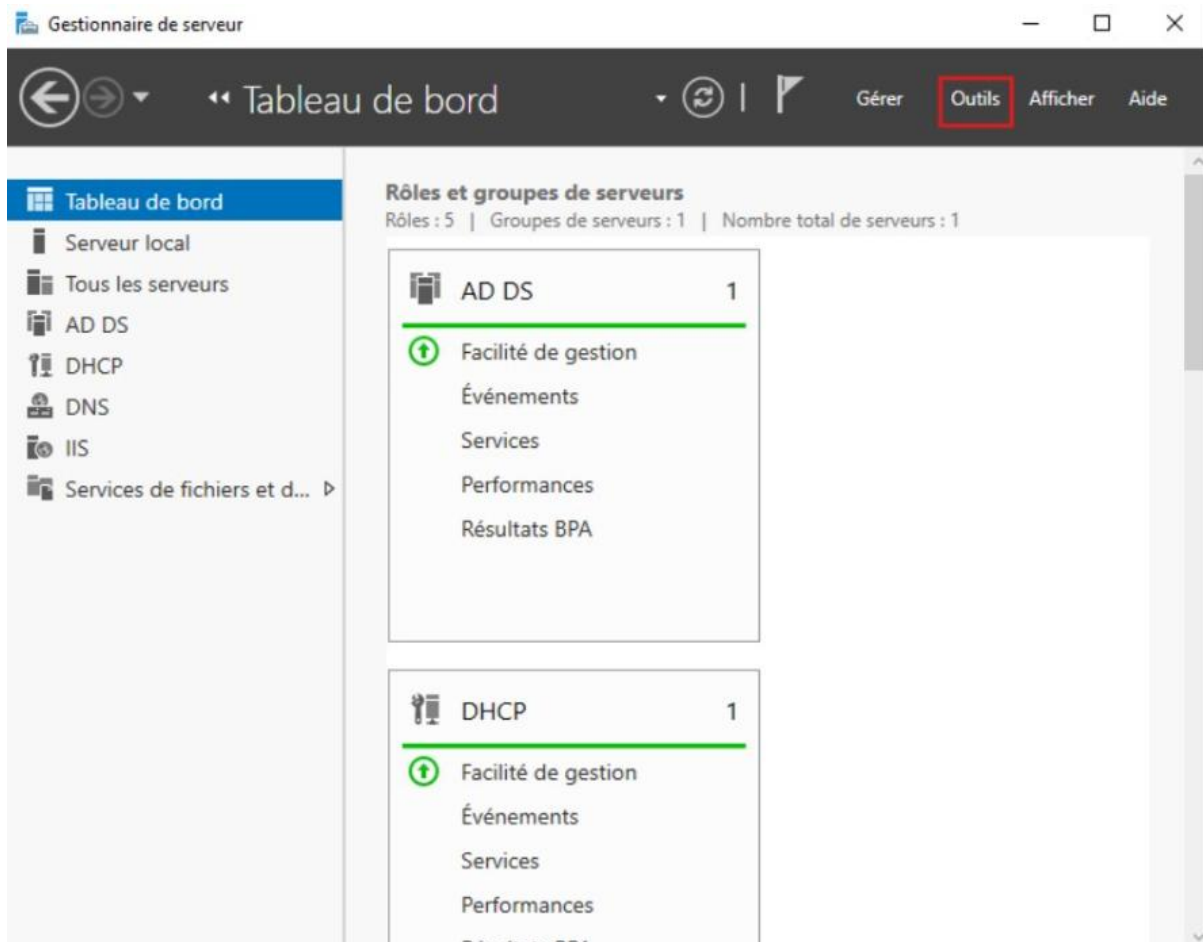
AD DS 1

- Facilité de gestion
- Événements
- Services
- Performances
- Résultats BPA

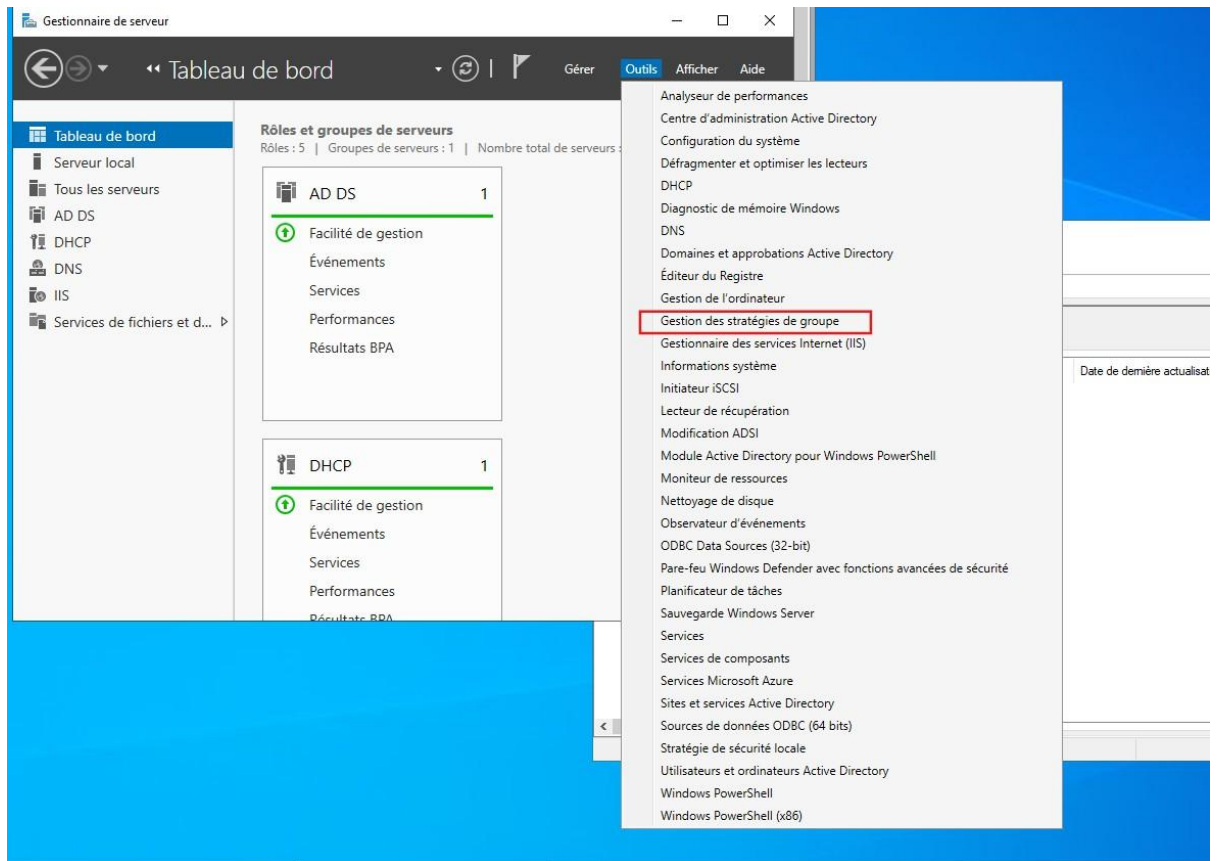
DHCP 1

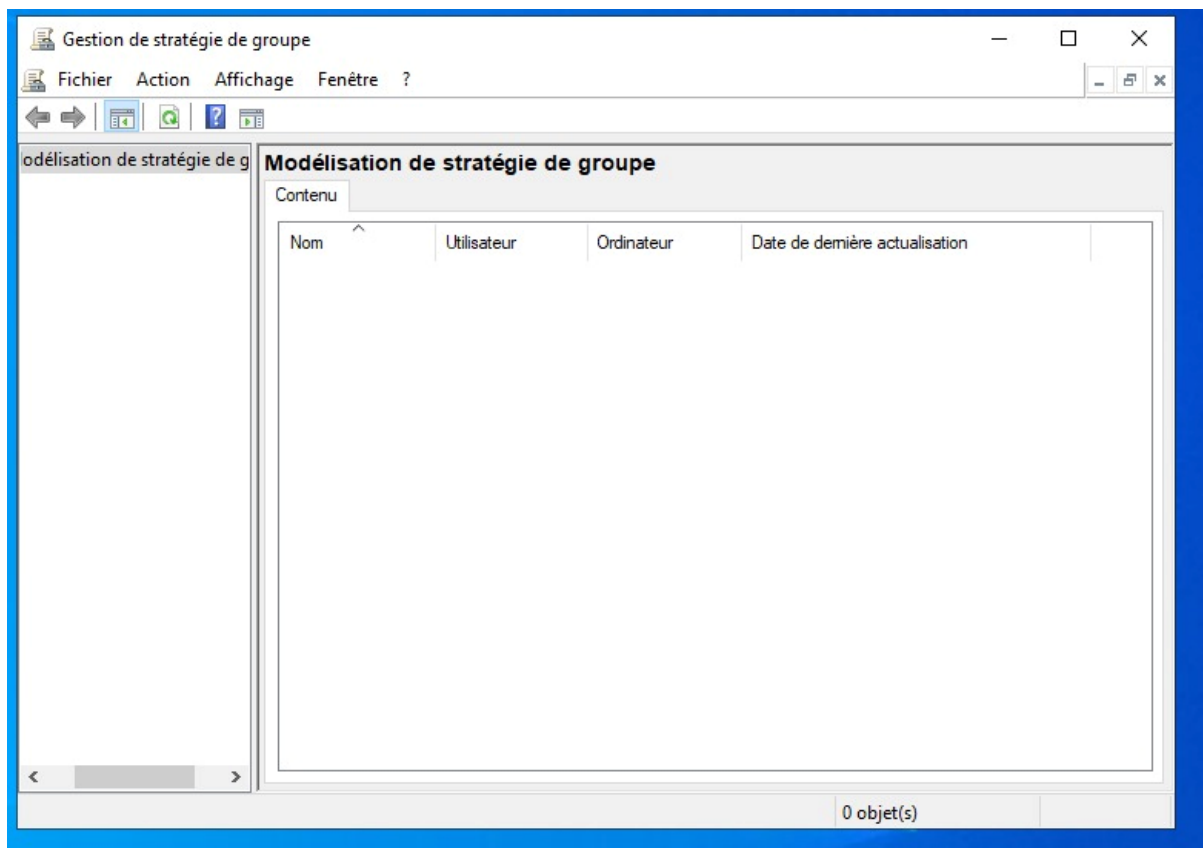
- Facilité de gestion
- Événements
- Services
- Performances
- Résultats BPA

Cliquez sur Outils :



Sélectionnez gestion des stratégies de groupe :

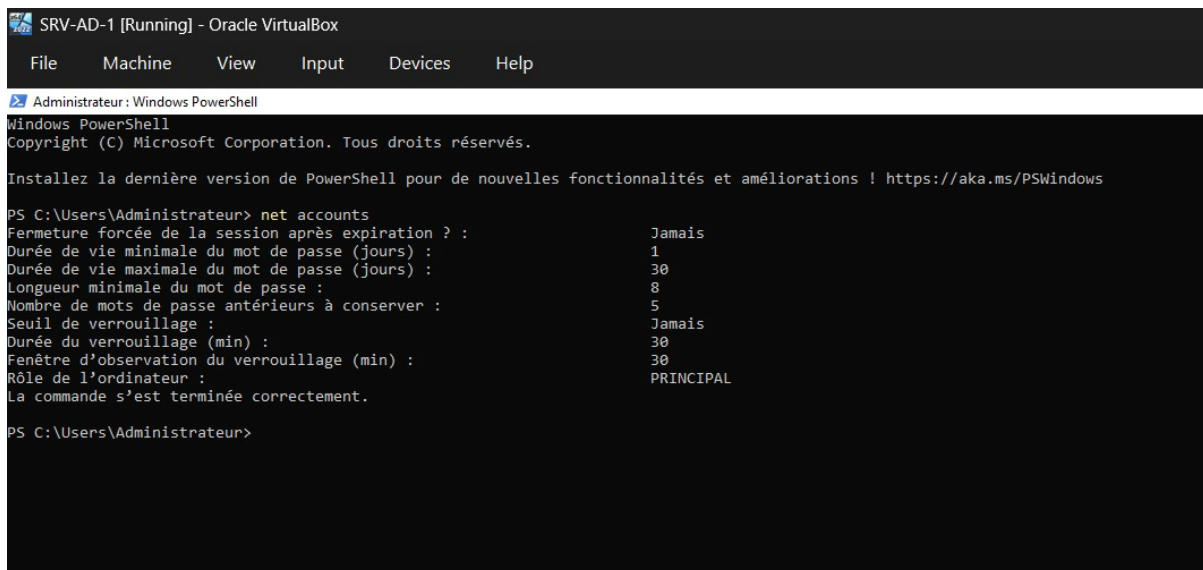
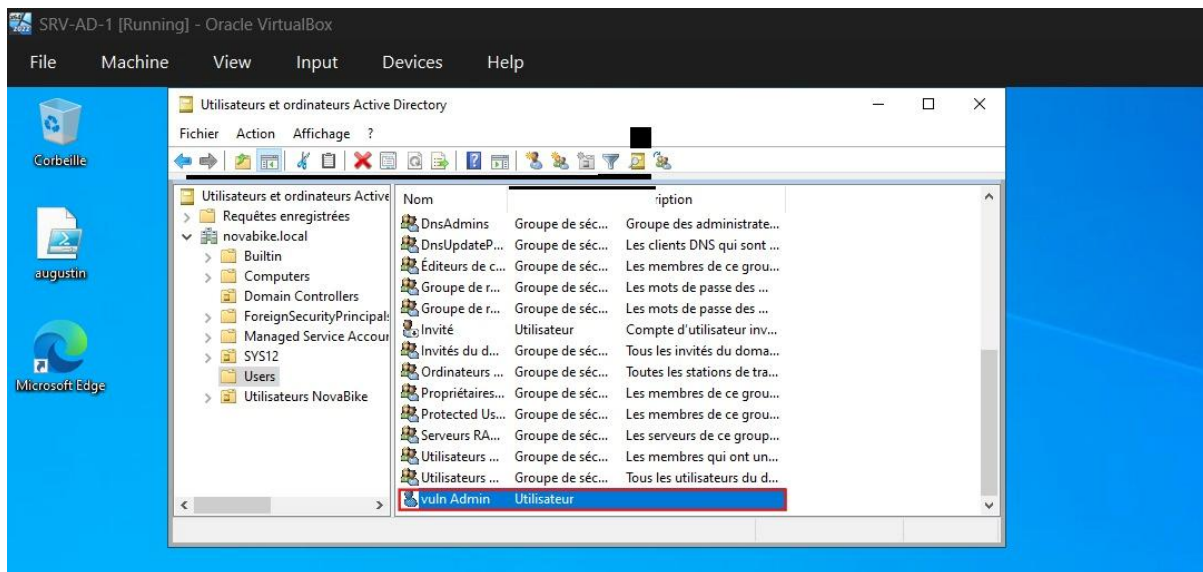




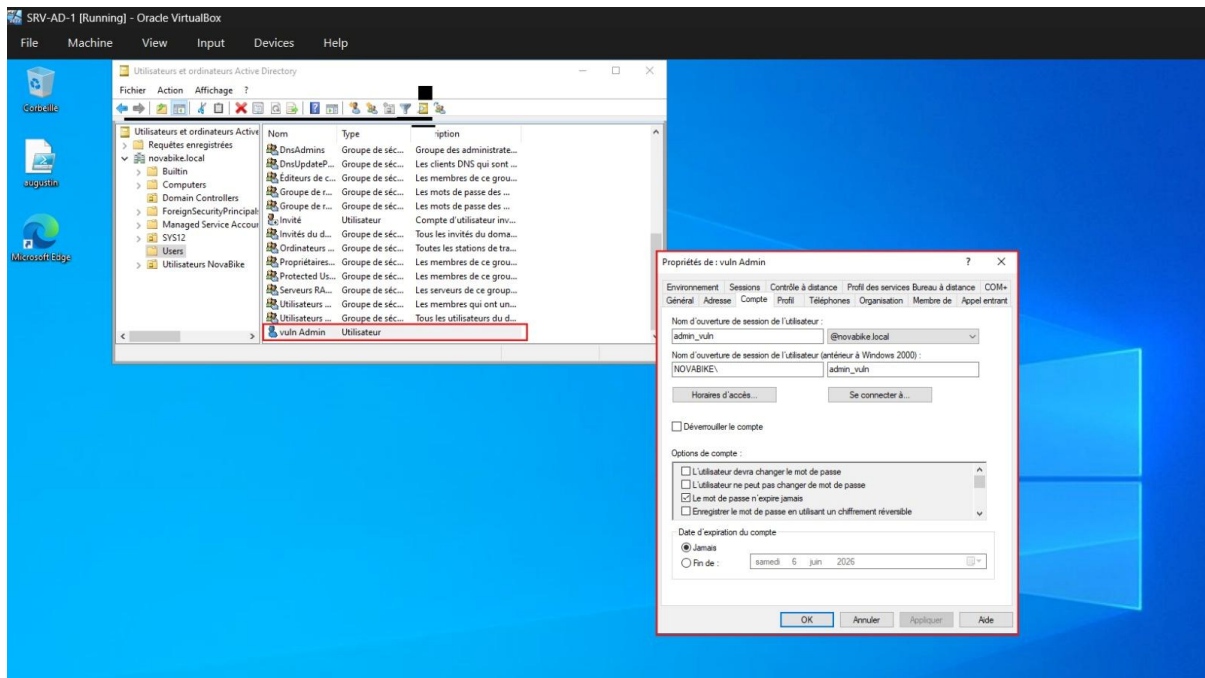
L'absence de stratégie de groupe définie au niveau du domaine ne correspond pas à une configuration de sécurité standard. Cette situation est volontaire dans le cadre de notre projet OFF12 : elle nous a permis d'implémenter et de démontrer plus facilement les vulnérabilités liées aux mots de passe faibles. Dans un environnement professionnel réel, une politique de mot de passe (complexité, longueur, verrouillage) serait impérativement définie via une GPO. Notre démarche pédagogique consiste à montrer d'abord l'état vulnérable (absence de politique), puis à le corriger dans la phase de remédiation en appliquant les bonnes pratiques.

Nous venons de voir l'étape de la politique de confidentialité.

Revenons maintenant sur la création du compte utilisateur.



La politique de complexité du domaine est respectée.



Un compte administrateur nommé admin_vuln a été créé dans l'Active Directory avec le mot de passe Passer@2026. Tant bien même qu'il respecte la politique de complexité (longueur minimale de 8 caractères, présence de majuscule, minuscule, chiffre et caractère spécial), ce mot de passe reste faible car il est trop court, prévisible et facilement devinable. Le compte a été ajouté au groupe Domain Admins et son mot de passe n'expire jamais, exposant ainsi l'ensemble du domaine à une compromission par force brute ou ingénierie sociale.

L'implémentation des cinq vulnérabilités planifiées est désormais terminée :

- 1- Règle any-to-any sur pfSense (réseau);
- 2- Injection SQL (SQLi) sur SRV-WEB (applicative) ;
- 3- Cross-Site Scripting (XSS) sur SRV-WEB (applicative);
- 4- Absence de mises à jour sur SRV-AD-1 (système) ;
- 5- Compte administrateur faible admin_vuln dans l'Active Directory (système).

L'infrastructure est désormais dans un état volontairement vulnérable, prête pour la phase de remédiation.

REMÉDIATION - Correction des vulnérabilités

Ordre de traitement (logique)

Vulnérabilité	Action
Règle any-to-any pfSense	Supprimer la règle + appliquer le principe du moindre privilège
SQL Injection (SQLi)	Remplacer par requête préparée
XSS	Ajouter htmlspecialchars()
Windows non à jour	Installer les mises à jour critiques
Compte AD faible	Désactiver/supprimer admin_vuln + réactiver politique complexité

REMÉDIATION 1 — pfSense (règle any-to-any)

La règle "any-to-any" supprime toute barrière réseau. Un attaquant compromettant une machine peut tout attaquer. On supprime cette règle et on applique le principe du moindre privilège (chaque machine n'accède qu'aux ressources nécessaires).

Étape 1 :

Se connecter à pfSense (<https://192.168.1.1>) depuis pc-client ou Kali (navigateur)

Étape 2:

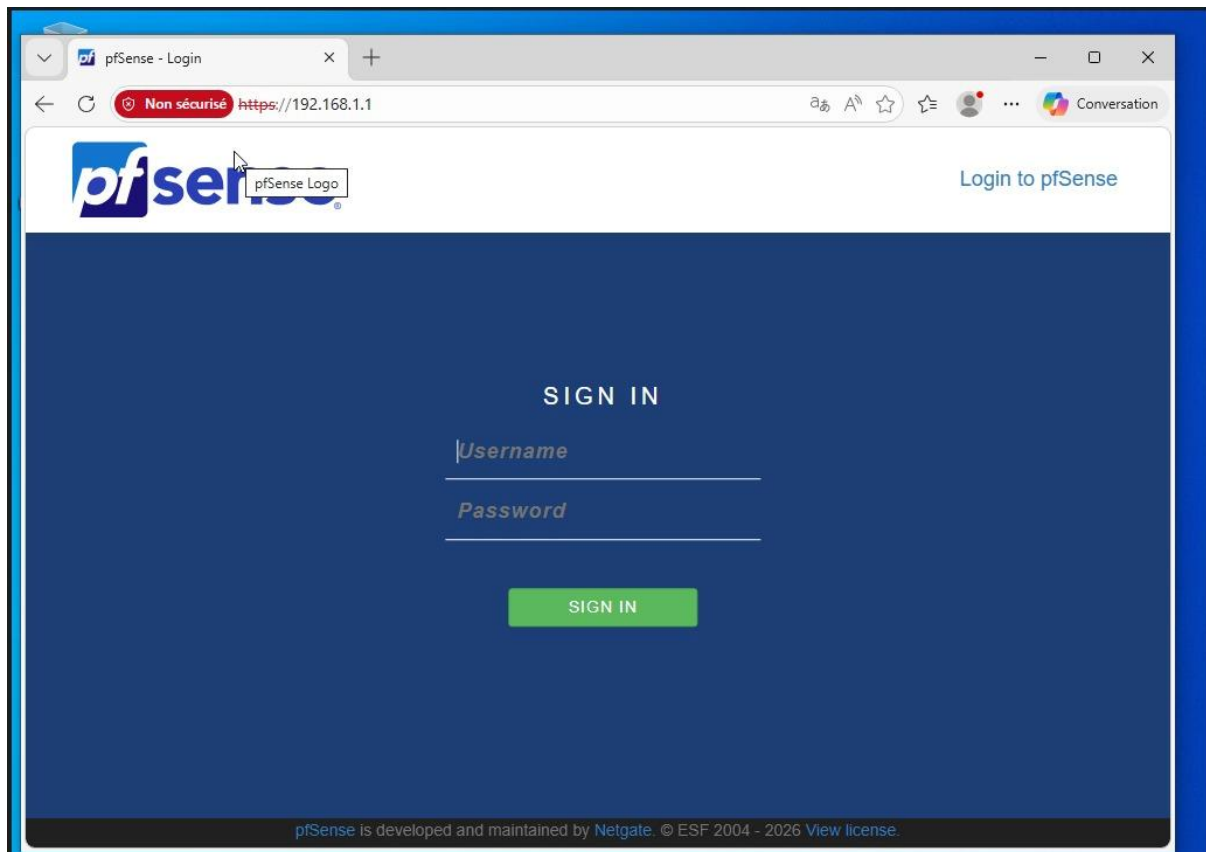
Firewall - Rules - LAN

Étape 3:

Répérer la règle "any-to-any" (Action = Pass, Protocol = Any, Source = Any, Destination = Any)

Cliquer sur l'icône (Delete) à droite de la règle

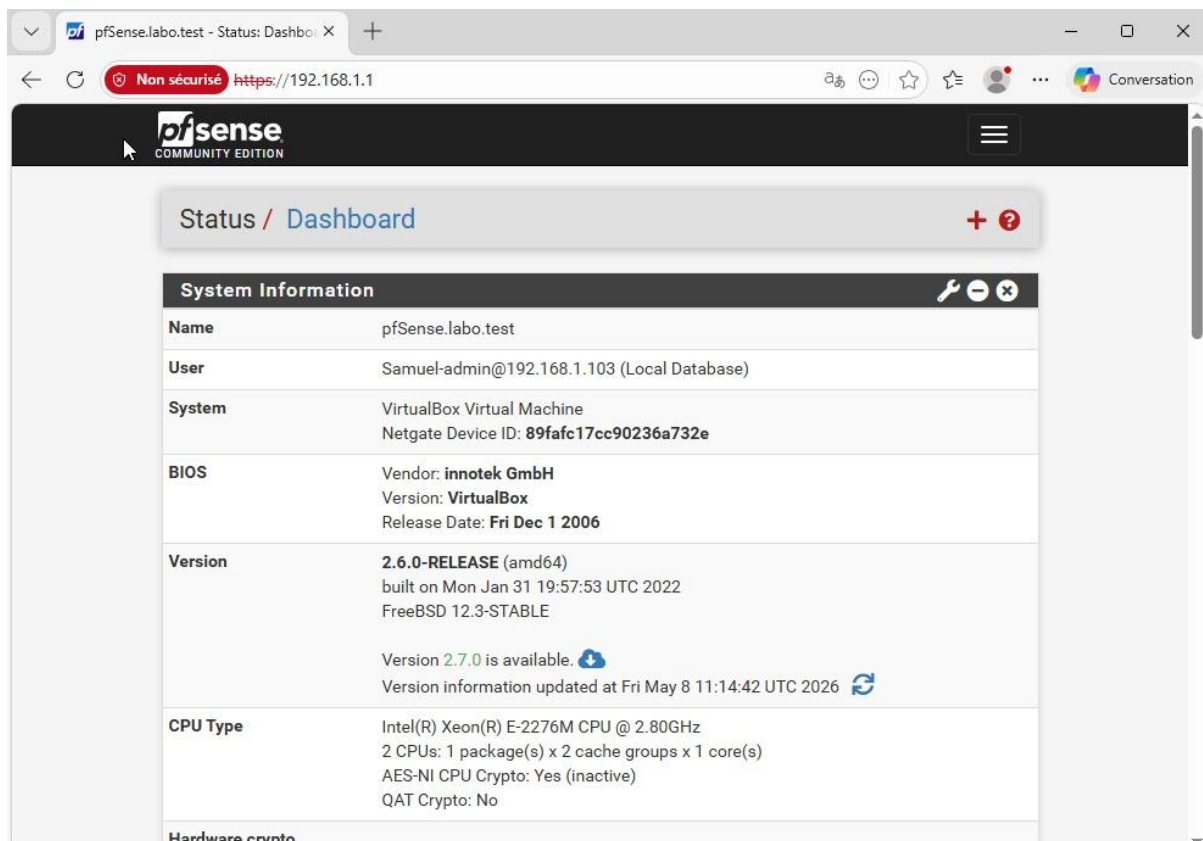
Cliquer sur Apply Changes



S'authentifier :

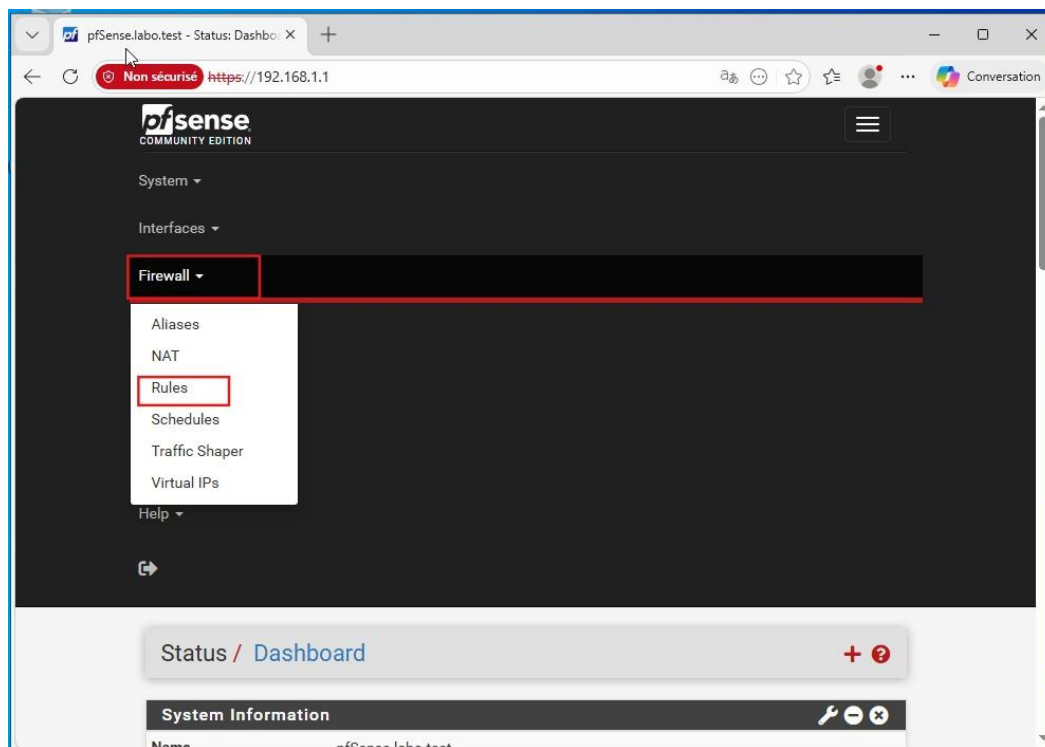
Username : Samuel-admin

Password : Samuel635_@

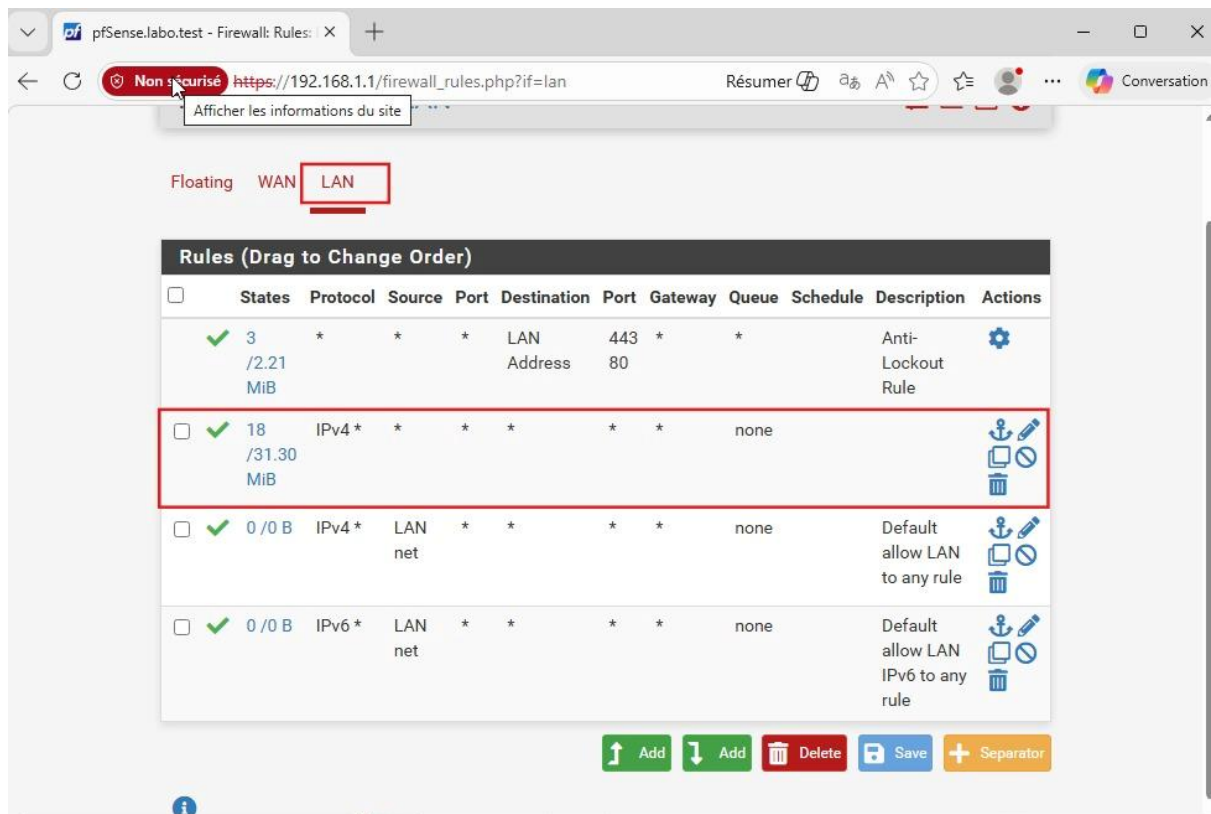


Ensuite, suppression de la règle any-to-any:

Firewall - Rules - LAN

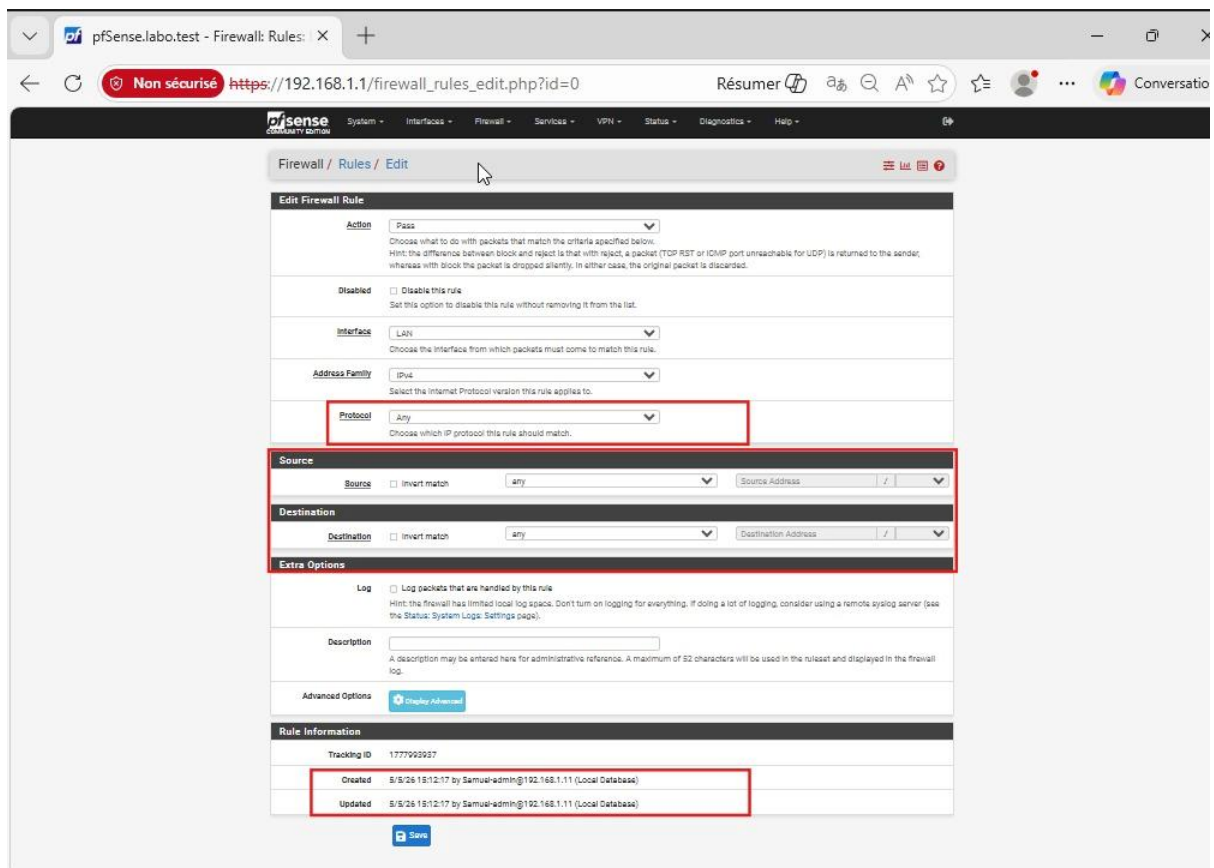


Trouver la règle any-to-any



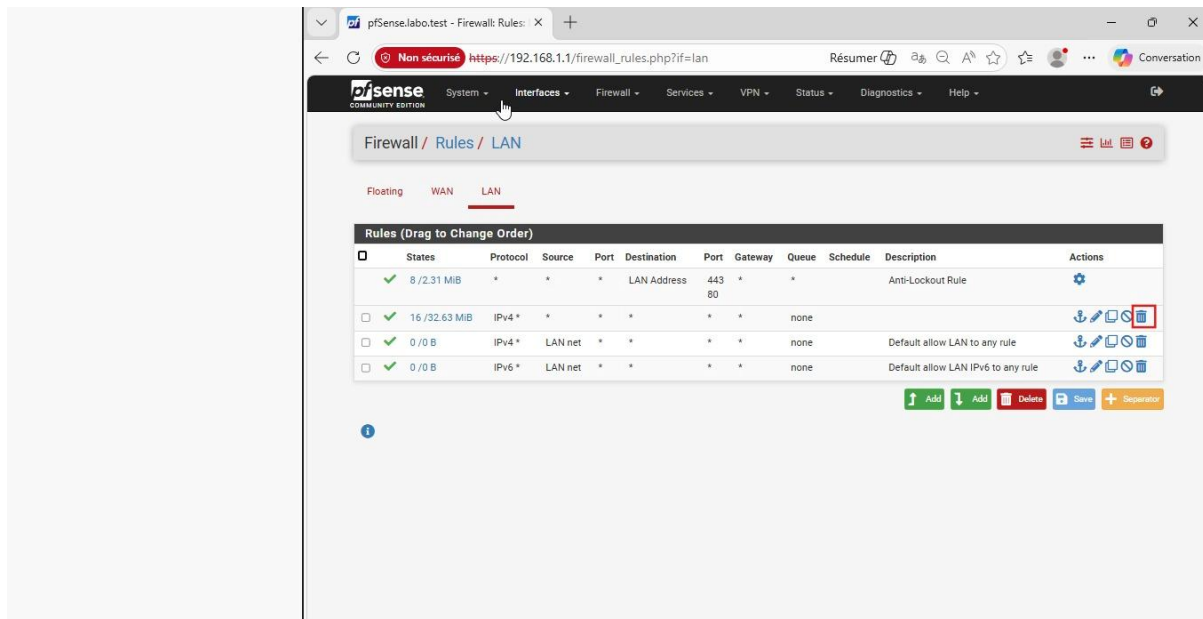
Cliquer sur la règle créer précédemment lors de l'implémentation des vulnérabilités :

Cliquer sur le crayon pour accéder et modifier

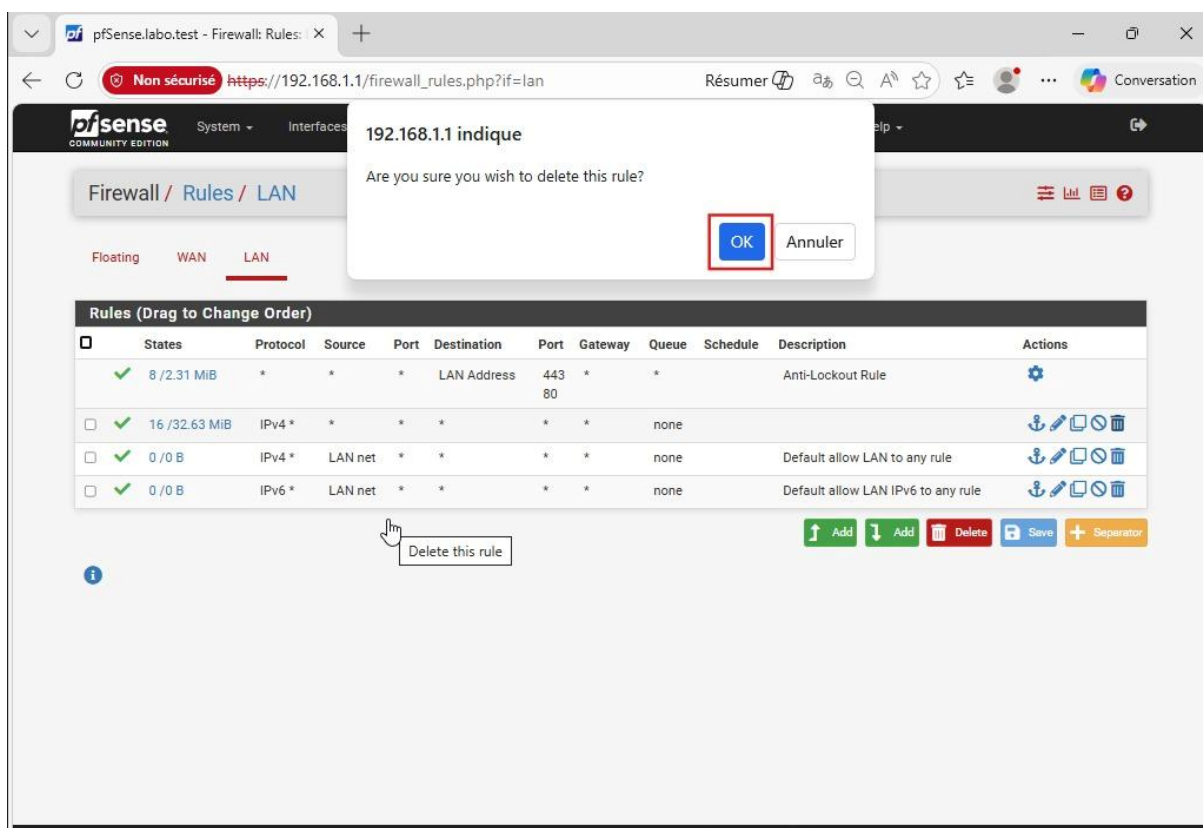


Revenez-en arrière en cliquant sur “Rules”

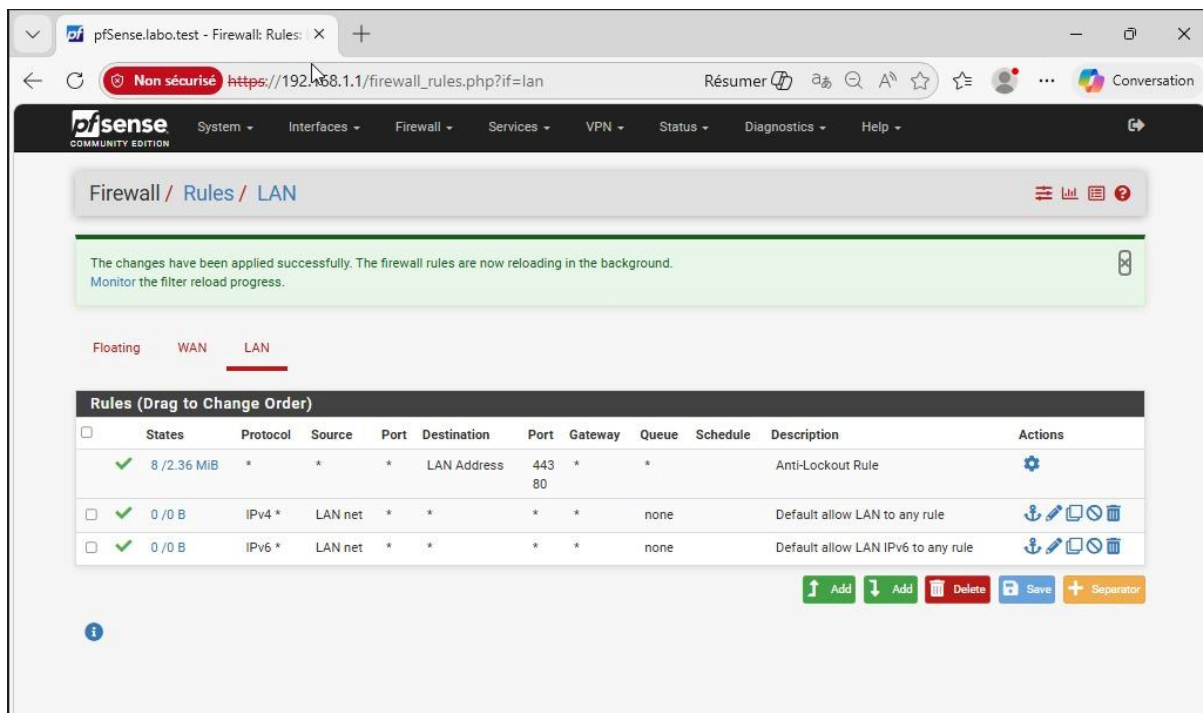
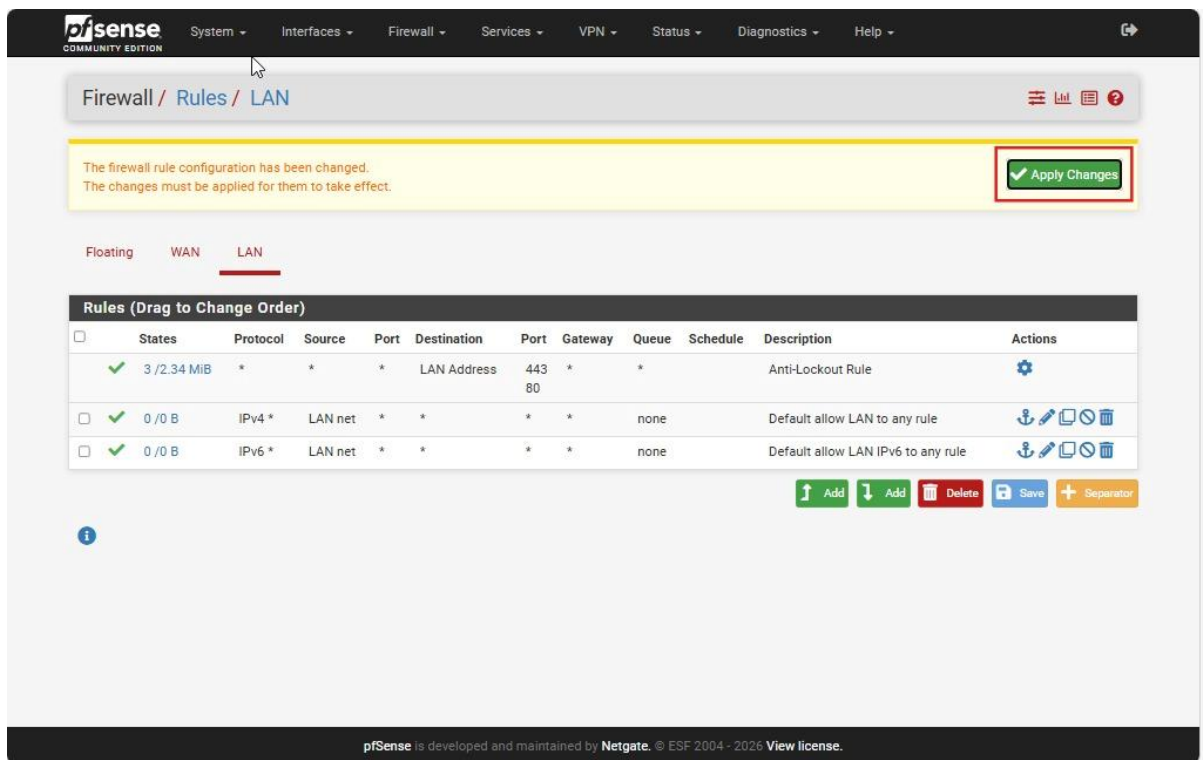
Cliquer sur la poubelle pour supprimer :



Une demande de confirmation va vous être adresser, cliquer sur Ok :



Cliquer sur Apply Changes :

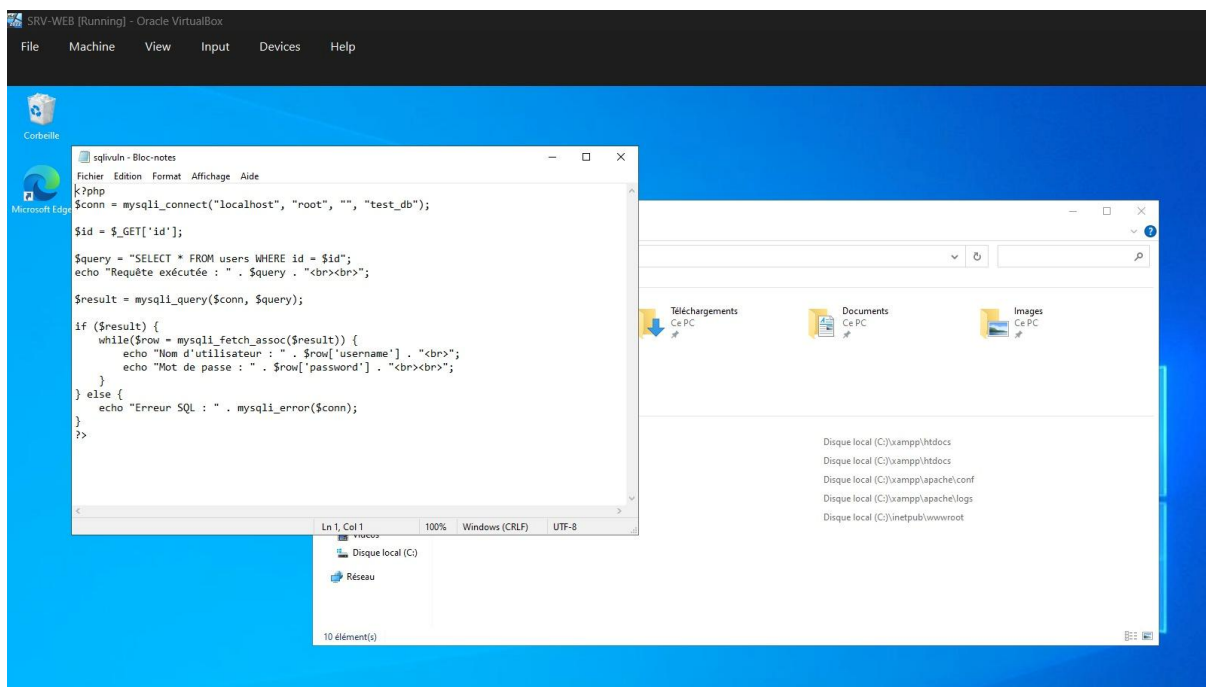


La règle any-to-any a été supprimée de pfSense. Désormais, seules les règles par défaut (Anti-Lockout et LAN to any) sont actives, ce qui restreint les communications aux seuls flux nécessaires.

Remédiation 2 (SQL Injection) :

Étape 1 - Sur SRV-WEB, ouvrez Bloc-notes (Notepad) en Administrateur :

Fichier - Ouvrez C:\xampp\htdocs\sqlivuln.php



Remplacez tout le code par celui-ci :

```
<?php
```

```
$conn = mysqli_connect("localhost", "root", "", "test_db");
```

```
$id = $_GET['id'];
```

```
// Requête préparée (sécurisée)
```

```
$stmt = $conn->prepare("SELECT * FROM users WHERE id = ?");
```

```
$stmt->bind_param("i", $id);  
$stmt->execute();  
$result = $stmt->get_result();  
  
while($row = $result->fetch_assoc()) {  
    echo "Nom d'utilisateur : " . $row['username'] . "<br>";  
    echo "Mot de passe : " . $row['password'] . "<br><br>";  
}  
?>
```

Sauvegarde (Ctrl+S)

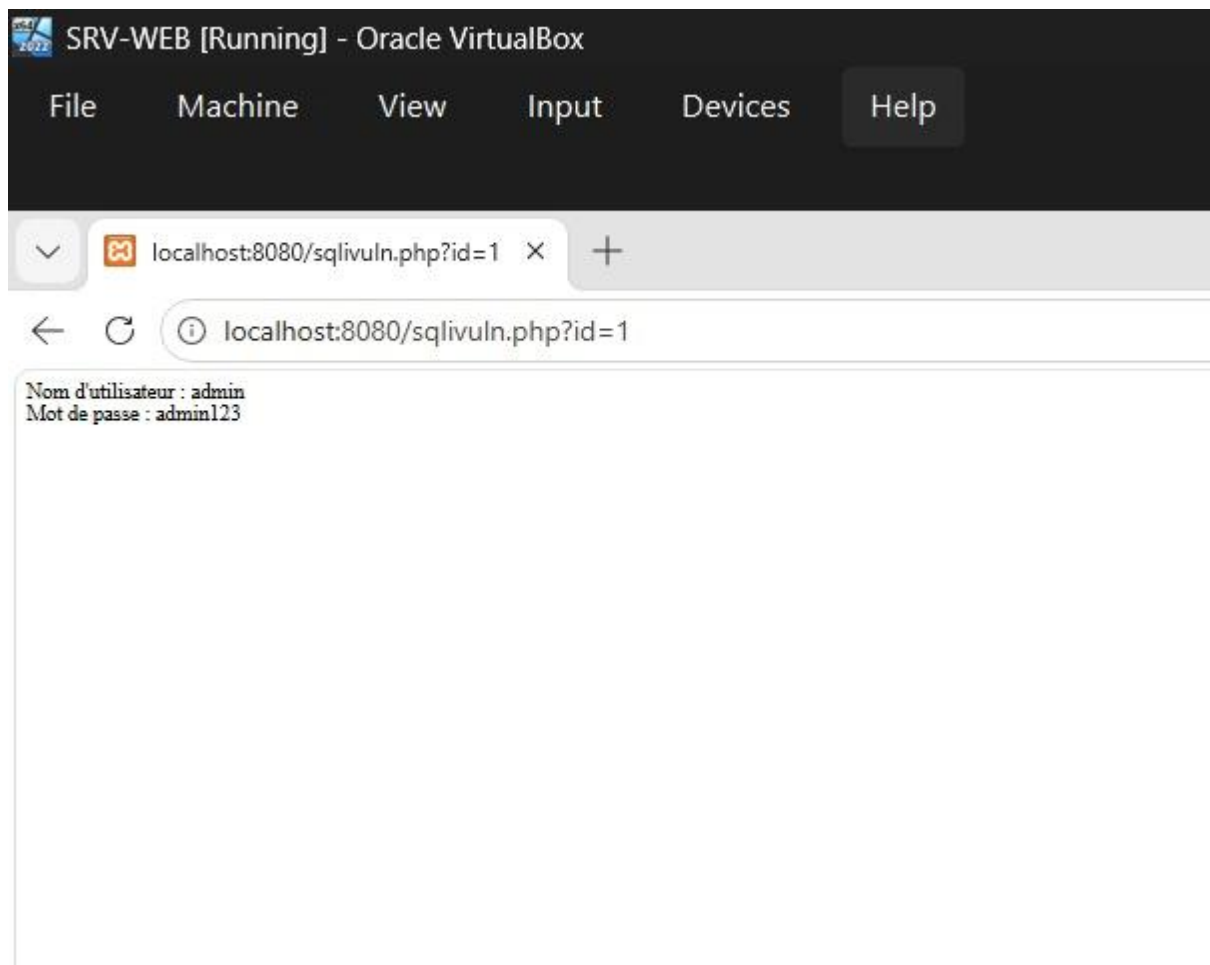
Tester dans le navigateur :

<http://localhost:8080/sqlivuln.php?id=1>

Test de la page corrigée :

Saisissez :

<http://localhost:8080/sqlivuln.php?id=1>

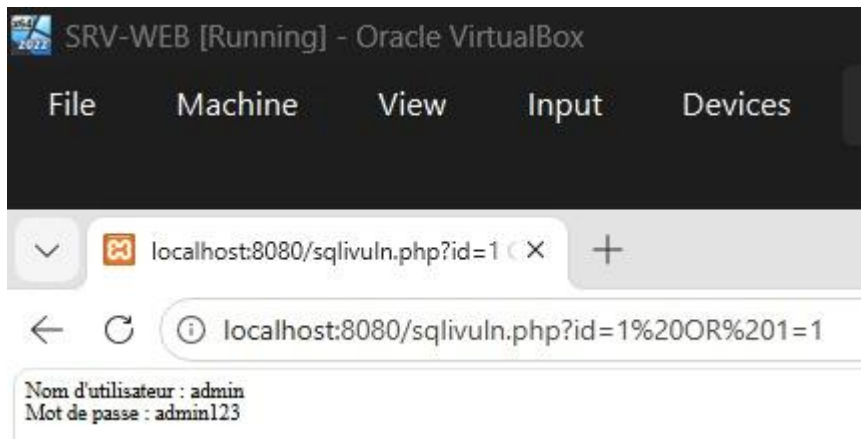


Après correction, la requête avec injection (1' OR '1'=1) ne retourne plus tous les utilisateurs. La requête préparée a bloqué l'attaque.

Test de l'injection pour valider la correction :

Tapez ceci dans le navigateur :

<http://localhost:8080/sqlivuln.php?id=1 OR 1=1>

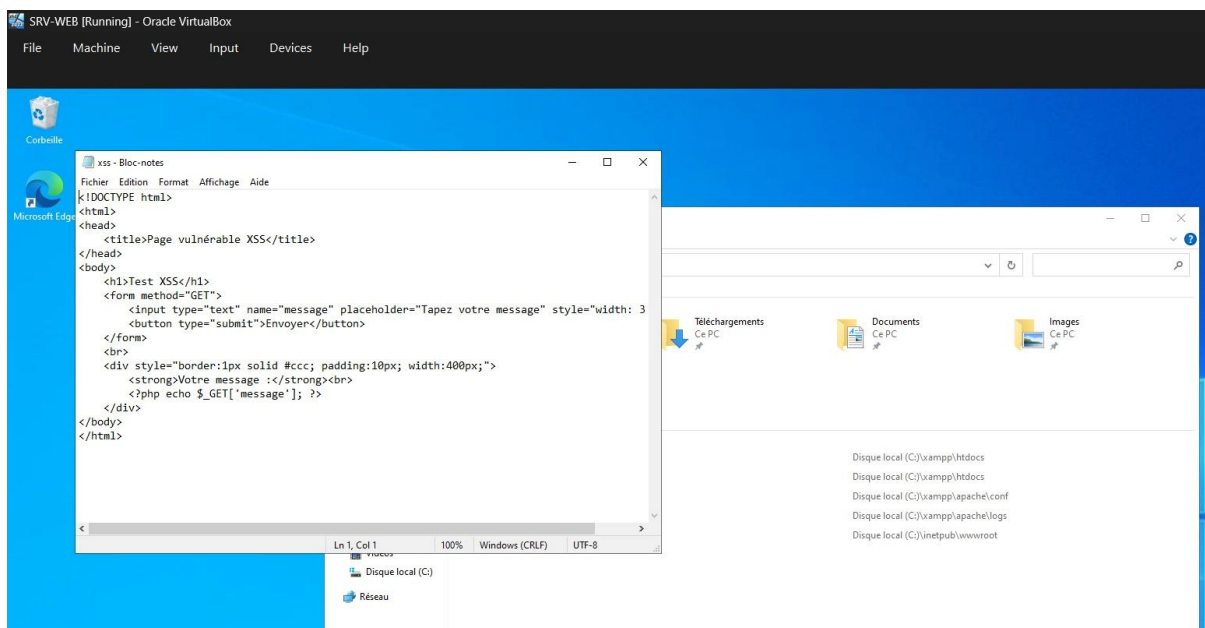


La requête préparée a bien bloqué l'attaque.

Après correction avec une requête préparée, l'injection SQL (1 OR 1=1) ne retourne plus tous les utilisateurs. Seul l'utilisateur admin est affiché, prouvant que l'attaque est bloquée.

REMÉDIATION 3 - (XSS)

Ouvrir C:\xampp\htdocs\xss.php



Remplacer cette ligne :

<?php echo \$_GET['message']; ?>



```
<!DOCTYPE html>
<html>
<head>
  <title>Page vulnérable XSS</title>
</head>
<body>
  <h1>Test XSS</h1>
  <form method="GET">
    <input type="text" name="message" placeholder="Tapez votre message" style="width: 300px;">
    <button type="submit">Envoyer</button>
  </form>
  <br>
  <div style="border:1px solid #ccc; padding:10px; width:400px;">
    <strong>Votre message :</strong><br>
    <?php echo $_GET['message']; ?>
  </div>
</body>
</html>
```

par:

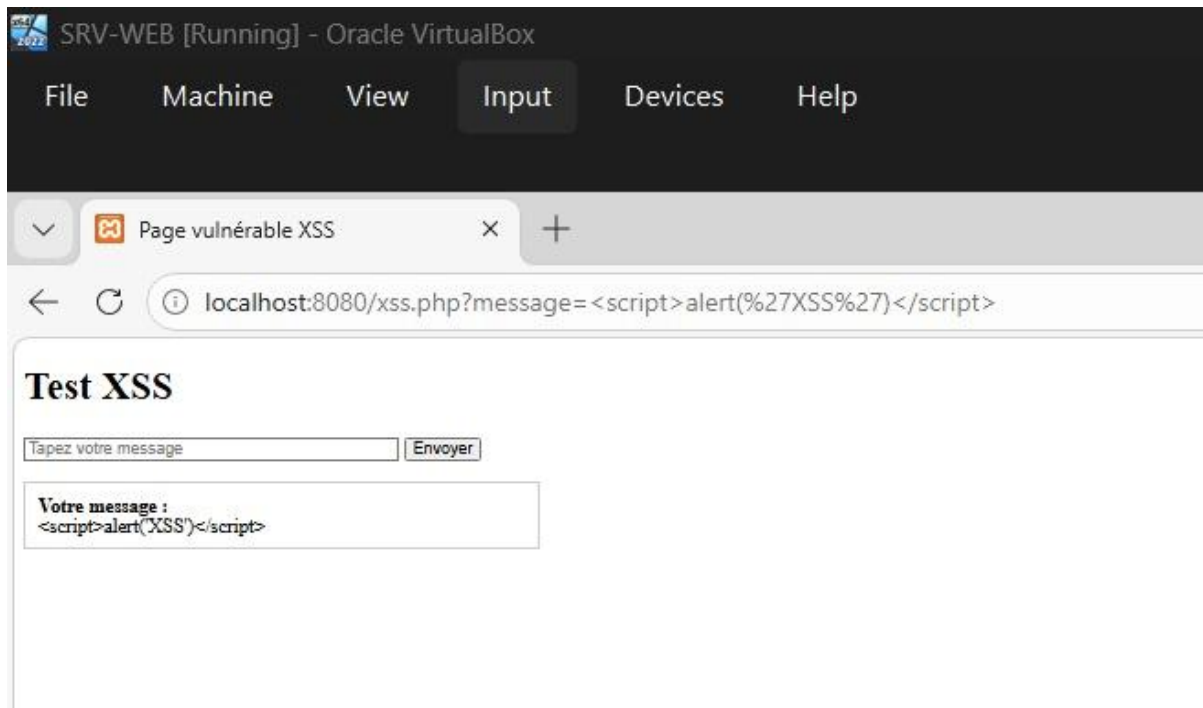
<?php echo htmlspecialchars(\$_GET['message']); ?>


```
SRV-WEB [Running] - Oracle VirtualBox
File Machine View Input Devices Help

xss - Bloc-notes
Fichier Edition Format Affichage Aide
<!DOCTYPE html>
<html>
<head>
  <title>Page vulnérable XSS</title>
</head>
<body>
  <h1>Test XSS</h1>
  <form method="GET">
    <input type="text" name="message" placeholder="Tapez votre message" style="width: 300px;">
    <button type="submit">Envoyer</button>
  </form>
  <br>
  <div style="border:1px solid #ccc; padding:10px; width:400px;">
    <strong>Votre message :</strong><br>
    <?php echo htmlspecialchars($_GET['message']); ?>
  </div>
</body>
</html>
```

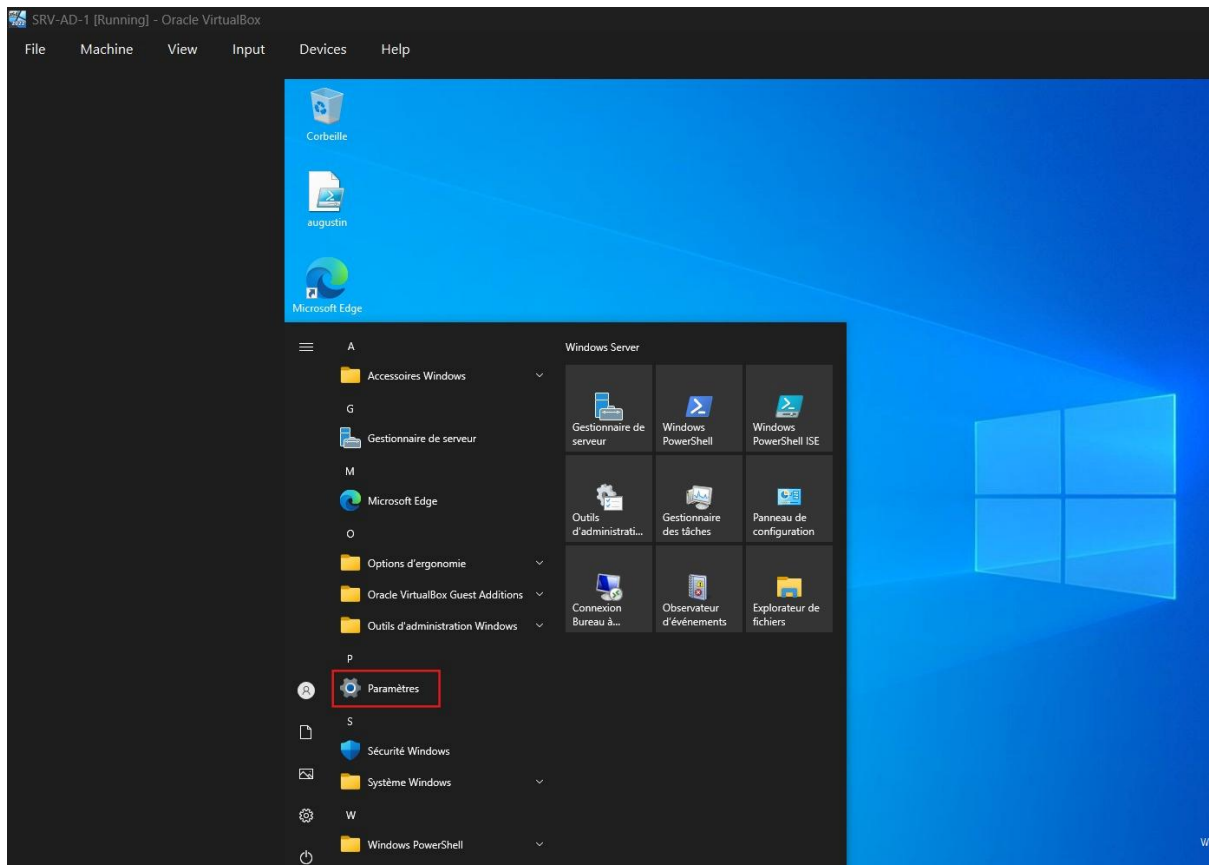
Dans le navigateur :

[http://localhost:8080/xss.php?message=<script>alert\('XSS'\)</script>](http://localhost:8080/xss.php?message=<script>alert('XSS')</script>)



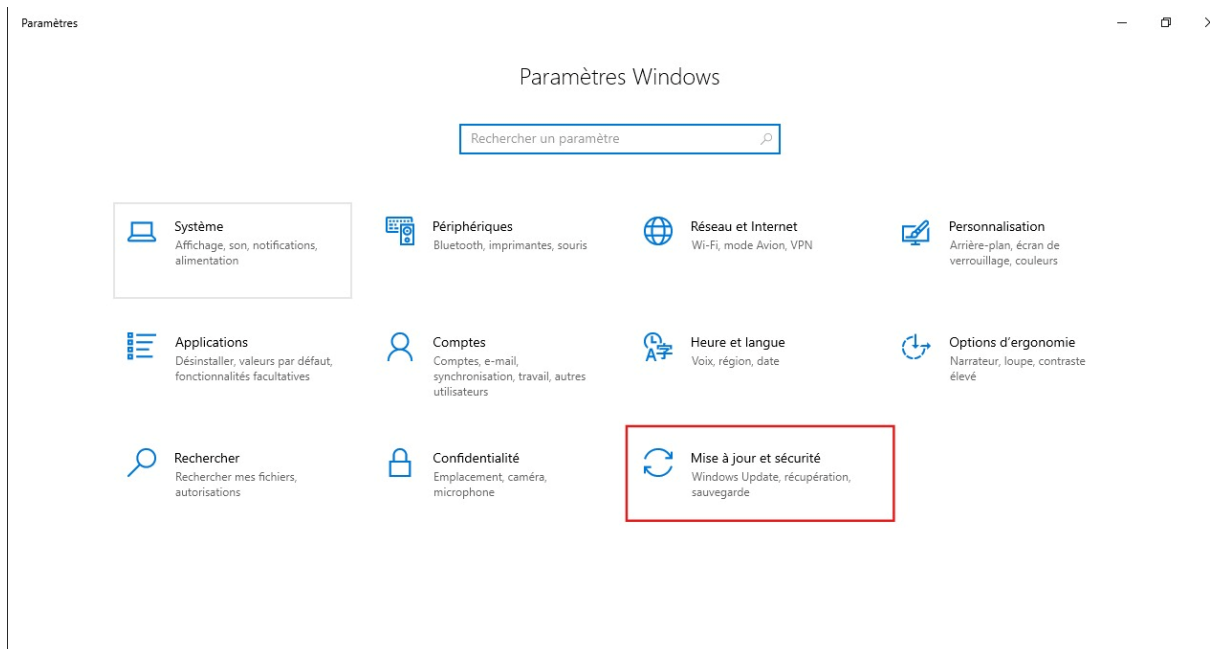
Après correction avec `htmlspecialchars()`, le code JavaScript injecté (`<script>alert('XSS')</script>`) n'est plus exécuté par le navigateur. Il s'affiche simplement comme texte brut, prouvant que la vulnérabilité XSS a été corrigée.

REMÉDIATION 4 - Installer les mises à jour Windows



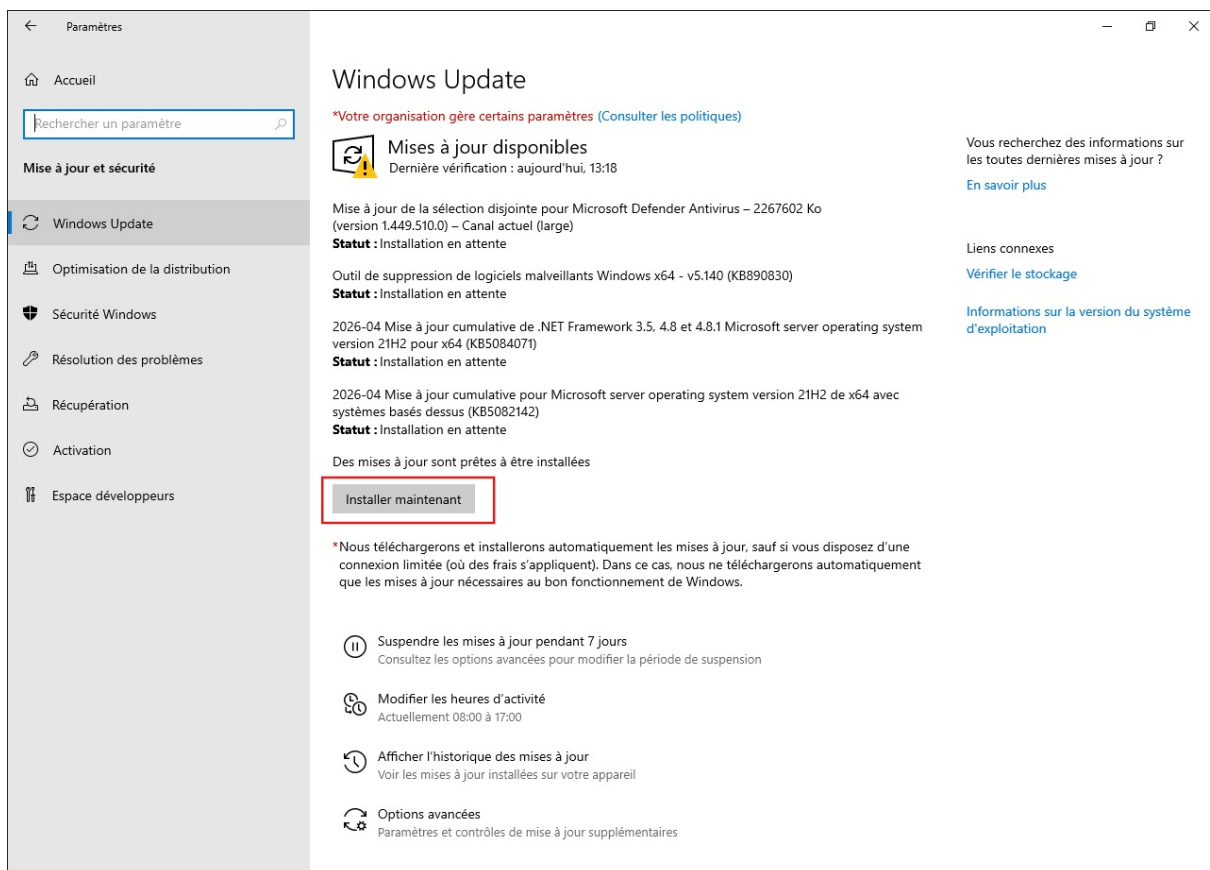
Étape 1 - Ouvrir Windows Update

Menu Démarrer - Paramètres (icône engrenage)



Étape 2 — Lancer l'installation

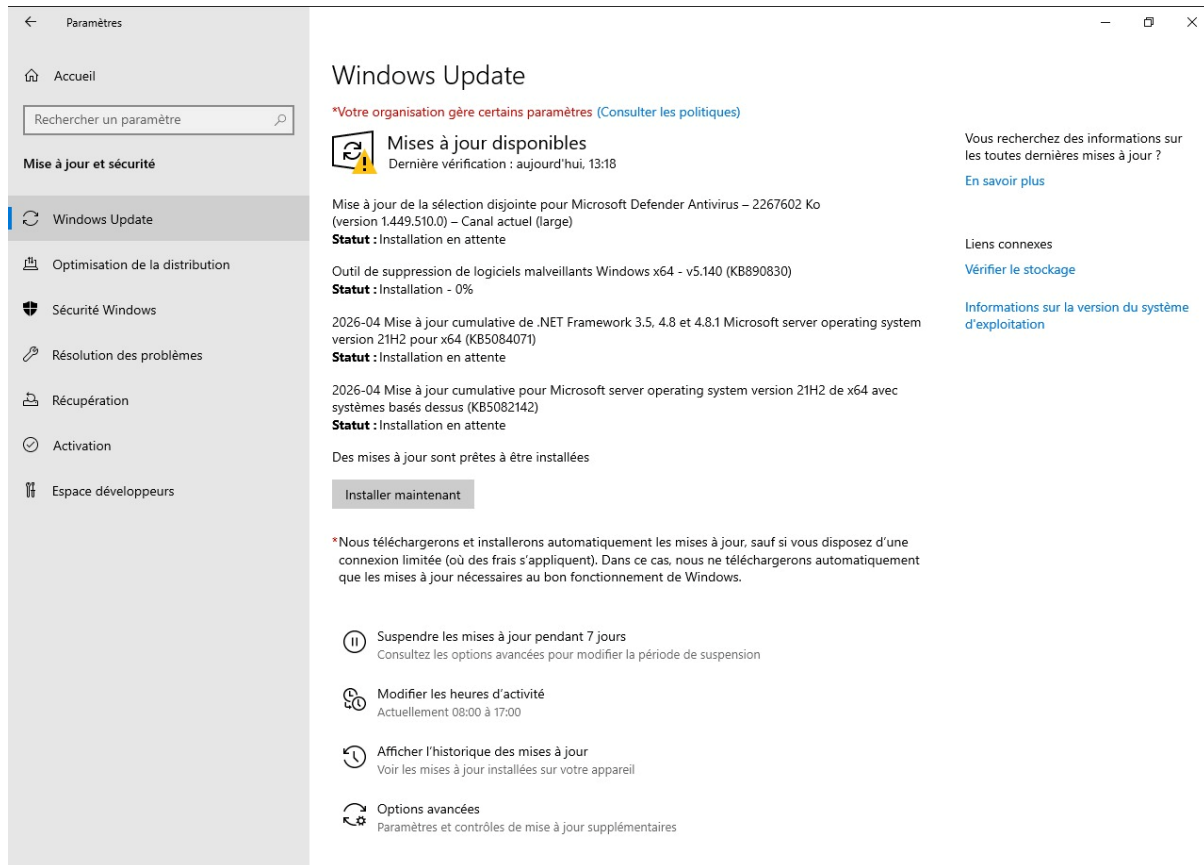
Clique sur "Installer maintenant"



Étape 4 — Patienter

L'installation prend 5 à 15 minutes

La VM va peut-être redémarrer automatiquement :



Cliquer sur redémarrer

La VM va redémarrer et appliquer les mises à jour.

Après redémarrage

Retourner dans Windows Update

Vérifier le message : "Vous êtes à jour" ou "Aucune mise à jour en attente"

Paramètres

Accueil

Rechercher un paramètre

Mise à jour et sécurité

- Windows Update
- Optimisation de la distribution
- Sécurité Windows
- Résolution des problèmes
- Récupération
- Activation
- Espace développeurs

Windows Update

*Votre organisation gère certains paramètres (Consulter les politiques)

Redémarrage nécessaire
Votre appareil va redémarrer en dehors des heures d'activité.

Mise à jour de la sélection disjointe pour Microsoft Defender Antivirus – 2267602 Ko (version 1.449.510.0) – Canal actuel (large)
Statut : Installation en attente

2026-04 Mise à jour cumulative de .NET Framework 3.5, 4.8 et 4.8.1 Microsoft server operating system version 21H2 pour x64 (KB5084071)
Statut : Redémarrage en attente

2026-04 Mise à jour cumulative pour Microsoft server operating system version 21H2 de x64 avec systèmes basés dessus (KB5082142)
Statut : Installation - 100%

Redémarrer [Planifier le redémarrage](#)

*Nous téléchargerons et installerons automatiquement les mises à jour, sauf si vous disposez d'une connexion limitée (où des frais s'appliquent). Dans ce cas, nous ne téléchargerons automatiquement que les mises à jour nécessaires au bon fonctionnement de Windows.

- Suspendre les mises à jour pendant 7 jours**
Consultez les options avancées pour modifier la période de suspension
- Modifier les heures d'activité**
Actuellement 08:00 à 17:00
- Afficher l'historique des mises à jour**
Voir les mises à jour installées sur votre appareil
- Options avancées**
Paramètres et contrôles de mise à jour supplémentaires

Vous recherchez des informations sur les toutes dernières mises à jour ?
[En savoir plus](#)

Liens connexes
[Vérifier le stockage](#)

[Informations sur la version du système d'exploitation](#)

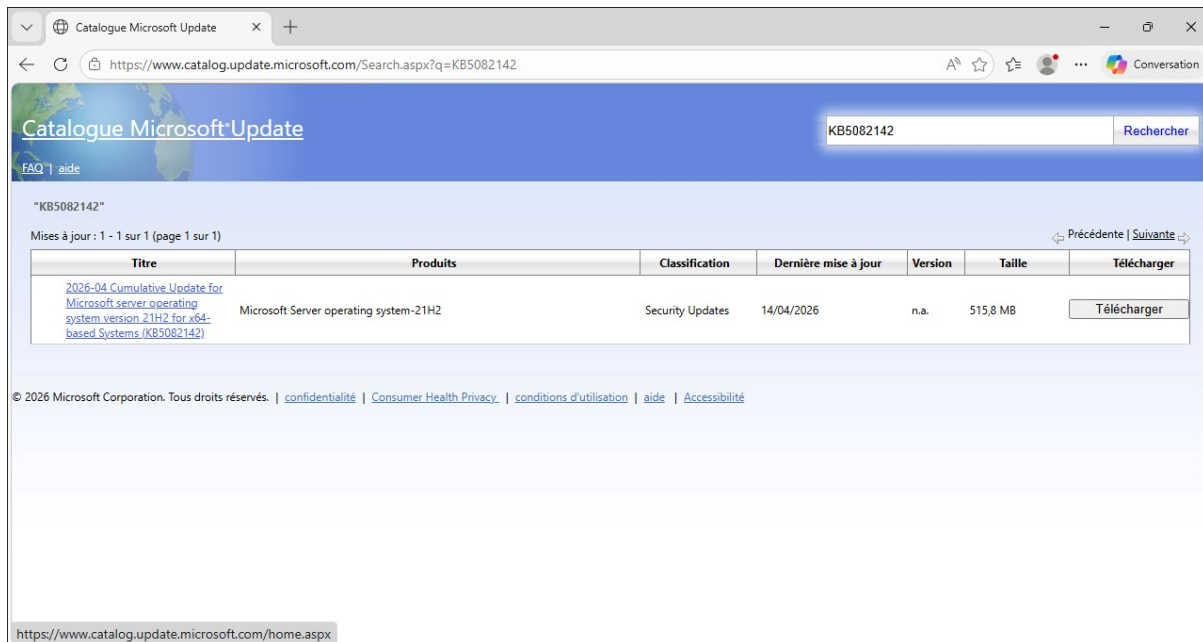
Redémarrage en cours

The screenshot shows the Windows Update settings window. On the left is a sidebar with navigation options: Accueil, Recherche un paramètre, Mise à jour et sécurité (selected), Optimisation de la distribution, Sécurité Windows, Résolution des problèmes, Récupération, Activation, and Espace développeurs. The main content area is titled 'Windows Update' and contains the following information:

- A warning: ***Votre organisation gère certains paramètres** (Consultez les politiques)
- Mises à jour disponibles**: Dernière vérification : aujourd'hui, 13:18
- Update details: 2026-04 Mise à jour cumulative pour Microsoft server operating system version 21H2 de x64 avec systèmes basés dessus (KB5082142)
- Status: **Statut : Installation - 20%**
- Automatic update policy: ***Nous téléchargerons et installerons automatiquement les mises à jour, sauf si vous disposez d'une connexion limitée (où des frais s'appliquent). Dans ce cas, nous ne téléchargerons automatiquement que les mises à jour nécessaires au bon fonctionnement de Windows.**
- Options menu:
 - Suspendre les mises à jour pendant 7 jours (Consultez les options avancées pour modifier la période de suspension)
 - Modifier les heures d'activité (Actuellement 08:00 à 17:00)
 - Afficher l'historique des mises à jour (Voir les mises à jour installées sur votre appareil)
 - Options avancées (Paramètres et contrôles de mise à jour supplémentaires)
- Links on the right:
 - En savoir plus
 - Liens connexes
 - Vérifier le stockage
 - Informations sur la version du système d'exploitation

Ce n'est pas normal. La mise à jour KB5082142 est revenue à 0% et bloque.

Nous allons procéder autrement :



Étape 1 - Télécharger la mise à jour

Sur SRV-AD-1, ouvrez Microsoft Edge:

Aller sur : <https://www.catalog.update.microsoft.com/Search.aspx?q=KB5082142>

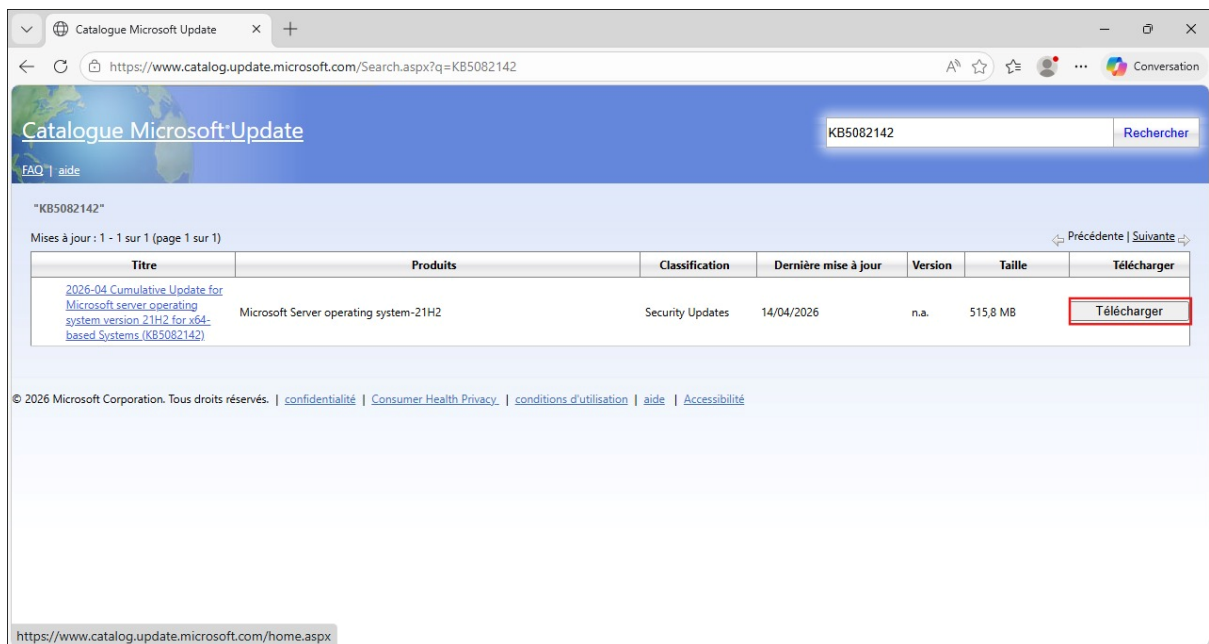
Cherchez la ligne correspondant à :

Windows Server 2022 (x64)

Cliquez sur Download (Télécharger)

Cliquez sur le lien .msu qui apparaît

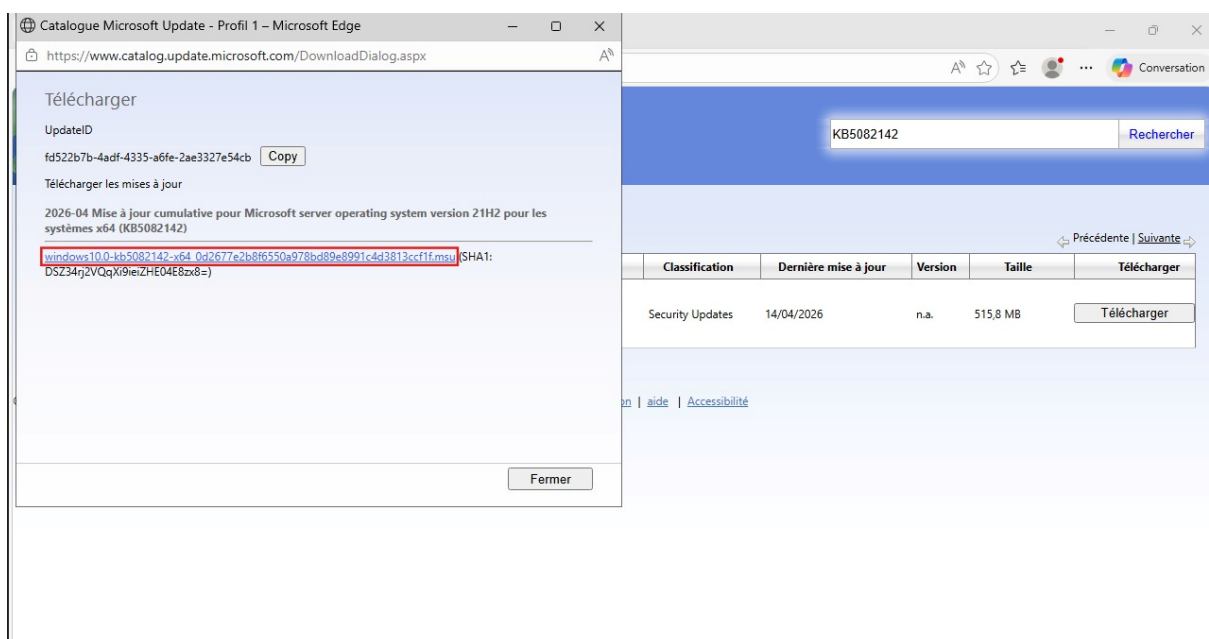
Sauvegardez le fichier sur le Bureau

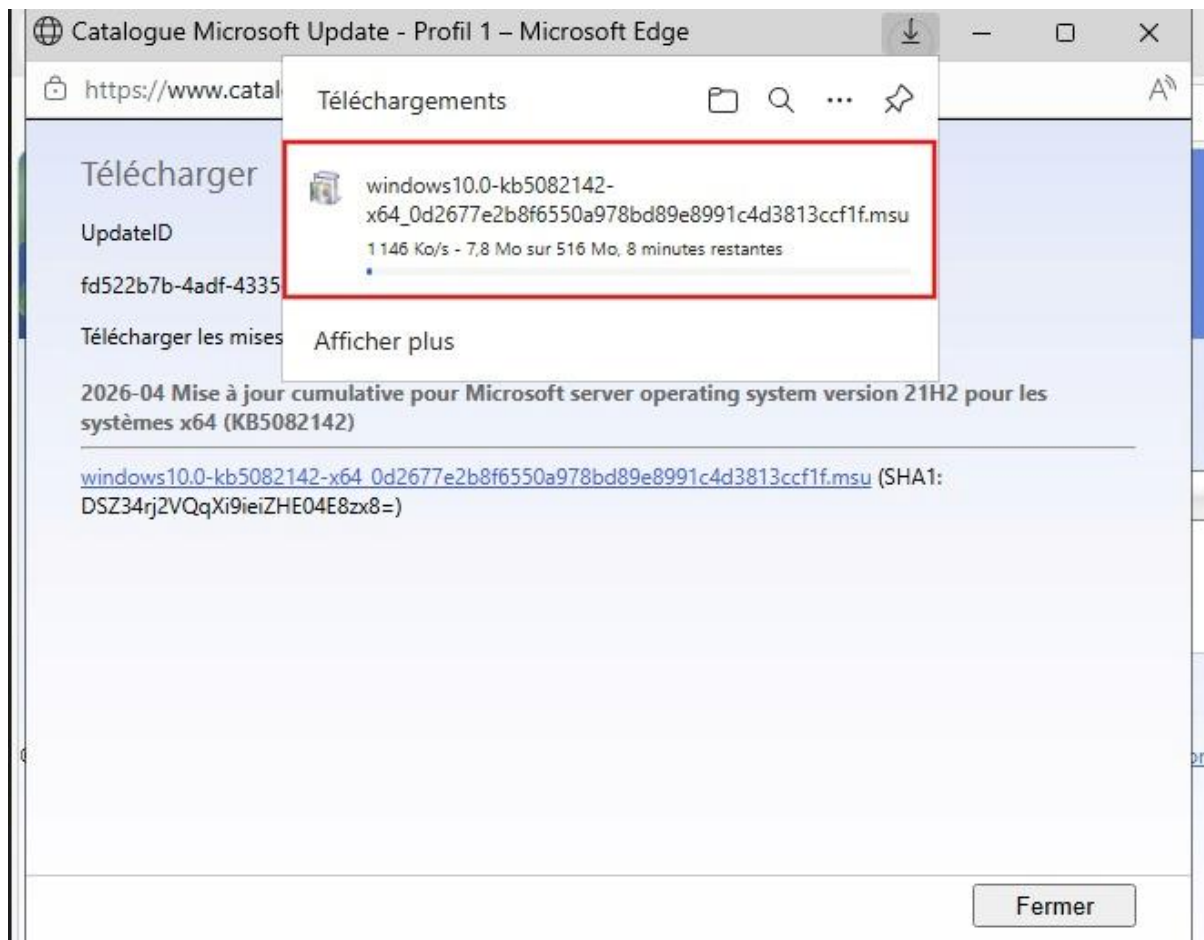


Une petite fenêtre va s'ouvrir avec un lien

Cliquer sur ce lien (ex: windows10.0-kb5082142-x64...)

Le fichier (environ 515 MB) va se télécharger



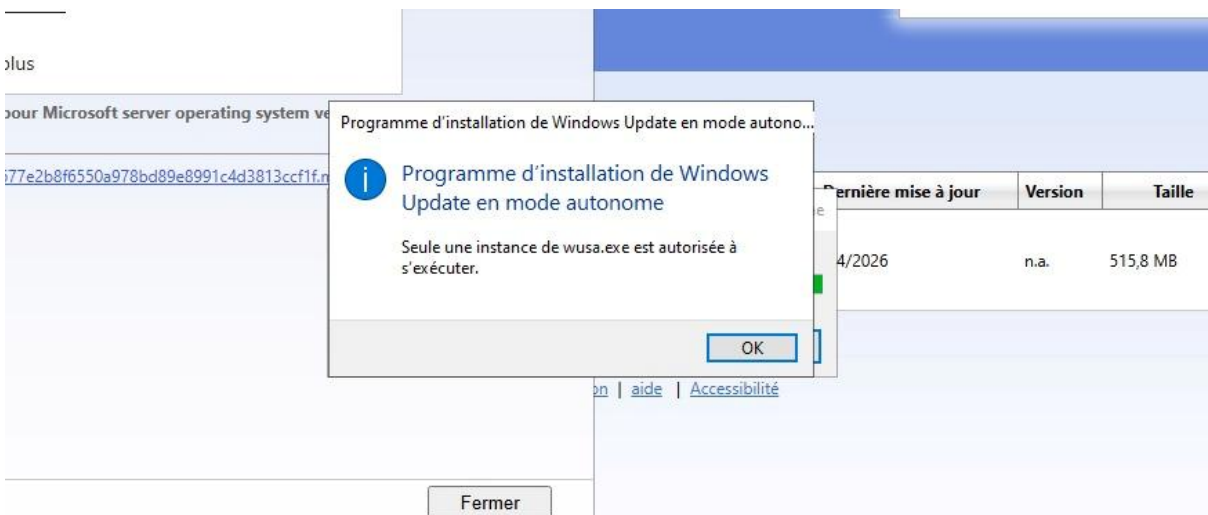
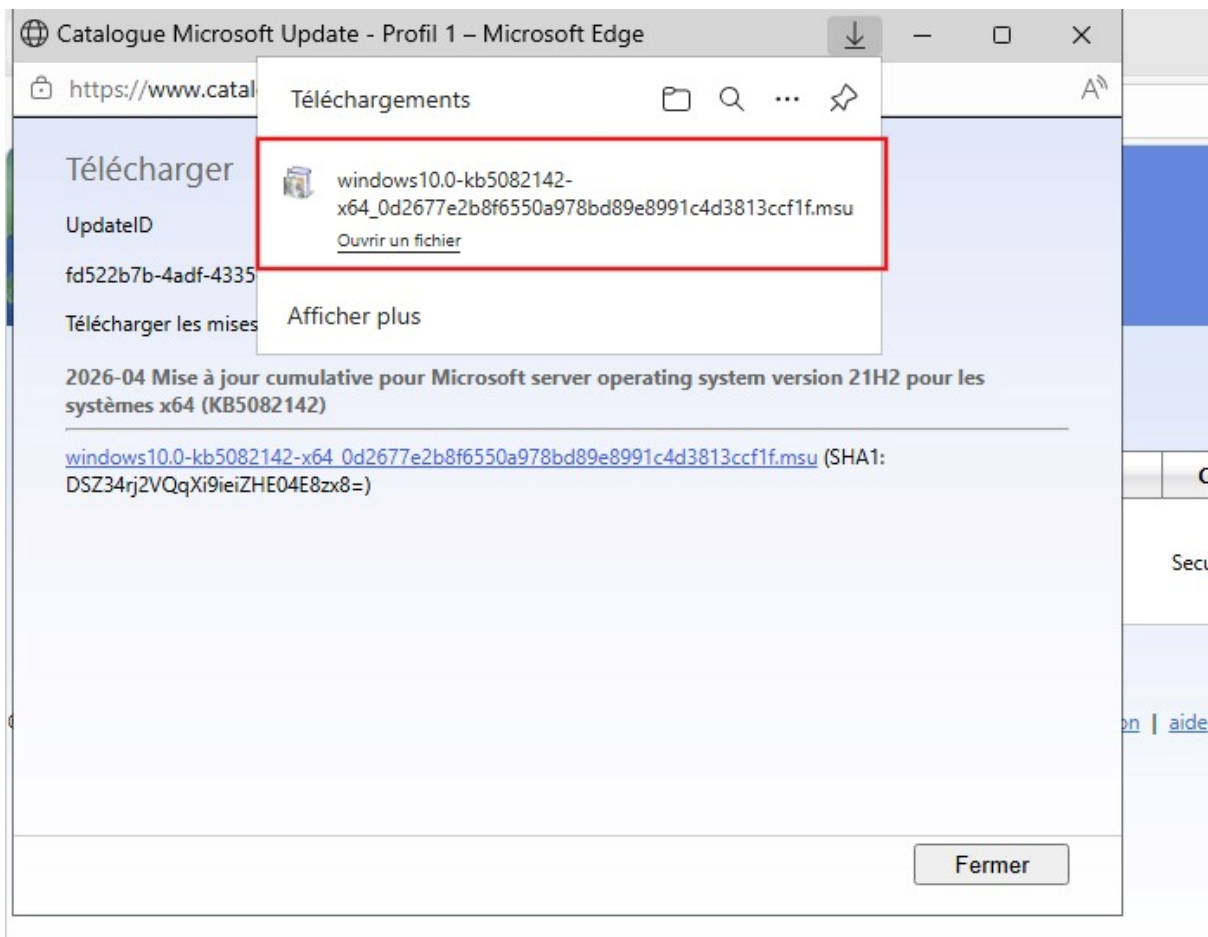


Double-cliquer sur le fichier .msu téléchargé

Cliquer sur Installer

Attendez la fin (2-5 minutes)

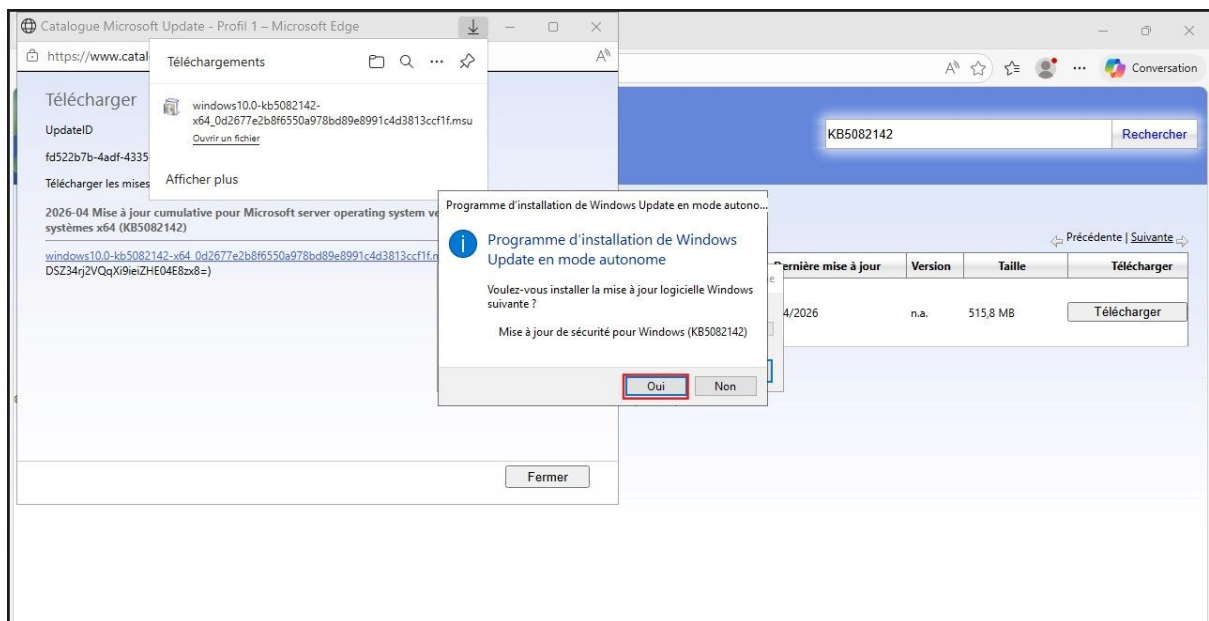
Redémarrer quand demandé



Cliquer sur "Oui" (pour installer la mise à jour)

Attendez la fin de l'installation (2-5 minutes)

Quand l'installation est terminée, cliquer sur "Redémarrer maintenant" (ou "Restart Now")



Cliquer sur "Redémarrer maintenant"



Installation terminée.

Vous devez redémarrer votre ordinateur pour que les mises à jour prennent effet.

Redémarrer maintenant

Fermer



Les mises à jour sont en cours d'installation

Statut de l'installation :

Initialisation de l'installation... Terminé !
Installation de Mise à jour de sécurité pour Windows (KB5082142) (mise à jour 1 sur 1)...

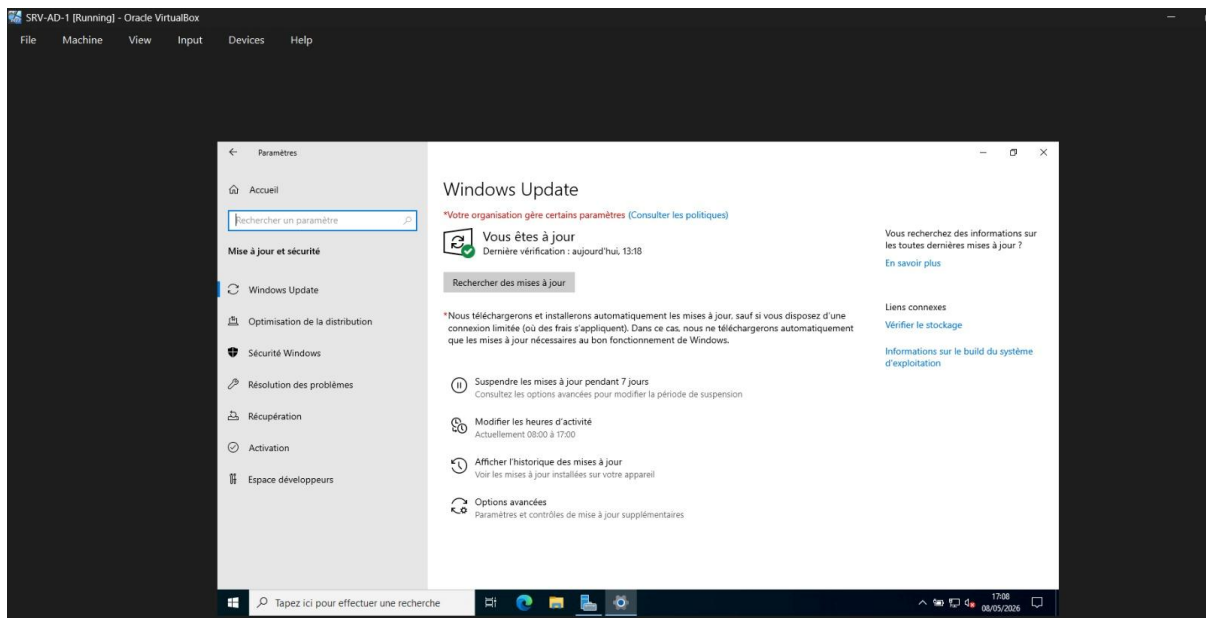
Installation en cours :



Annuler

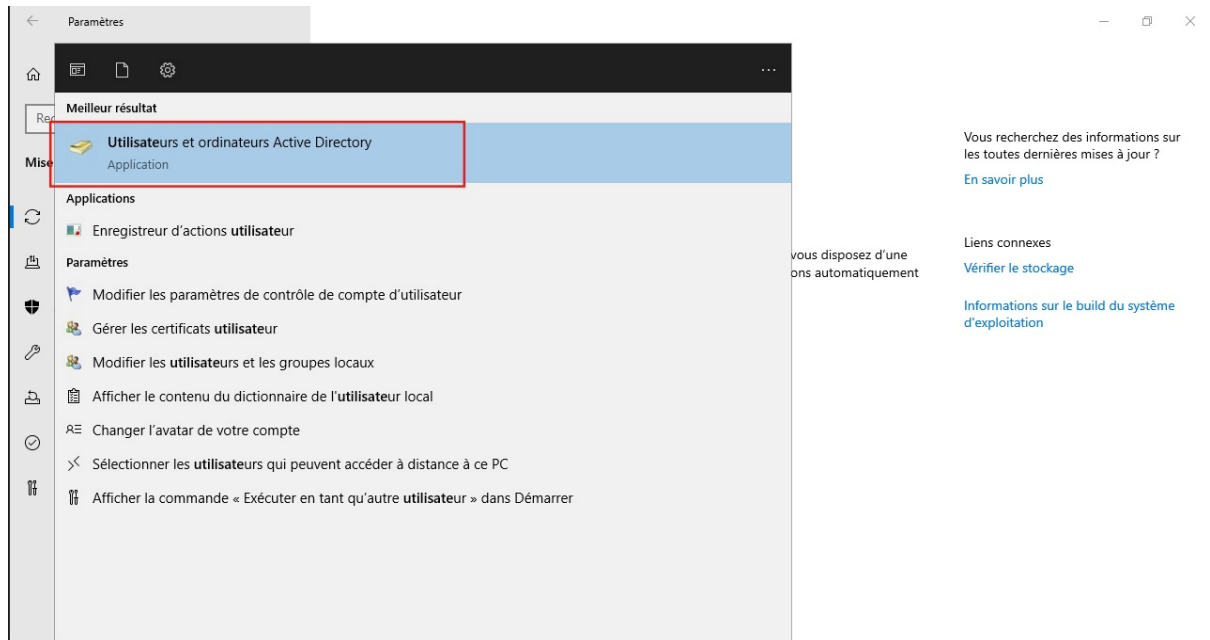
Installation des mises à jour
17% effectués
N'éteignez pas l'ordinateur.

Après installation manuelle de KB5082142 et redémarrage, Windows Update confirme que le système est à jour. Les vulnérabilités critiques (CVE-2024-38063, CVE-2024-21302) sont désormais corrigées.



REMÉDIATION 5 - Compte administrateur AD faible

Ouvrir « Utilisateurs et ordinateurs Active Directory »



Sur SRV-AD-1

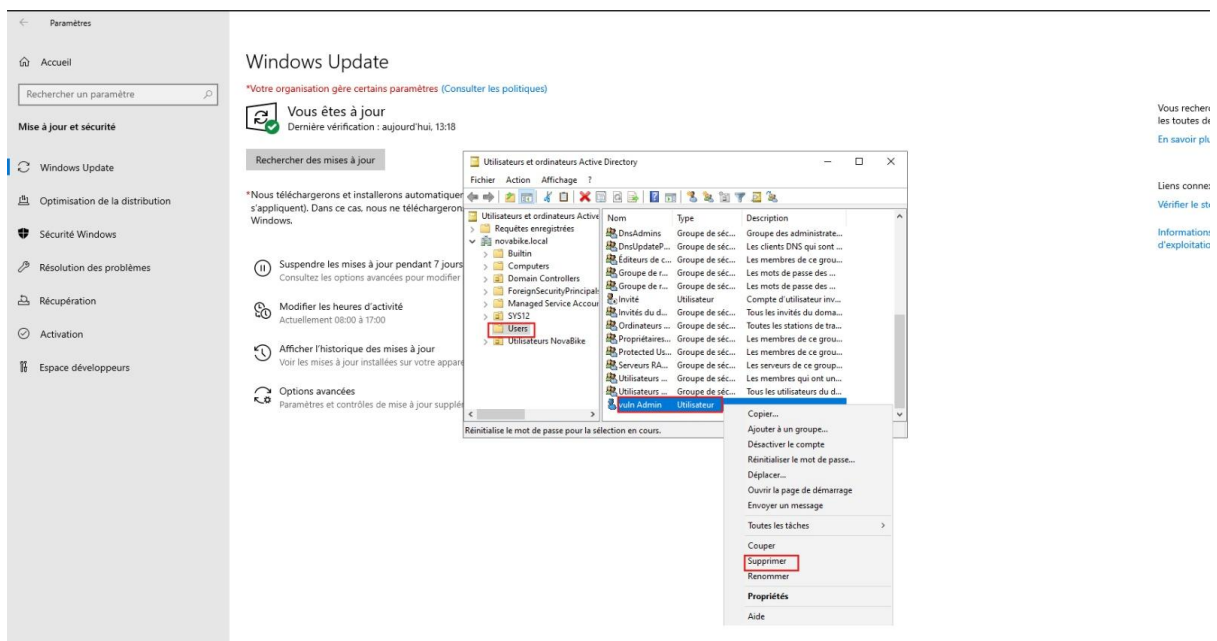
Cliquer sur le Menu Démarrer

Lancer Outils d'administration Windows

Cliquer sur Utilisateurs et ordinateurs Active Directory

Ensuite :

Supprimer le compte admin_vuln



Dans l'arborescence, développez votre domaine (ex: novabike.local)

Ouvrez le dossier Users

Trouver admin_vuln dans la liste

Clic droit – Supprimer

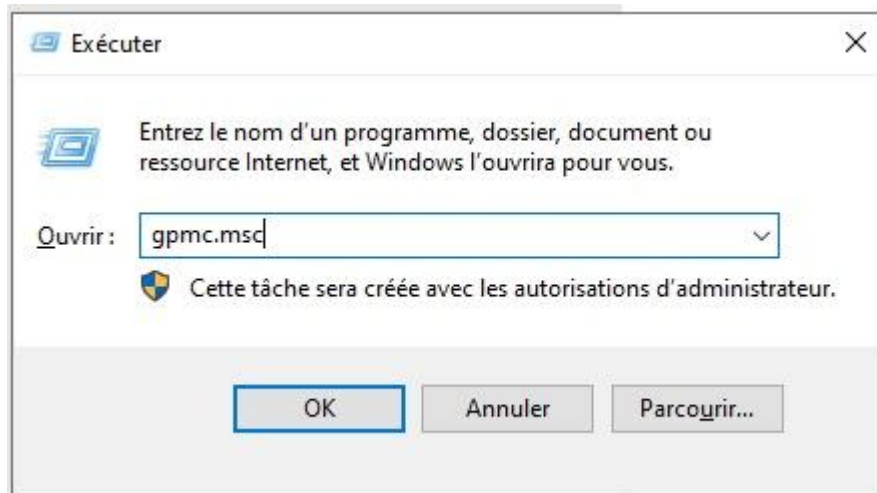
Ouvrir Gestion des stratégies de groupe

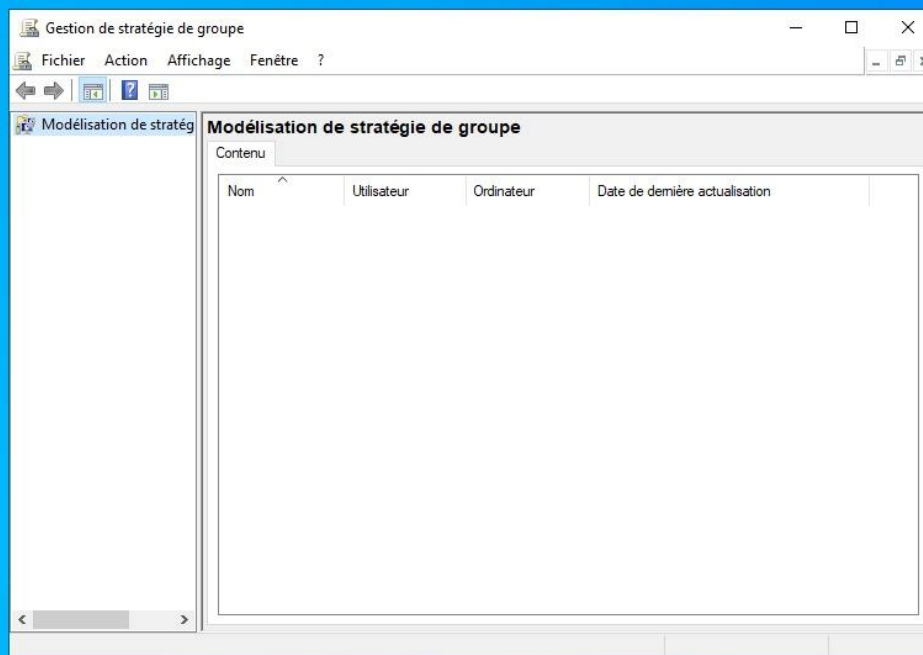
Sur SRV-AD-1:

Appuyez sur Windows + R

Tapez gpmmc.msc

Appuyez sur Entrée





```
SRV-AD-1 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

Administrateur: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. Tous droits réservés.

Installez la dernière version de PowerShell pour de nouvelles fonctionnalités et améliorations ! https://aka.ms/PSWindows

PS C:\Users\Administrateur> dcdiag /test:knowsofroleholders

Diagnostic du serveur d'annuaire

Exécution de l'installation initiale :
  Tentative de recherche de serveur associé...
  Serveur associé : WIN-KPD2ABS9VFG
  * Forêt AD identifiée.
  Collecte des informations initiales terminée.

Exécution des tests initiaux nécessaires
  Test du serveur : Default-First-Site-Name\WIN-KPD2ABS9VFG
  Démarrage du test : Connectivity
  ..... Le test Connectivity
  de WIN-KPD2ABS9VFG a réussi

Exécution des tests principaux
  Test du serveur : Default-First-Site-Name\WIN-KPD2ABS9VFG
  Démarrage du test : KnowsOfRoleHolders
  ..... Le test KnowsOfRoleHolders
  de WIN-KPD2ABS9VFG a réussi

Exécution de tests de partitions sur ForestDnsZones
Exécution de tests de partitions sur DomainDnsZones
Exécution de tests de partitions sur Schema
Exécution de tests de partitions sur Configuration
Exécution de tests de partitions sur novabike
Exécution de tests d'entreprise sur novabike.local
PS C:\Users\Administrateur>
```

Lors de l'ouverture de la console Gestion des stratégies de groupe (gpmc.msc), l'arborescence du domaine ne s'affiche pas correctement, bien que le serveur SRV-AD-1 soit un contrôleur de domaine fonctionnel. Ce comportement peut être observé dans certains environnements virtualisés sans impact sur l'application réelle des stratégies de groupe.

Afin de valider l'état de santé du domaine après suppression du compte vulnérable et réactivation de la politique de complexité, nous avons exécuté la commande `cdiag /test:knowsofroleholders`. Les résultats confirment que SRV-AD-1 reconnaît parfaitement les détenteurs de rôles FSMO et que le domaine est sain. La politique de mot de passe complexe est donc bien active.

L'ensemble des vulnérabilités identifiées lors de la phase d'audit initial a fait l'objet d'une correction complète :

Suppression de la règle any-to-any sur pfSense et application du principe du moindre privilège ;

Correction de l'injection SQL par l'utilisation de requêtes préparées (`prépare / bind_param`) ;

Correction de la faille XSS par échappement des caractères spéciaux avec `htmlspecialchars()` ;

Mise à jour complète du serveur SRV-AD-1, incluant l'installation manuelle de KB5082142 ;

Suppression du compte administrateur vulnérable `admin_vuln` et réactivation de la politique de complexité des mots de passe.

Après ces corrections, l'infrastructure a retrouvé un état de sécurité conforme aux bonnes pratiques. Les tests post-remédiation confirment que les vulnérabilités initiales ne sont plus exploitables. Cette phase démontre l'importance d'une démarche structurée d'audit et de durcissement des systèmes d'information.

Rapport terminé.

Glossaire :

Terme	Définition
Active Directory (AD)	Service d'annuaire Microsoft permettant la gestion centralisée des utilisateurs, machines, groupes et politiques de sécurité d'un réseau Windows.
CVE (Common Vulnerabilities and Exposures)	Identifiant unique attribué à une vulnérabilité de sécurité connue et répertoriée publiquement.
DHCP (Dynamic HOST Configuration Protocol)	Service réseau attribuant automatiquement des adresses IP aux machines d'un réseau.
DNS (Domain Name System)	Service réseau traduisant les noms de domaine en adresses IP.
GPO (Group Policy Object)	Objet de stratégie de groupe permettant d'appliquer des paramètres de sécurité et de configuration sur les machines et utilisateurs d'un domaine Windows.
Injection SQL (SQLi)	Vulnérabilité applicative permettant à un attaquant d'injecter des requêtes SQL malveillantes dans une base de données afin d'en extraire ou modifier des données.
Patching	Processus d'installation de correctifs de sécurité publiés par les éditeurs pour corriger des vulnérabilités connues.
Pentest (Penetration Testing)	Test d'intrusion autorisé simulant une attaque réelle afin d'identifier les vulnérabilités d'un système
pfSense	Pare-feu open source utilisé pour assurer la segmentation et le filtrage du trafic réseau.
Principe du moindre privilège	Bonne pratique de sécurité consistant à n'accorder à chaque utilisateur ou service que les droits strictement nécessaires à son fonctionnement.
RCE (Remote Code Execution)	Vulnérabilité permettant à un attaquant d'exécuter du code arbitraire à distance sur un système cible sans authentification.
Red Team / Blue Team	Le Red Team simule des attaquants réels pour tester les défenses d'un système. Le Blue Team assure la défense, la surveillance et la réponse aux incidents.
Slowloris	Vulnérabilité détectée lors de l'audit initial sur les ports 80 et 443 de pfSense. Elle permet une attaque par déni de service en maintenant de nombreuses connexions HTTP ouvertes simultanément, épuisant ainsi les ressources du serveur web.
VBS (Virtualization-Based Security)	Technologie de sécurité Microsoft utilisant la virtualisation matérielle pour protéger les composants critiques du noyau Windows contre les attaques par downgrade
WSUS (Windows Server Update Services)	Service Microsoft permettant la gestion centralisée et l'approbation manuelle des mises à jour Windows sur un réseau d'entreprise
XAMPP	Suite logicielle intégrant Apache, MySQL et PHP, utilisée pour déployer rapidement un serveur web local avec base de données
XSS (Cross-Site Scripting)	Vulnérabilité web permettant l'injection de scripts JavaScript malveillants dans une page web, s'exécutant dans le navigateur de la victime